

LOGMERRY · AUTOMATISATION & IA POUR LES ENTREPRISES

Livrables de soutenance

Mini CRM et cockpit d'activité avec assistant IA connecté à mes notes, conçu et déployé en no-code et IA.

SOUTENANCE · 16 NOVEMBRE 2026

AUTEUR
ALEX PERICAT

VERSION
13 NOVEMBRE 2026

FORMATION
BACHELOR CHEF DE PROJET NO-CODE ET IA

Sommaire

Treize livrables, un chapitre chacun, et une annexe. Les mentions « À confirmer » signalent ce qui n'est pas vérifié.

01 Schéma de données 5

- Vue d'ensemble 5
- Modèle conceptuel (MCD) 5
- Dictionnaire de données 8
- Règles d'intégrité transversales 10
- Évolution du schéma 11

02 Workflows : saisie des documents et gestion de l'IA (RAG) 12

- Les trois workflows 12
- A. Saisie et indexation d'une note 13
- B. Question à l'assistant 15
- C. Propositions de l'IA 16
- Workflows métier existants 16
- Événements qui déclenchent un traitement 20
- Délais et niveaux de service (SLA) 21
- MCP : ce qu'il en est 21
- Limites et suite 21

03 UX, maquettes et système de design 22

- Principes 22
- Architecture de l'information 22
- Parcours clés 23
- Système de design 24
- Accessibilité 25
- Adaptation aux écrans 26
- Gabarits et structure des pages 26
- Aperçu de l'application réelle 28
- Maquettes 30
- Points ouverts de la conception 30

04 Intégration : API Supabase et authentification 31

- Vue d'ensemble des échanges 31
- Les trois formes d'appel 32
- Mappings 34
- Authentification 37
- Contrat de sécurité de l'intégration 38
- Délais, erreurs et reprises 38
- Ce qui n'existe pas 38
- Limites et suite 39

05 Qualité de service 40

Comment lire les chiffres 40
Délais mesurés 40
Plafonds et délais réglés dans le code 41
Objectifs proposés 41
Contrôles automatiques à chaque envoi 42
Observabilité : ce qui existe 42
Ce qui n'existe pas 44
Modes dégradés 44
Limites et suite 44

06 Démonstration de l'application 45

Où et comment 45
Ce que la production contient (et ne contient pas) 45
Avant de commencer : la liste de contrôle 46
Scénario 46
Rejeu du 9 novembre 2026 (production) 48
Ce qui peut mal tourner, et la réponse 48
Ce qui n'est pas démontrable aujourd'hui 49
Limites de ce chapitre 49

07 Rapport d'évaluation de l'assistant 50

Ce qui est évalué 50
Méthode 50
Résultats de qualité 51
Pertinence et hallucinations 51
Latence 51
Coût 52
Limites de cette évaluation 53
Reproduire la mesure 54

08 Registre des données et index RAG, gouvernance 55

Registre des données du RAG 55
L'index vectoriel 56
Cycle de vie d'une note dans l'index 57
Qui reçoit quoi : les flux vers des tiers 57
Gouvernance 58
Limites et suite 59

09 Garde-fous et conformité 60

Vue d'ensemble : trois lignes de défense 60
1. Avant l'appel à l'IA 60
2. Pendant l'appel 61
3. Après l'appel : vérification avant affichage 61
Ce que les tests prouvent 61
Données personnelles 62
Garde-fous de l'application hors IA 62
Manques et risques connus 63

10 Déploiement et retour arrière 64

De mon poste à la production 64
Ce que la CI contrôle 65

Configuration de production 66
Compte rendu de mise en production (état au 5 novembre 2026) 66
Mises en production du 12 novembre 2026 67
Retour arrière 68
Ce qui n'existe pas 68
Limites et suite 69

11 Sécurité d'accès : authentification, droits et secrets 70

Authentification 70
Matrice des droits 71
Comment c'est garanti dans la base 71
Tests qui le prouvent 72
Secrets 73
En-têtes de sécurité du site 73
Limites et suite 73

12 Continuité de service et reprise 74

Ce que l'offre gratuite garantit, et ne garantit pas 74
Objectifs de reprise, tels qu'ils sont aujourd'hui 74
Test de restauration du 12 novembre 2026 75
Reconstruire LogMerry de zéro 76
Exporter les données 76
Modes dégradés dans le code 76
Disponibilité et retour arrière 77
Scénarios et réponses 77
Ce qui reste à faire 78

13 Exploitation et conformité 79

1. Tableau de bord d'exploitation 79
2. Kit de support 80
3. Registre des traitements (RGPD), version synthétique 81
4. Mention d'information : projet à valider par le responsable de traitement 93
5. Limites connues et plan d'action 93

14 Annexe : purges automatiques (proposition, non activée) 97

Schéma de données



> *Ce que ce chapitre montre.* Le modèle de données de LogMerry : 22 tables dans le schéma `public`, toutes protégées par la sécurité par ligne (RLS). Il a été relu directement dans la base Supabase du projet le 4 novembre 2026, et non reconstitué de mémoire.

01.1

Vue d'ensemble

LogMerry sépare trois mondes, qui ne se mélangent jamais.

- **Mes données de travail** : notes, clients, missions, factures, échéances. Chaque ligne appartient à un compte (`owner_id`).
- **L'assistant IA** : les extraits de mes notes, transformés en vecteurs, et l'historique des échanges avec leurs sources.
- **Ce qui est public** : les réalisations publiées avec l'accord du client et le formulaire de contact. Le public n'a accès à aucune table : seulement à deux vues en lecture et à une fonction.

Toutes les tables pointent vers `auth.users`, la table des comptes gérée par Supabase Auth. C'est ce lien qui rend possible l'isolation entre comptes.

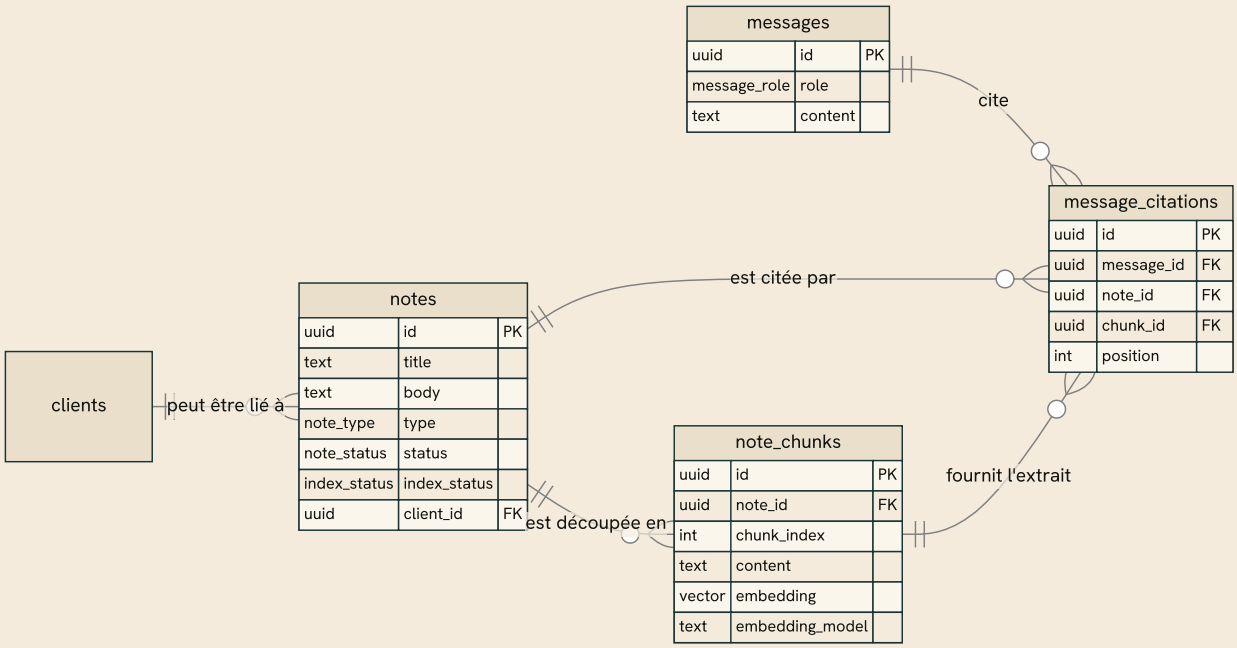
DOMAINE	TABLES	RÔLE
Connaissances et assistant	`notes`, `note_chunks`, `messages`, `message_citations`	Base de connaissances interrogeable par l'IA, historique et citations
Clients et missions agiles	`clients`, `contacts`, `missions`, `sprints`, `user_stories`, `tasks`	CRM léger et pilotage des missions en agile
Finances et échéances	`quotes`, `invoices`, `payments`, `deadlines`, `task_checks`, `regulatory_rules`, `professional_profile`	Suivi des devis, factures, encaissements, obligations administratives
Portfolio, contact, technique	`realisations`, `realisation_images`, `contact_form_settings`, `contact_submissions`, `ai_calls`	Vitrine publique, formulaire de contact, quota d'appels à l'IA

01.2

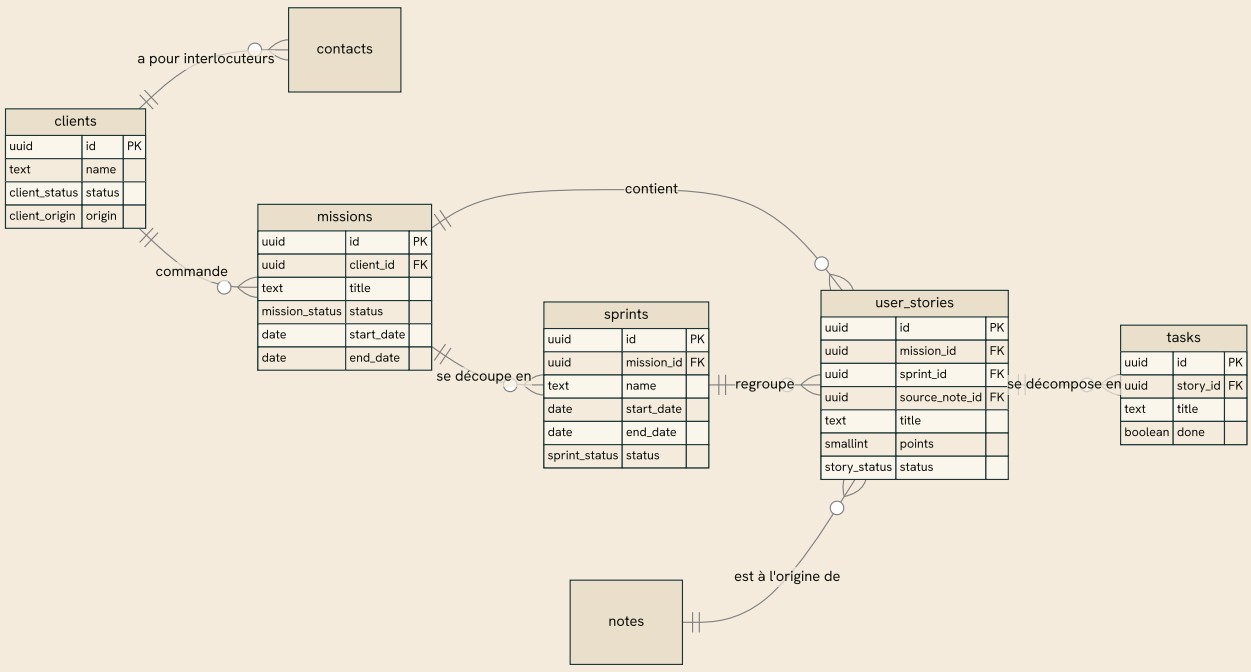
Modèle conceptuel (MCD)

Chaque diagramme montre les liens entre les tables d'un domaine. Le lien vers `auth.users` (le propriétaire) existe sur toutes les tables et n'est pas redessiné à chaque fois.

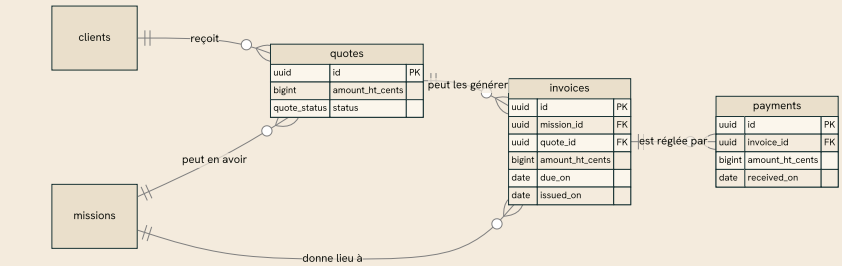
Connaissances et assistant

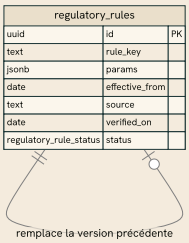


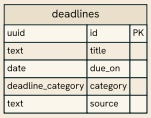
Clients et missions agiles

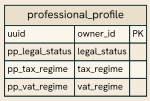


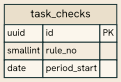
Finances et échéances



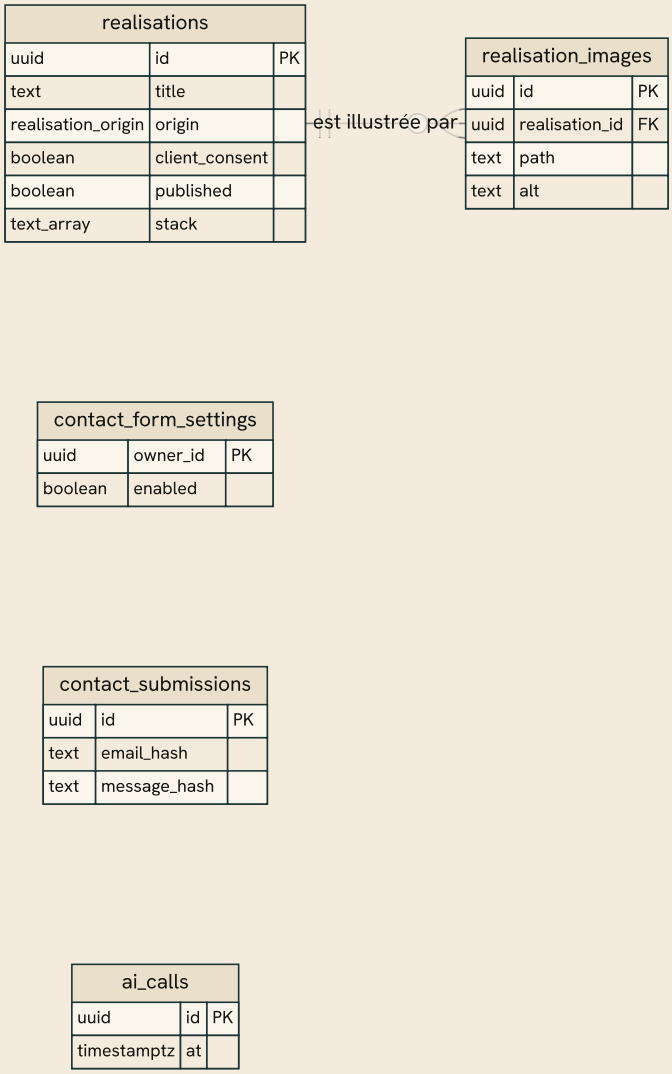








Portfolio public, contact et technique



01.3

Dictionnaire de données

Les colonnes communes ne sont pas répétées : `id` (identifiant unique généré), `owner_id` (propriétaire, valeur par défaut `auth.uid()`), `created_at` et `updated_at`.

Connaissances et assistant

TABLE	RÔLE	COLONNES PRINCIPALES	RÈGLES D'INTÉGRITÉ
`notes`	Une note de la base de connaissances	`title`, `body`, `type` (note, procédure, modèle, FAQ), `status` (brouillon, active), `index_status` (en attente, indexée, échec), `client_id` (facultatif), `search` (index plein texte français généré)	Titre de 1 à 200 caractères, texte de 50 000 caractères au plus ; le client lié doit appartenir au même propriétaire
`note_chunks`	Un extrait d'une note, avec son vecteur	`note_id`, `chunk_index`, `content`, `embedding` (vecteur), `embedding_model`	Index positif, contenu non vide, modèle d'embeddings obligatoire

TABLE	RÔLE	COLONNES PRINCIPALES	RÈGLES D'INTÉGRITÉ
`messages`	Un message de l'historique du chat	`role` (utilisateur, assistant), `content`	De 1 à 20 000 caractères
`message_citations`	Les sources d'une réponse	`message_id`, `note_id`, `chunk_id`, `position`	Position positive ; supprimée avec son message ; si la note ou l'extrait cité disparaît, la citation reste, avec un lien vide

Clients et missions agiles

TABLE	RÔLE	COLONNES PRINCIPALES	RÈGLES D'INTÉGRITÉ
`clients`	Un prospect ou un client	`name`, `status` (prospect, client), `origin` (client réel, formation, ami, démo)	Nom de 1 à 200 caractères
`contacts`	Un interlocuteur chez un client	`client_id`, `name`, `job_title`, `email`, `phone`, `address`	E-mail de 254 caractères au plus avec une arobase entourée de texte ; téléphone 30 caractères au plus ; adresse 500 au plus
`missions`	Une mission pour un client	`client_id`, `title`, `status` (prévue, en cours, terminée, annulée), `start_date`, `end_date`	Titre de 1 à 200 caractères
`sprints`	Un sprint d'une mission	`mission_id`, `name`, `goal`, `start_date`, `end_date`, `status`	Nom de 1 à 120 caractères ; un seul sprint actif par mission (index unique partiel)
`user_stories`	Une user story du backlog	`mission_id`, `sprint_id`, `source_note_id`, `title`, `role`, `benefit`, `acceptance_criteria`, `points`, `status`, `position`	Points limités à 1, 2, 3, 5, 8 ou 13 ; critères de 4 000 caractères au plus
`tasks`	Une tâche d'une story	`story_id`, `title`, `done`, `done_at`, `position`	Titre de 1 à 200 caractères

Finances et échéances

TABLE	RÔLE	COLONNES PRINCIPALES	RÈGLES D'INTÉGRITÉ
`quotes`	Un devis	`client_id`, `mission_id`, `amount_ht_cents`, `tax_cents`, `status` (brouillon, envoyé, accepté, refusé)	Montants en centimes : strictement positif pour le montant, positif ou nul pour la taxe
`invoices`	Une facture de suivi	`mission_id`, `quote_id`, `amount_ht_cents`, `tax_cents`, `due_on`, `issued_on`, `reference`	Montant de 1 centime à 1 000 000 euros ; référence de 60 caractères au plus
`payments`	Un encaissement	`invoice_id`, `amount_ht_cents`, `tax_cents`, `received_on`	Mêmes bornes de montant que les factures
`deadlines`	Une échéance administrative	`title`, `due_on`, `category`, `priority`, `recurrence`, `series_id`, `series_day`, `source`	La source est une adresse en `https://` ; jour de série de 1 à 31
`regulatory_rules`	Une règle réglementaire versionnée	`rule_key`, `activity_category`, `params` (JSON), `effective_from`, `effective_to`, `source`, `verified_on`, `revalidate_after`, `status`	Source obligatoire ; statut : à vérifier, vérifiée, essai ; une version peut pointer vers la précédente

TABLE	RÔLE	COLONNES PRINCIPALES	RÈGLES D'INTÉGRITÉ
`professional_profile`	Le profil professionnel (une ligne par compte)	Statut juridique, régime fiscal, TVA, ACRE, fréquence URSSAF, etc., chacun avec sa date de confirmation	Une donnée inconnue reste vide : jamais préremplie, **sauf** le statut juridique et la catégorie d'activité, préremplis par défaut (« Micro-entreprise » et « BNC », « Déclaré ») : voir chapitre 13, registre des traitements ; seuils d'alerte validés par une fonction
`task_checks`	Les contrôles du cockpit déjà faits	`rule_no`, `source_id`, `period_start`, `ceiling_key`, `threshold`	Numéro de règle de 1 à 8 ; seuil : 50, 75, 90 ou 100

Portfolio public, contact et technique

TABLE	RÔLE	COLONNES PRINCIPALES	RÈGLES D'INTÉGRITÉ
`realisations`	Une réalisation du portfolio	`title`, `description`, `origin`, `status`, `problem`, `design_choice`, `tests`, `validation`, `result_figure`, `stack`, `link_url`, `client_consent`, `published`	Champs texte de 600 caractères au plus ; adresse en `https://` ; 12 outils au plus ; visible du public seulement si publiée **et** accord du client (filtre des vues publiques)
`realisation_images`	Une capture d'une réalisation	`realisation_id`, `path`, `alt`	Chemin au format imposé (dossier du propriétaire), unique ; texte alternatif obligatoire
`contact_form_settings`	Qui reçoit les messages du formulaire	`owner_id`, `enabled`	Un seul destinataire activé à la fois (index unique partiel)
`contact_submissions`	Journal des envois du formulaire	`email_hash`, `message_hash`	Aucun texte de message : des empreintes seulement ; lignes de plus de 30 jours supprimées
`ai_calls`	Un appel à l'IA, pour le quota	`at`	Compté par une fonction (`consume_ai_quota`)

01.4

Règles d'intégrité transversales

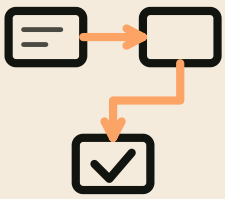
- **Un propriétaire sur chaque ligne.** `owner_id` vaut `auth.uid()` par défaut et pointe vers `auth.users`. La suppression d'un compte supprime en cascade toutes ses données (vérifié sur les 22 tables).
- **Sécurité par ligne partout.** Les 22 tables ont la RLS activée. Chaque politique est réservée aux comptes connectés et relie les lignes à `auth.uid()`. Aucune politique n'est ouverte à tous. Un test automatique le vérifie à chaque modification des migrations.
- **Montants en centimes entiers.** Jamais de nombre décimal pour l'argent.
- **Textes bornés.** Chaque texte a une longueur minimale et maximale, contrôlée par la base, pas seulement par l'interface.
- **Valeurs fermées.** Les statuts et les types sont des énumérations : la base refuse toute autre valeur.
- **Rien d'inventé.** Une donnée personnelle inconnue reste vide (« À confirmer »), **sauf** le statut juridique et la catégorie d'activité, préremplis par défaut (voir chapitre 13, registre des traitements). Les règles fiscales sont dans une table versionnée, avec source et date de vérification : aucun taux ni plafond n'est écrit dans le code.

- **Le vecteur dépend du modèle.** La dimension des vecteurs est liée au modèle d'embeddings (`mistral-embed`, 1 024 dimensions). Changer de modèle impose de tout réindexer : `embedding_model` garde la trace du modèle utilisé pour chaque extrait.
- **Le public ne touche aucune table.** Il lit deux vues (`public_realisations`, `public_realisation_images`) qui filtrent « publiée **et** accord du client », et exécute une seule fonction, `submit_contact_message`.

01.5

Évolution du schéma

Le schéma évolue par migrations versionnées, dans le dossier `supabase/migrations/` (56 fichiers, du 13 octobre au 7 novembre 2026). Après chaque migration, les types TypeScript sont régénérés, si bien qu'un schéma qui diverge du code est détecté à la compilation.



Workflows : saisie des documents et gestion de l'IA (RAG)

> *En deux phrases.* Une note suit un chemin court : elle est *enregistrée d'abord*, puis vectorisée ; l'IA ne peut jamais empêcher l'enregistrement. Une question suit un chemin plus long, où chaque étape peut échouer sans casser le reste (message d'erreur explicite). Aucun *MCP* n'est intégré à l'application : le MCP Supabase ne sert qu'au développement.

Faits relevés dans le code et les tests le 5 novembre 2026. Les délais annoncés sont des **délais d'attente du code** ou des **mesures** ; il n'existe aucun engagement de service (SLA) contractuel.

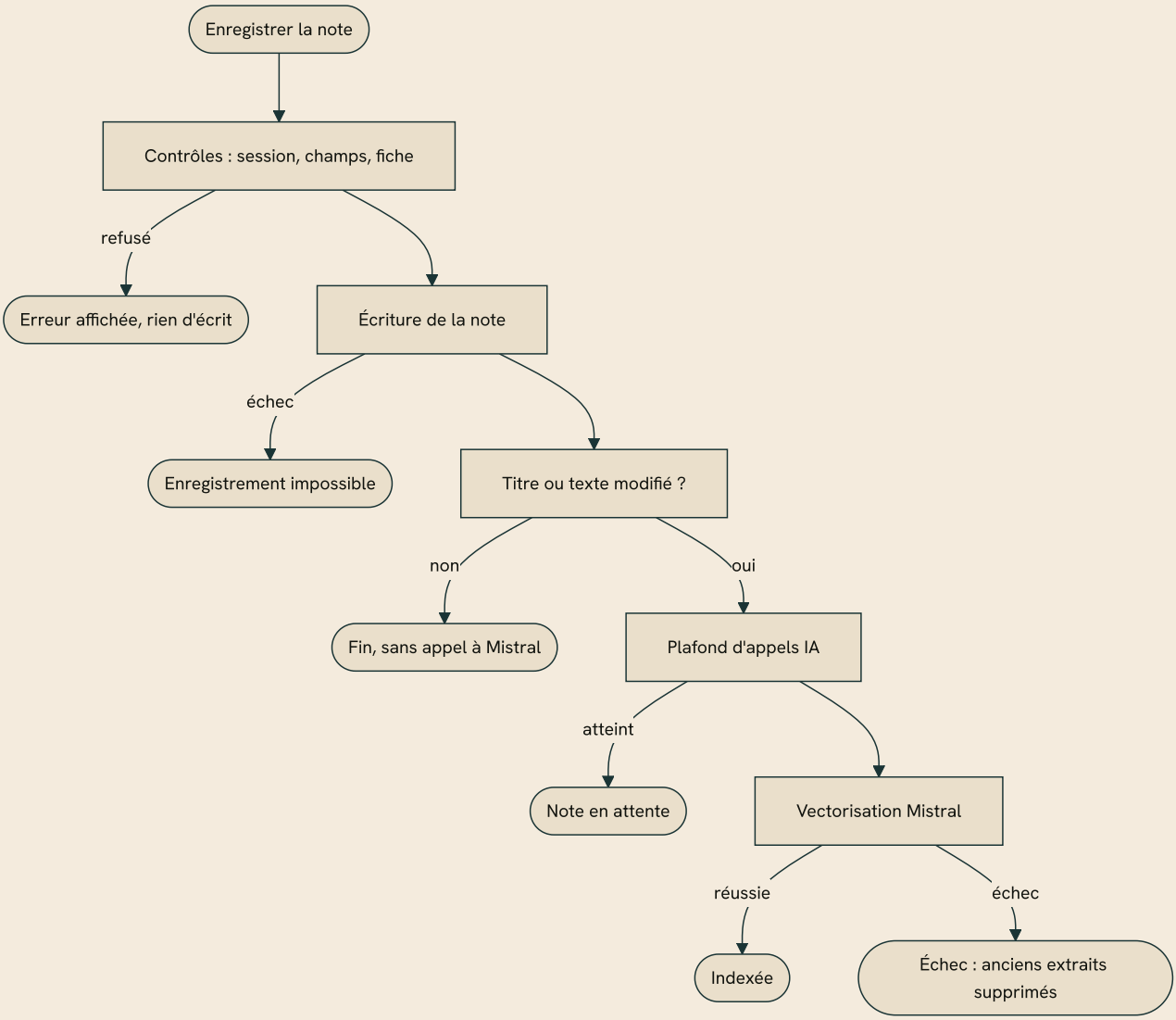
02.1

Les trois workflows

N°	WORKFLOW	DÉCLENCHEUR	RÉSULTAT
A	Saisie et indexation d'une note	Le propriétaire enregistre, modifie ou supprime une note	Note enregistrée, extraits vectorisés (ou état « échec » rattrapable)
B	Question à l'assistant	Le propriétaire pose une question	Réponse sourcée et vérifiée, message fixe sans appel à Claude, ou réponse prudente accompagnée d'un avertissement ; échange enregistré
C	Propositions de l'IA (stories, tâches, ordre, sprint, prompt, résumé)	Le propriétaire demande une proposition	Proposition **éphémère**, rien d'écrit tant qu'elle n'est pas gardée

02.2

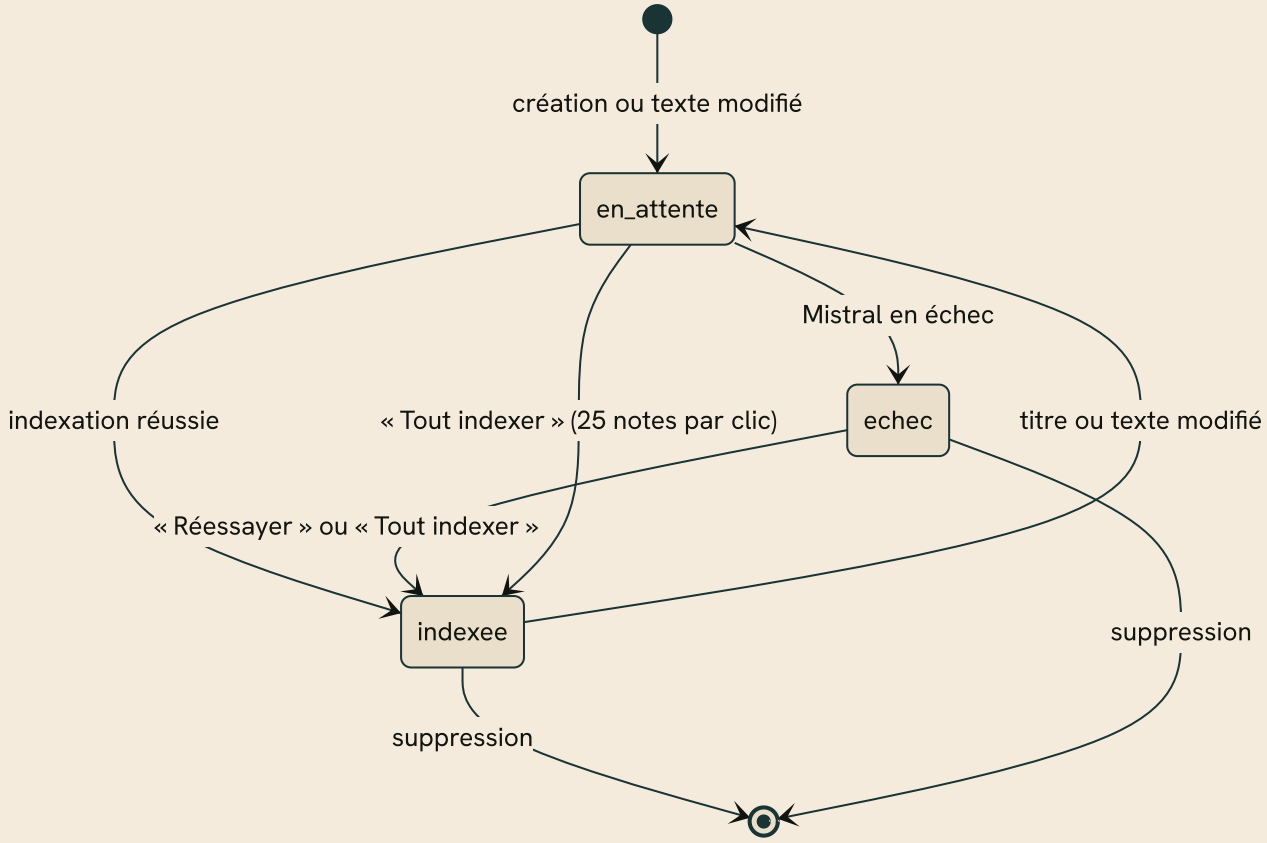
A. Saisie et indexation d'une note



Règles.

- Titre obligatoire, 200 caractères au plus ; texte de 50 000 caractères au plus ; type parmi note, procédure, modèle, FAQ. La base **refuse** aussi ces limites (double contrôle).
- `owner_id` est posé par la base, jamais par l'écran.
- La fiche client liée est facultative ; on peut en créer une comme **prospect** dans le même geste (deux écritures : si la note échoue, la fiche reste, supprimable).
- Une modification qui ne touche ni le titre ni le texte d'une note déjà indexée **n'appelle pas Mistral**.
- Les vecteurs sont calculés **avant** toute écriture d'extraits ; l'échec supprime les anciens extraits plutôt que de laisser un texte périmé.
- Supprimer une note supprime ses extraits (cascade) ; les citations qui la visaient deviennent vides, les réponses restent.

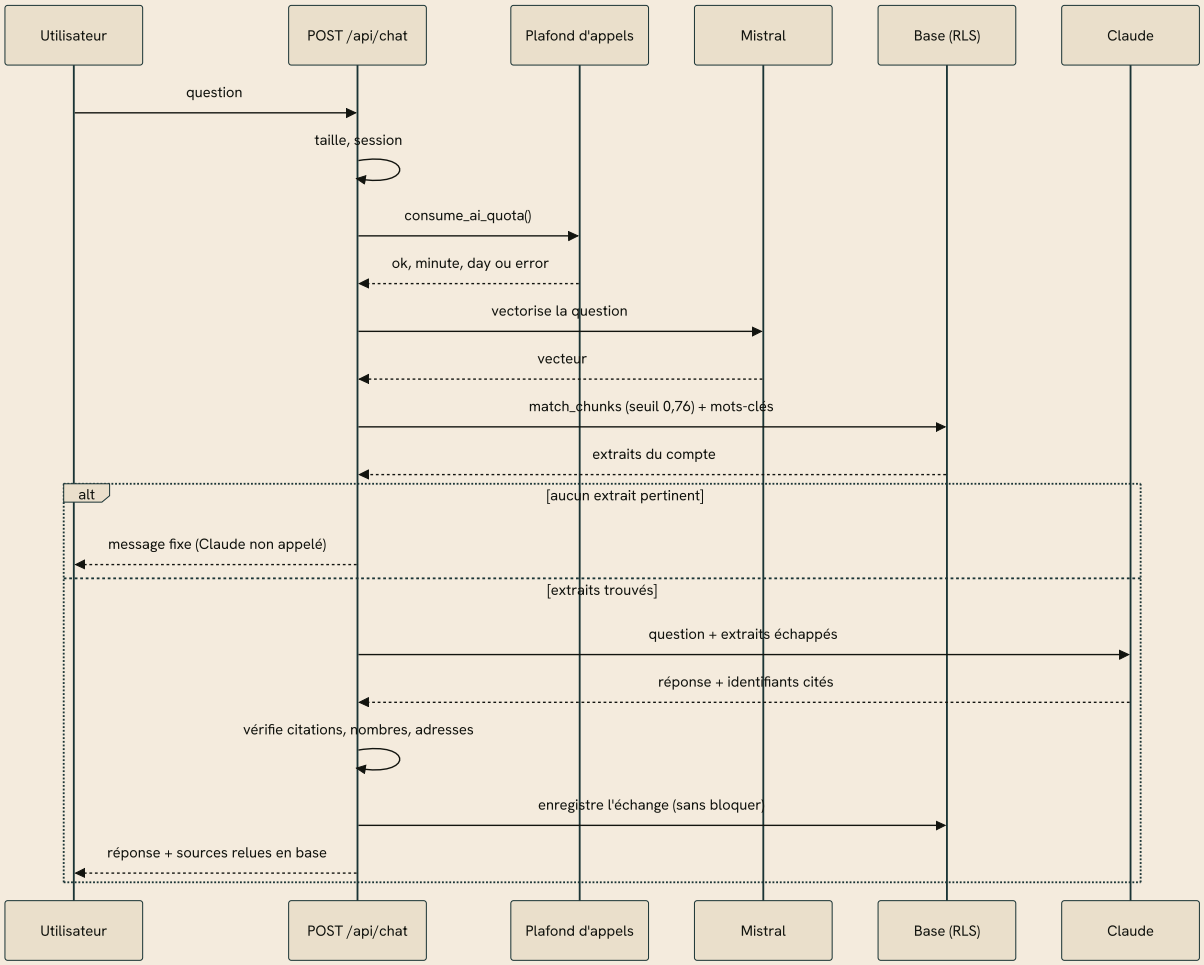
États d'une note



Un second état existe, **indépendant** : `draft` (brouillon) ou `active`. Un brouillon naît de deux façons : le bouton « Créer une note à documenter plus tard » de l'assistant (titre « À documenter : … », texte vide, jamais citable) ou un message du formulaire de contact public. **Constat** : aucune action de l'application ne fait passer une note de `draft` à `active` (la modification ne change pas ce statut) ; les propositions agiles, qui n'utilisent que des notes `active`, ne verront donc pas un brouillon complété. **Décision du 10 novembre 2026** : limite connue, non corrigée avant la soutenance.

02.3

B. Question à l'assistant



Règles.

- Deux voies de recherche : par le **sens** (vecteurs, seuil 0,76, 8 extraits au plus) et par **mots-clés** (5 au plus) ; les extraits trouvés par les deux sont fusionnés sans doublon.
- Sans extrait pertinent : message fixe « Je n'ai trouvé aucune procédure documentée correspondant à cette requête », **sans appel à Claude**, avec l'offre de créer une note à documenter.
- Claude ne renvoie que des **identifiants** de sources ; le texte des sources est relu en base.
- La réponse est vérifiée (citations envoyées, nombres, adresses) **avant** l'affichage ; sinon rejet.
- **Deux comportements à ne pas confondre quand la réponse n'est pas dans les notes.** (1) **Aucun extrait n'est retrouvé** (ni par le sens, avec un seuil de similarité de 0,76 : `MATCH_THRESHOLD` dans `lib/domain/matching.ts`, ni par mots-clés) : la fonction `answerQuestion` de `lib/domain/chat-flow.ts` renvoie le message fixe « Je n'ai trouvé aucune procédure documentée correspondant à cette requête. » **avant** d'appeler Claude. **Statut : lu dans le code et vérifié par un test unitaire local** (`chat-flow.test.ts`, dépendances simulées). **Non observé sur la production** : ce message figurait dans l'historique de la production pour deux questions plus anciennes (relevé le 9 novembre 2026, lecture seule), mais l'absence d'appel à Claude n'a pas pu y être constatée. (2) **Des extraits sont retrouvés, mais ils ne contiennent pas l'information** : Claude est appelé (**déduit du contenu de la réponse, qui rappelle des faits de la note ; l'appel n'a pas été observé directement**) et répond avec prudence (la note ne contient pas l'information, parfois en rappelant un fait voisin), puis le code ajoute « Aucune de tes notes ne soutient cette réponse » avec l'offre de créer une note à documenter. **Statut : observé sur la production le 9 novembre 2026** (deux questions, une exécution chacune) et lu dans le code (`showsNoSourceNotice`). **Le cas (2) n'est pas un**

refus à phrase fixe : c'est une limite connue, avec une amélioration possible (refuser plutôt que répondre quand aucune source n'est citée), **non réalisée** (périmètre gelé). Détail au chapitre 7.

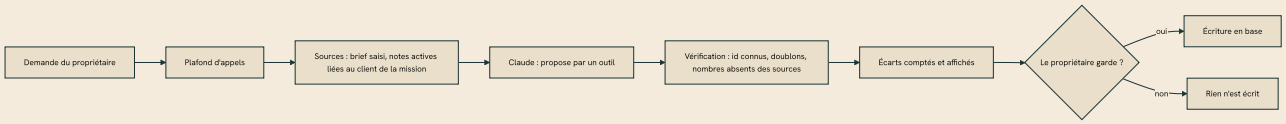
- L'enregistrement de l'historique **ne bloque jamais** la réponse.

Exceptions

SITUATION	CE QUE VOIT L'UTILISATEUR	STATUT
Pas de session (session expirée)	« Ta session a expiré. Recharge la page pour te reconnecter. »	401
Question vide	« Écris une question. »	400
Question ou corps trop longs	« Question trop longue. »	413
Plafond atteint (20 par minute, 300 par jour)	Message dédié, réessayer plus tard	429
Compteur de plafond indisponible	« Le compteur d'appels à l'IA est indisponible. » (on bloque plutôt que de laisser passer)	503
Mistral ou Claude en échec ou en délai (20 s, 60 s)	« L'assistant n'a pas pu répondre pour le moment. »	502
Réponse rejetée par la vérification	« La réponse n'a pas pu être vérifiée par rapport à tes notes, elle n'est pas affichée. Réessaie. »	502
Échec de l'enregistrement de l'historique	Rien : la réponse s'affiche ; journal sans contenu	200

02.4

C. Propositions de l'IA



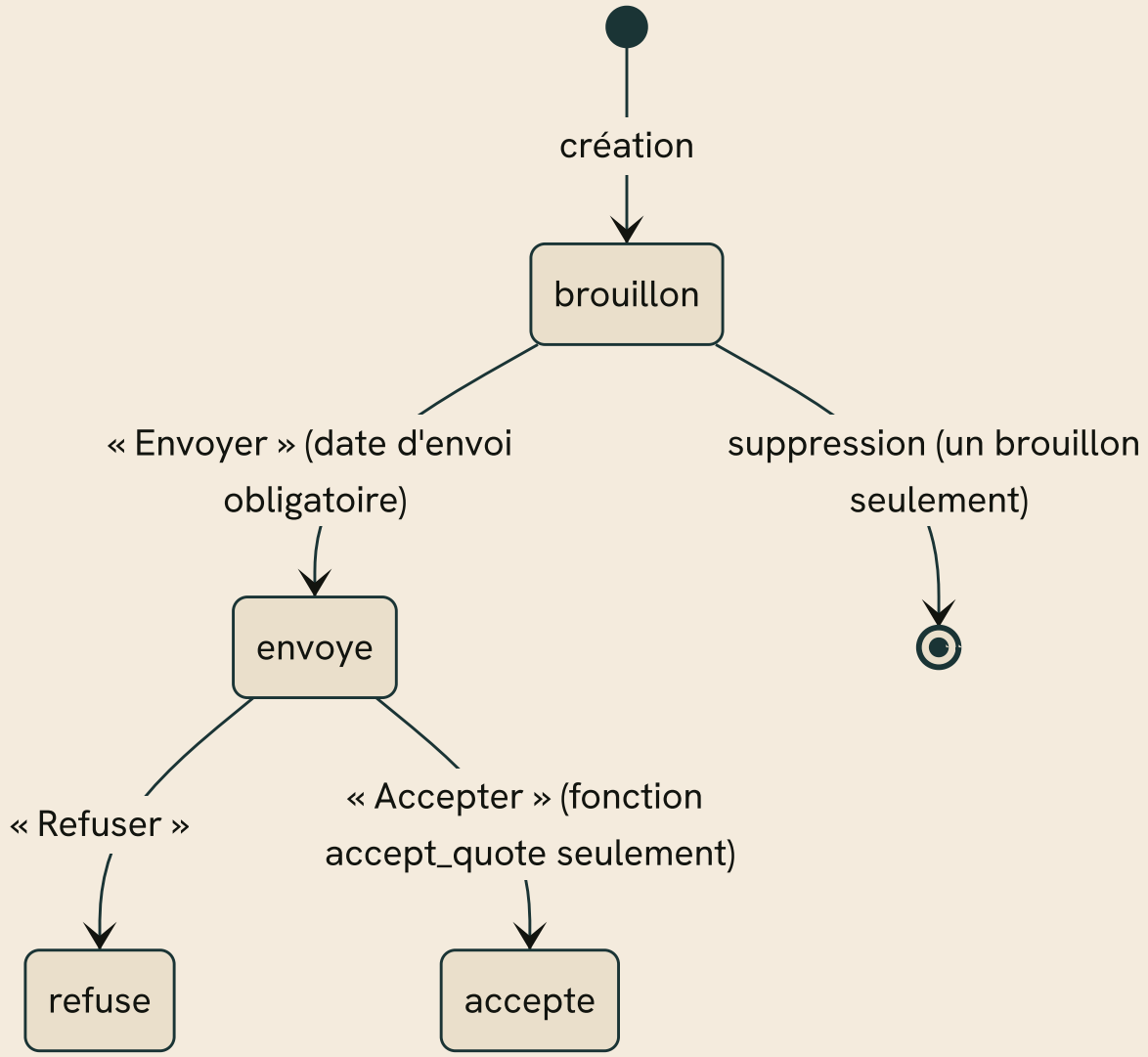
Propositions : user stories (avec tâches si demandé), tâches d'une story, ordre du backlog, composition d'un sprint, relecture d'une story, prompt de mission, résumé d'une note. Règles communes : **éphémères** tant que le propriétaire ne les garde pas ; seules les notes **actives liées à la fiche du client de la mission** sont envoyées ; un chiffre absent des sources fait écarter la proposition (ou sa raison) ; texte fourni traité comme **donnée**. Détail au chapitre 9.

02.5

Workflows métier existants

Cette section décrit, d'après le code et les migrations relus le 10 novembre 2026, les états des entités métier qui existent réellement. Elle ne décrit rien qui n'existe pas (voir « Ce qui n'existe pas » en fin de section). **Rendu des diagrammes non contrôlé** : aucun outil de rendu n'a été lancé pour cette section ; la syntaxe suit celle des diagrammes ci-dessus.

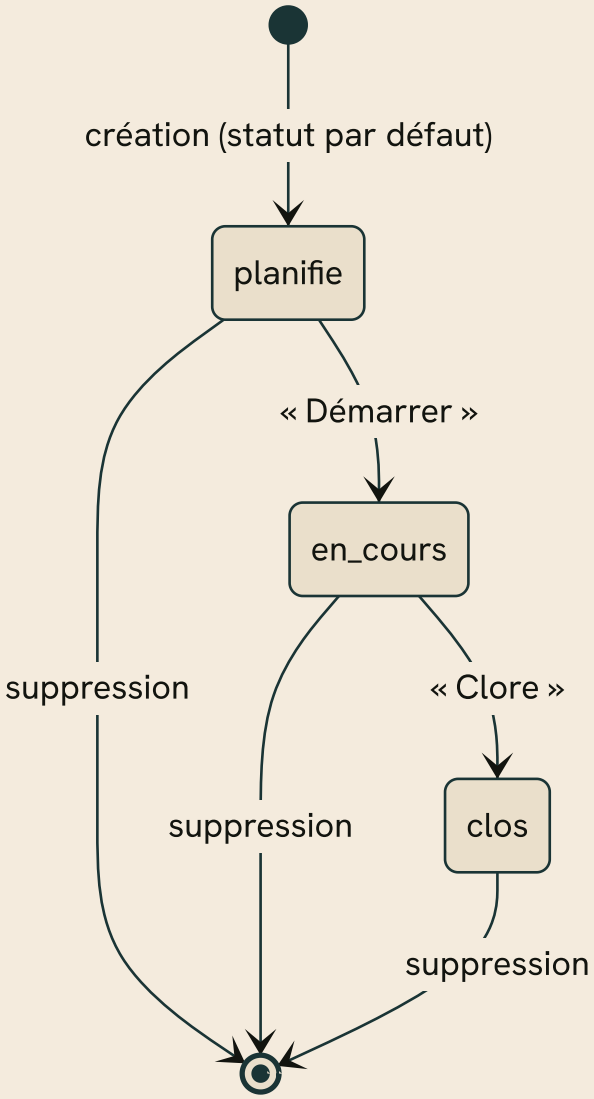
Devis



- Statuts : `supabase/migrations/20261018100100_quotes.sql:2` ; libellés `lib/domain/quotes.ts:5-7`. Dès que le statut n'est plus « brouillon », la date d'envoi est obligatoire (`quotes.sql:16`).
- La base impose les transitions : brouillon vers envoyé, envoyé vers refusé, envoyé vers accepté **seulement** quand `accept_quote` a posé le réglage `app.accepting_quote` (`quotes.sql:48-66`) ; un devis accepté ou refusé est figé (`quotes.sql:54-56`) ; déclencheur `quotes_guard` (`quotes.sql:68-69`). Seul un brouillon se supprime (règle d'accès `quotes.sql:44-46`).
- Ce que l'interface permet selon le statut : modifier un brouillon ou un devis envoyé, envoyer un brouillon, refuser ou accepter un devis envoyé, supprimer un brouillon (`lib/domain/quotes.ts:10-14`). Actions : `sendQuote` (`app/(app)/clients/quote-actions.ts:97-101`), `refuseQuote` (`:105-106`), `acceptQuote` (`:110-113` , appelle `accept_quote`), `deleteQuote` (`:129-132`).
- `accept_quote` (version en vigueur : `supabase/migrations/20261029210000_accept_quote_title.sql:4-33` , qui remplace celle de `quotes.sql:73-102` pour le seul titre de la mission) : un devis déjà accepté renvoie sa mission sans rien créer (`:15`) ; un devis qui n'est pas « envoyé » est refusé (`:16`) ; si le devis n'est lié à aucune mission (`:20`), la fiche passe de prospect à client (`:22-24`) et une mission au statut « planned » est créée, titrée « {nom du client} — devis du JJ/MM/AAAA » (`:25-27`) ; le devis devient accepté et pointe vers la mission (`:29`). L'acceptation est faite « en une action, tout ou rien » (`quotes.sql:71`).

Sprint

Lecture préalable des actions : `app/(app)/missions/sprint-actions.ts` (`startSprint` `:93-117` , `closeSprint` `:124-160` , `deleteSprint` `:163-187`).



- Statuts : `supabase/migrations/20261017120000_sprints.sql:2` ; statut par défaut « planned » (`:12`) ; libellés `lib/domain/sprints.ts:7-9` . À la création, l'action n'écrit pas le statut (`sprint-actions.ts:65`).
- **Démarrer** : `startSprint` ne change que les sprints « planned » (`sprint-actions.ts:96`). **Un seul sprint en cours par mission** : index unique `sprints_one_active_per_mission` (`sprints.sql:20-21`) ; son refus (code 23505) donne « Un sprint est déjà en cours » (`sprint-actions.ts:97,113`). Dans un second temps, une mission « planned » passe à « in_progress » (`:101`) ; l'échec de cette seconde écriture ne défait pas le démarrage (`:99-104`).
- **Clore** : seulement un sprint « active » (`sprint-actions.ts:130`). Les stories non terminées sont déplacées **avant** le changement d'état, vers le backlog ou vers un sprint « planned » de la même mission (`:133-148` , contrôle de la cible `:139`) ; en cas d'échec le sprint reste en cours (`:119-122`). Puis le statut passe à « closed » (`:149`).
- **Sprint clos** : seuls le nom et l'objectif se modifient (`sprint-actions.ts:85`) ; son contenu est figé **en base** par le déclencheur `user_stories_guard_closed_sprint` , qui refuse l'entrée comme la sortie d'une story (`supabase/migrations/20261017150000_user_stories_closed_sprint_guard.sql:5-23`).
- **Suppression** : `deleteSprint` ne vérifie aucun statut (`sprint-actions.ts:163-187`) ; les stories retournent au backlog (`:162,166-177`).

- Dans le code de l'application (`app/`), seules deux actions écrivent le statut d'un sprint : `startSprint` (`:96`) et `closeSprint` (`:149`) ; la création laisse le statut par défaut et `updateSprint` n'envoie jamais le statut (`:85-86`). Les scripts de données de démonstration, eux, insèrent des sprints avec un statut choisi (`scripts/seed-demo-backlog.ts:199`, `scripts/seed-demo-to-invoice.ts:51`).

Mission : valeurs de statut seulement

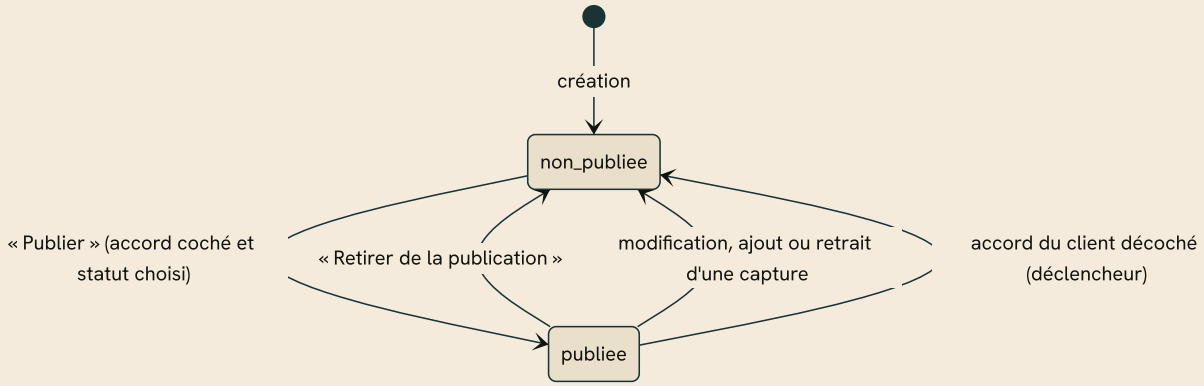
Statut libre, aucune transition imposée.

- Valeurs : `in_progress`, `done`, `cancelled` (`supabase/migrations/20261015162137_missions.sql:2`) et `planned` (`supabase/migrations/20261018100000_mission_status_planned.sql:3`) ; libellés « À planifier », « En cours », « Terminée », « Annulée » (`lib/domain/missions.ts:6-9`). Valeur par défaut en base : « in_progress » (`missions.sql:9`).
- Aucun déclencheur ne contrôle le statut : seul `missions_set_updated_at` existe (`missions.sql:20`). Le formulaire écrit le statut choisi (`app/(app)/missions/actions.ts:83-89`, validation `lib/domain/missions.ts:42`).
- **Deux écritures automatiques existent pourtant** : l'acceptation d'un devis crée une mission « planned » (`supabase/migrations/20261029210000_accept_quote_title.sql:25-27`), et le démarrage d'un sprint fait passer une mission « planned » à « in_progress » (`sprint-actions.ts:101`). Elles ne sont pas des transitions imposées : le statut reste modifiable à la main.

Facture : un statut calculé, pas une machine d'états stockée

- La table `invoices` n'a aucune colonne de statut (`lib/supabase/database.types.ts:197`, et dictionnaire du chapitre 1). Le statut est **déduit des encaissements** par `invoiceBalance` (`lib/domain/payments.ts:77-91`) : sans encaissement, « Non payée » ; total encaissé au moins égal au dû, « Payée » ; sinon « Partiellement payée » (`:81`). Le dû est calculé toutes taxes comprises si la taxe de la facture est connue, hors taxe sinon (`:78-80`). Libellés `:52-54`.
- **Échue** : pas totalement payée et échéance strictement avant aujourd'hui (`lib/domain/invoices.ts:73-74`). C'est une règle de date, pas un état stocké.
- Garde des encaissements : `payments_guard` (`supabase/migrations/20261023110000_payments.sql:43-67`) : un encaissement ne change ni de facture ni de propriétaire (`:50-57`), sa date n'est jamais dans le futur, jour de Paris (`:58-61`) ; un encaissement est toujours supprimable (`:39-41`). Un trop-perçu déclenche un avertissement, rien ne le bloque (`lib/domain/payments.ts:93-95`).

Réalisation du portfolio



- Publier exige l'accord du client et un statut : `setRealisationPublication` (`app/(app)/realisations/actions.ts:90-110`, filtre `:102`) ; la base refuse de toute façon une publication sans accord (contrainte `realisations_publish_needs_consent`, `supabase/migrations/20261030130000_realisations.sql:21-22`).
- Retirer l'accord d'une réalisation publiée la **dépublie d'office** (`supabase/migrations/20261030160000_realisations_unpublish_on_consent_removed.sql:8-10`) ; la date de publication est posée à la publication et effacée à la dépublication (`:11-15`).

- Toute modification enregistre la réalisation non publiée (`realisations/actions.ts:79-80`), de même que l'ajout ou le retrait d'une capture (`:164`, `:193`) : il faut republier ensuite.
- La page publique ne montre que les réalisations publiées, avec accord et un statut (`supabase/migrations/20261106100000_realisation_design_choice.sql:34`).

Ce qui n'existe pas

- **Aucune machine d'états de facture stockée** : le statut est calculé (voir ci-dessus).
- **Aucune transition imposée pour une mission** : statut libre (voir ci-dessus).
- **Aucune transition imposée pour une story** : son statut (« todo », « in_progress », « done » : `lib/domain/user-stories.ts:6`) change librement par le menu de statut (`app/(app)/missions/story-actions.ts:167-176`) ou le formulaire (`:153-163`). Seule protection : le contenu d'un sprint clos est figé (`20261017150000_user_stories_closed_sprint_guard.sql:5-23`).
- **Aucun garde-fou contre la suppression d'un sprint, y compris en cours** : ni côté serveur (`app/(app)/missions/sprint-actions.ts:163-187` ne contrôle aucun statut), ni côté interface (le bouton « Supprimer » est affiché quel que soit le statut : `components/sprint-block.tsx:146-148` ; seule une confirmation « Supprimer ce sprint ? C'est définitif. » est demandée : `:195-208`), ni dans les migrations du dépôt (la politique `sprints_delete` ne contrôle que le propriétaire : `supabase/migrations/20261017120000_sprints.sql:42-43` ; le seul déclencheur posé sur `sprints` est `sprints_set_updated_at`, avant mise à jour, `:23-24`, et la garde `user_stories_guard_closed_sprint` porte sur les stories, pas sur la suppression d'un sprint : `20261017150000_user_stories_closed_sprint_guard.sql:3-4`, `:21-22`). Relevé fait sur les 56 fichiers de `supabase/migrations/` le 12 novembre 2026 ; la base déployée n'a pas été interrogée : **non vérifié** pour elle. Les stories d'un sprint supprimé retournent au backlog (`sprints.sql:45-46`).
- **Aucune réouverture d'un sprint clos** : aucune écriture ne remet un sprint à « planned » ou « active » (voir « Sprint »).
- Un devis accepté ou refusé ne peut plus changer (`quotes.sql:54-56`).

02.6

Événements qui déclenchent un traitement

ÉVÉNEMENT	TRAITEMENT	SYNCHRONE ?
Note enregistrée ou modifiée	Indexation (workflow A)	**Oui** : l'enregistrement attend la fin de l'indexation avant de rendre la main
Clic sur « Réessayer » ou « Tout indexer »	Indexation de la note, ou de 25 notes au plus par clic	Oui
Question posée	Workflow B	Oui, sans flux : la réponse arrive en une fois
« Vider la conversation »	Suppression de tout l'historique du compte	Oui
Message du formulaire de contact	Note en brouillon chez le destinataire, **jamais indexée** : ni « Tout indexer » (`lib/domain/index-batch.ts:10`), ni l'enregistrement, ni « Réessayer » (`lib/domain/index-note.ts:24`, état « skipped ») n'envoient le message à Mistral ; repère : le titre « Message reçu · » (`lib/domain/contact-message.ts:8`, `:13`) ; correction déployée le 12 novembre 2026 (n° 103)	Oui

Il n'existe **aucune tâche planifiée ni file d'attente** dans l'application : tout se passe à la demande. Rappels et résumé hebdomadaire (n8n) sont hors du MVP.

02.7

Délais et niveaux de service (SLA)

MESURE	VALEUR	NATURE
Réponse de l'assistant	Environ 3,4 s en moyenne ; 6 à 7 s pour la plus lente des 20 questions	**Mesurée** sur deux exécutions du 4 novembre 2026 (chapitre 7) : ordre de grandeur, pas une garantie
Délai maximal d'un appel à Claude	60 s	Réglage du code
Délai maximal d'un appel à Mistral	20 s par lot de 16 textes	Réglage du code
Plafond d'appels à l'IA	20 par minute, 300 par jour, par compte	Règle de la base
Disponibilité de l'application	Aucun engagement ; offre gratuite de Supabase, pause possible après une semaine d'inactivité	Voir chapitre 12
Temps d'indexation d'une note	**À confirmer** : non mesuré (un appel Mistral, au plus 20 s)	—

02.8

MCP : ce qu'il en est

Aucun serveur MCP n'est intégré à LogMerry : pas de fichier `.mcp.json`, pas de dépendance, aucun appel dans le code de l'application. Le **MCP Supabase** est utilisé **uniquement pendant le développement** (migrations, types, lecture de la base, avis de sécurité), en lecture seule hors modification du schéma, avec approbation manuelle des appels. Si un MCP était un jour intégré à l'application, il faudrait décrire ici ses droits et ses flux.

MCP : non utilisé dans l'application (constaté, lecture du dépôt le 13 novembre 2026, par l'assistant).

02.9

Limites et suite

LIMITE	CONSÉQUENCE	PISTE
Indexation synchrone dans l'enregistrement	Enregistrer une note peut durer jusqu'à 20 s si Mistral est lent	Indexer en arrière-plan (file d'attente), si l'usage le justifie
Pas de nouvelle tentative automatique	Une panne brève se voit tout de suite	Une reprise unique avec attente
Aucun passage de `draft` à `active`	Un brouillon complété n'alimente pas les propositions agiles	Limite connue (décision du 10 novembre 2026)
Hors corpus avec des extraits retrouvés : réponse prudente et avertissement, pas un refus sec (observé sur la production)	Un fait voisin peut être rappelé ; la réponse reste signalée comme non soutenue par les notes	Refuser plutôt que répondre quand aucune source n'est citée (non fait : périmètre gelé)
Pas de flux de réponse	L'utilisateur attend la réponse complète	Flux (streaming), après le MVP

UX, maquettes et système de design



> *En deux phrases.* LogMerry est pensé *ordinateur d'abord*, en français, avec une barre latérale, un assistant qui s'ouvre depuis toute page et un cockpit « Aujourd'hui » pour premier écran de travail. L'interface obéit à un *système de jetons* (aucune couleur ou police écrite en dur) et à un *plancher d'accessibilité* WCAG 2.1 AA, mesuré le 29 octobre 2026 : Lighthouse accessibilité à 100 sur les cinq pages testées, avec des limites de méthode écrites plus bas.

Sources : `DESIGN.md` (aspect, statut « final », mis à jour le 18 octobre 2026), `EXPERIENCE.md` (comportement), `docs/ui-rules.md` (contrat court), `docs/audit-accessibilite.md` (audit du 29 octobre 2026), `docs/ux-resume.md`. Quand ces documents divergent, `DESIGN.md` et `EXPERIENCE.md` font foi.

03.1

Principes

PRINCIPE	TRADUCTION DANS L'INTERFACE
Un cockpit, pas un tableau de bord chargé	« Aujourd'hui » liste les tâches du jour **avec leur motif** (« facture échue depuis 1 jour ») ; cocher une tâche réordonne la liste
Un assistant toujours à portée	Panneau ouvrable depuis toute page, réponse d'abord en 2 ou 3 puces, sources dessous, « Copier le texte » et « Ouvrir » la note complète
Dire quand on ne sait pas	Message fixe de l'assistant quand aucun extrait n'est retrouvé, sinon réponse prudente avec le bandeau « Aucune de tes notes ne soutient cette réponse », « paramètre manquant » plutôt qu'un chiffre douteux, « À confirmer » pour une donnée inconnue, sauf le statut juridique et la catégorie d'activité, préremplis par défaut (voir chapitre 13, registre des traitements)
Jamais la couleur seule	Un statut = une icône + un mot + sa couleur
Aucun montant calculé sans étiquette	Tout montant calculé porte « estimation »
Sobre et net	Grille nette, fort contraste, traits marine de 2 px et ombre dure en thème clair

03.2

Architecture de l'information

Barre latérale fixe à gauche (repliable en icônes), le cockpit en première entrée, assistant en panneau poussé à droite (décision de l'auteur, déclarée ; non revérifiée dans cette version).

SURFACE	RÔLE
Connexion, mot de passe oublié	Accès sécurisé (pas d'inscription : voir ci-dessous)

SURFACE	RÔLE
Aujourd'hui	Tâches du jour avec motif, jauges de plafond, lignes « paramètre manquant »
Assistant + historique	Question, réponse citée, échanges conservés
Notes	Base de connaissances, recherche (mots et sens), résumé généré
Clients (prospects, contacts, devis)	CRM minimal
Missions	Backlog agile (stories, tâches, sprints), glisser-déposer, propositions de l'IA, prompt de mission
Factures et encaissements	Montants, statut « payée » déduit des encaissements
Calendrier	Échéances administratives, source unique des obligations
Profil, Règles, Plafonds	Données personnelles, règles réglementaires versionnées, jauges de plafond
Réalisations	Édition du portfolio, accord du client, publication
À faire	Éléments à documenter plus tard (notes en brouillon)
Portfolio public	Vitrine en lecture seule et formulaire de contact, sans connexion

> *Écart entre la conception et l'application.* `EXPERIENCE.md` mentionne un écran d'inscription et une page « Finances » (estimation de cotisations). *Aucun des deux n'existe dans l'application* : il n'y a pas de page d'inscription (l'inscription est désactivée dans Supabase, chapitre II), et le dossier `app/(app)/` n'a pas de page « Finances ». La spécification est donc en avance sur le code sur ces deux points.

03.3

Parcours clés

1. Le cockpit du lundi matin. Connexion, arrivée sur « Aujourd'hui », lecture des tâches et de leur motif, cochage (retour de satisfaction, la liste se réordonne), message « Bravo, tu as fait toutes tes tâches du jour. » à la dernière.

2. Retrouver une procédure pendant une visioconférence. Ouvrir l'assistant dans un coin de l'écran, taper des mots-clés, lire la réponse en 2 ou 3 puces, copier le texte dans le chat de la visio, ouvrir ensuite la note complète. Si rien n'est trouvé : l'assistant le dit et propose « Créer une note à documenter plus tard ».

3. Un visiteur consulte une réalisation (personnage fictif). Ouverture du lien reçu par e-mail ; en dix secondes, l'impression d'une personne rigoureuse et soignée ; lecture d'une réalisation (description, captures, chiffre de résultat, outils) ; message à Alex par le formulaire de contact. Le nom du client n'apparaît jamais sans son accord.

4. Concevoir une mission en agile avec l'IA. Backlog en une ligne par story ; propositions de stories par l'IA à partir d'un brief et de notes cochées, à garder, modifier ou rejeter ; tâches proposées une par une ; glisser-déposer à la souris, au doigt ou **au clavier** (Espace, flèches, Espace, Échap annule), chaque déplacement annoncé ; génération d'un prompt à confier à un autre assistant, avec une case « sans le nom du client ».

Le texte complet des parcours, étape par étape, est dans `EXPERIENCE.md` (section Key Flows).

03.4

Système de design

Jetons et règles

Le contrat tient en 13 règles (`docs/ui-rules.md`), dont :

RÈGLE	CONTENU	CONTRÔLE AUTOMATIQUE
1	**Aucune valeur de couleur, de police ou de rayon dans un composant** : uniquement des jetons	`lib/theme.test.ts`
3	Un statut = icône + mot + couleur	Revue
5	Texte ≥ 4,5:1, éléments d'interface ≥ 3:1, en clair et en sombre	`lib/theme.test.ts` (paires de jetons)
7	Montants, dates et durées en police à chiffres alignés ; montant calculé étiqueté « estimation »	Revue
8	Chaque jeton existe en clair **et** en sombre	`lib/theme.test.ts`
9	Focus visible partout, navigation complète au clavier	Audit du 29 octobre 2026
13	`prefers-reduced-motion` et `forced-colors` respectés	Revue

Identité visuelle (état au 18 octobre 2026)

ÉLÉMENT	CHOIX
Thème clair « Arcade clair »	Fond ciel très pâle, encre marine, traits marine de 2 px, ombre dure, accents turquoise, violet, orange, rose, jaune (décoratifs, jamais du texte)
Thème sombre « Cobalt » (thème par défaut)	Cobalt en signature (lien, élément actif, case cochée) ; focus orange
Signature	Le cobalt (`#1D3BFF` en clair) marque ce qui est actif, jamais un statut ni une série de graphique
Statuts	Succès `#097145`, attention `#954F00`, erreur `#B3261E` (valeurs du thème clair, `DESIGN.md`)
Graphiques	Cinq jetons de série seulement, avec légende ou étiquette directe
Polices	Cinq polices, chargées dans `app/layout.tsx` : Hanken Grotesk (interface, titres, corps : `:18-19`), IBM Plex Mono (chiffres : `:18`, `:26`), Pixelify Sans (titres et étiquettes seulement, jamais le texte courant : `:22-23`), Bricolage Grotesque 700 (le nom « LogMerry », logotype : `:20-21`), Instrument Serif (titres de la page publique `/portfolio` seulement : `:24-25`)
Composants	shadcn/ui (style new-york, icônes lucide), recolorés par les jetons ; on ne redessine pas sans raison de marque

> *Mise à jour du 5 novembre 2026.* `docs/ux-resume.md` décrivait encore l'ancienne palette (Chalk, Dawn, Forest, Kyuri) de la session du ll octobre ; il a été corrigé d'après `DESIGN.md`. En cas de doute, `DESIGN.md` et `ui-rules.md` font foi.

03.5

Accessibilité

Plancher fixé par la conception (`EXPERIENCE.md`)

WCAG 2.1 AA sur tous les écrans ; `lang="fr"` partout ; un seul titre de niveau 1 par page ; lien d'évitement « Aller au contenu » ; repères (`nav`, `main`, `aside`) ; libellés associés et récapitulatif d'erreurs en tête de formulaire ; mot de passe collable, gestionnaires de mots de passe acceptés, aucun CAPTCHA ; cibles tactiles de 44 px sur téléphone ; reflow à 320 px ; glisser-déposer doublé d'une alternative clavier.

Revue de la conception

`review-accessibility.md` a relu les documents de conception avant le code et listé **29 écarts** de spécification : 0 critique, 7 élevés, 16 moyens, 6 faibles (revue de spécification, pas du code).

Audit du code (29 octobre 2026, story 7.2)

Réalisé sur une version de production locale, compte de démonstration, WCAG 2.1 AA, parcours cockpit, saisie après un rendez-vous et paiement.

MESURE	RÉSULTAT
Lighthouse accessibilité (cockpit, calendrier, clients, fiche mission, factures)	**100** sur les 5 pages
Débordement horizontal à 400 px	Aucun sur les 14 pages mesurées
`tabindex` **positif**	Aucun
Contraste du texte sur fond uni	≥ 4,5:1 sur les 14 pages, deux thèmes
Focus visible	Présent sur tous les éléments tabulables des 9 pages mesurées
Statuts	Mot ou icône en plus de la couleur (« Payée », « Échue », « Prospect »…)

#	CONSTAT	SUITE
1	Le focus tombait sur la page à l'ouverture d'un formulaire (le bouton d'ouverture disparaissait)	**Corrigé**
2	Titre de page orange sur bleu pâle à 2,73:1 (3:1 exigé) en thème clair	**Corrigé** : couleur passée de `#E4600B` à `#C44A00` (3,77:1 au pire point), option A choisie par l'auteur
3	Focus non rendu au bouton d'ouverture après « Annuler » (factures, devis, règles)	**Corrigé** le 30 octobre 2026
4	Liens d'en-tête de colonne plus étroits que 44 px sur téléphone	Dette connue
5	Anneau de focus des champs de 1 px, visible mais fin	Dette, à juger à l'usage
6	Sur iOS, le focus d'un menu déroulant n'a pas d'effet visible	Noté

Ce que l'audit ne prouve pas

- **Un seul parcours** a été fait au clavier touche par touche (une facture). Les parcours du cockpit et de la saisie après un rendez-vous n'ont pas été parcourus de bout en bout sans souris : **à faire par l'auteur** (`docs/controles-visuels.md`, section 11).

- **Non testés** : lecteur d'écran réel (VoiceOver), glisser-déposer au toucher, panneaux de l'IA, assistant, page de connexion, palette de commandes ⌘K, Lighthouse à 400 px.
- **L'outil automatique axe-core n'a pas pu être chargé** ; seuls Lighthouse et des scripts maison ont servi. Un audit automatique ne détecte qu'une partie des défauts.
- Le script de contraste ne voit pas le texte en transparence, les états de survol et désactivé, ni les panneaux fermés.

03.6

Adaptation aux écrans

LARGEUR	COMPORTEMENT
Ordinateur (cible : Mac)	Barre latérale fixe et repliable, assistant à droite, tableaux pleine largeur
Téléphone (sous 768 px)	Barre du haut fixe, barre latérale en tiroir, cibles de 44 px, marges de 16 px, colonne de date masquée dans les tableaux ; consultation et saisie légère (saisie lourde non optimisée au MVP)
Tablette	Barre latérale en icônes ; **le point de rupture n'est pas fixé** (point ouvert de la conception)

Vérification annoncée dans `ui-rules.md` : émulation Pixel 6a (412 × 915) dans Chrome, clair et sombre, puis essai sur un vrai téléphone. **Constaté le 5 novembre 2026** (`06-demo.md:18` et `:111`) : l'ouverture de la page de connexion sur téléphone par QR. **Le parcours complet n'a jamais été testé sur un vrai téléphone** (déclaré par l'auteur, 12 novembre 2026 ; limite assumée) ; un essai de la preview sur son Pixel 6a est seulement consigné au journal du 14 octobre 2026 (`docs/journal.md:318` : rendu mobile « pas dingue »), sans détail. Résultats documentés de l'émulation Pixel 6a (story R8, journal du 15 octobre 2026, `docs/journal.md:396-403`) : barre du haut et tiroir avec libellés, cibles de 44 px (sauf le « i » de la recherche, zone tactile élargie, et les liens dans une phrase), aucun débordement horizontal sur Notes, Clients, fiche, formulaires, assistant, palette ⌘K et pages hors connexion (clair et sombre) ; limite notée : le menu « Lié à » affiche un nom de fiche long sur deux lignes dans l'émulation.

03.7

Gabarits et structure des pages

N'est appelé « gabarit » que ce qui structure réellement des pages entières. Relevé fait dans le code de la branche `main` le 10 novembre 2026.

Ce qui a été lu. Le dossier `components/` contient 90 fichiers (88 `.tsx` et 2 `.ts`) et un sous-dossier `ui/` de 8 fichiers. **15 fichiers ont été lus** : 3 en entier (`auth-shell.tsx`, `page-banner.tsx`, `portfolio-image.tsx`) et 12 en partie ou par extraits (`app-sidebar.tsx`, `assistant-panel.tsx`, `form-helpers.tsx`, `login-form.tsx`, `mission-form.tsx`, `portfolio-contact-form.tsx`, `portfolio-header-frame.tsx`, `portfolio-sections.tsx`, `portfolio-showcase.tsx`, `realisation-images.tsx`, `search-palette.tsx`, `sprint-form.tsx`). **75 fichiers n'ont pas été lus** ; le sous-dossier `ui/` n'a été que listé (voir la fin de la section). Quatre fichiers hors `components/` ont été lus en entier : `app/layout.tsx`, `app/(app)/layout.tsx`, `app/auth/login/page.tsx` et `app/portfolio/page.tsx`.

Gabarits de pages

RÔLE	FICHIER:LIGNE	CE QU'IL STRUCTURE
Toutes les pages	`app/layout.tsx:28-47`	Langue française (`:34`), thème sombre par défaut avec prise en compte du système (`:36-41`), cinq polices chargées (`:19-26`)

RÔLE	FICHIER:LIGNE	CE QU'IL STRUCTURE
Application connectée	`app/(app)/layout.tsx:13-46`	Revérification de la session (`:15-16`), historique de l'assistant chargé (`:21-27`), lien d'évitement « Aller au contenu » (`:32-37`), barre latérale (`:38`), zone `main#main` (`:39`), panneau de l'assistant (`:42`)
Pages d'authentification	`components/auth-shell.tsx:7-23`	Fond dégradé plein écran, logo et nom en haut à gauche, carte centrée ; utilisé par 4 pages : `app/auth/login` , `forgot-password` , `update-password` , `error`
En-tête d'un écran de l'application	`components/page-banner.tsx:13-55`	Bandeau avec titre, action principale, description, filtres et, pour le cockpit, tuiles ; importé par **32 fichiers** sous `app/`
Page publique `/portfolio`	`app/portfolio/page.tsx:39-62` et `components/portfolio-sections.tsx` (`PortfolioHeader:46` , `PortfolioHero:93` , `PortfolioLever:150` , `PortfolioProcess:171` , `PortfolioServices:208` , `PortfolioStack:233` , `PortfolioShowcaseFrame:269` , `PortfolioContact:281` , `PortfolioFooter:298`)	Sections empilées ; lien d'évitement et `main#contenu` dans la page ; en-tête posé sur la photo puis translucide au défilement (`components/portfolio-header-frame.tsx:13`)

Panneaux, formulaires et éléments publics (lus)

RÔLE	FICHIER:LIGNE	CE QUE LE FICHIER FAIT
Panneau	`components/assistant-panel.tsx:15-16`	Panneau « Assistant » non modal, placé après `main` : il réduit la largeur de la page sans la recouvrir, plein écran sous 1 024 px
Panneau (navigation)	`components/app-sidebar.tsx:52`	Barre latérale (lue en partie : imports, icônes)
Formulaire (aides communes)	`components/form-helpers.tsx` : `FocusOnMount:11` , `selectClass:34-36` , `ErrorLine:40` , `useFormFields:52` , `focusField:59` , `ErrorSummary:69` , `useMoreFields:105`	Récapitulatif d'erreurs en tête, ligne d'erreur reliée au champ, focus, menus ; 22 fichiers de `components/` importent ce fichier
Formulaire (exemples lus)	`components/mission-form.tsx:34` , `components/sprint-form.tsx:57`	Chacun affiche le récapitulatif d'erreurs en tête (`ErrorSummary`) ; le test de ces deux formulaires est `tests/components/mission-sprint-forms.test.tsx`
Public (carte de réalisation)	`components/portfolio-showcase.tsx:12` (`BrowserFrame`), `:34` (`PortfolioCard`), `:148` (`PortfolioShowcase`)	Cadre de navigateur, carte dépliable, miniatures
Public (image)	`components/portfolio-image.tsx:10-22`	Image de capture avec repli sobre portant le texte alternatif si le fichier ne se charge pas

Composants de base

Le sous-dossier `components/ui/` contient 8 fichiers (`badge` , `button` , `card` , `checkbox` , `dropdown-menu` , `input` , `label` , `textarea`). Seuls leurs noms ont été relevés : leur contenu n'a pas été lu. Le chapitre dit plus haut qu'ils sont recolorés par les jetons ; ce point reste celui de `docs/ui-rules.md` et de `lib/theme.test.ts` , non revérifié ici.

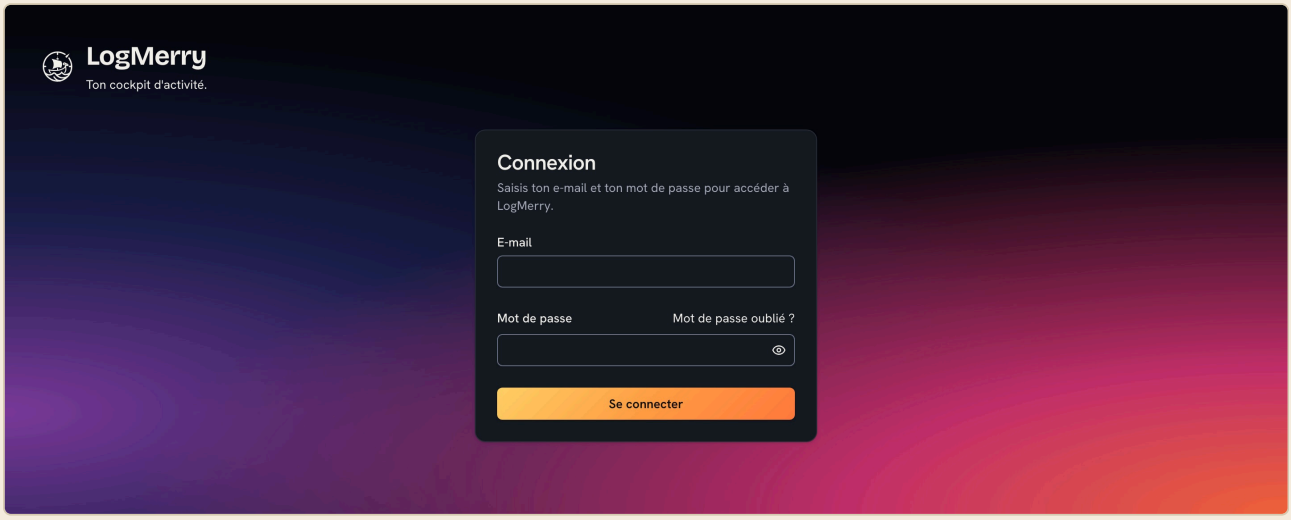
Fichiers de `components/` non lus (75)

assistant-draft-button, assistant-provider, assistant-sources, backlog-order, backlog, calendar-line-row, ceiling-gauge, client-card, client-form, client-status, cockpit-gauges, confirm-delete, confirm-panel, contact-form, contacts-section, dashboard-widgets, data-table, deadline-form, deadline-gantt, deadline-kanban, deadline-row, deadlines-panel, delete-client, delete-mission, delete-note, delete-realisation, dossier-images (.ts), filter-chips, forgot-password-form, index-all-notes, index-status, invoice-form, invoice-payments, invoice-row, invoices-panel, live-preview, logo-mark, logout-button, mission-prompt, mission-status, note-form, note-summary, password-input, payment-form, portfolio-dossier, portfolio-showcase-filter, profile-field, promote-client, publication-control, quotes-section, realisation-form, retry-indexing, rule-actions, rule-form, rule-status, scroll-effects, sense-search, sketch-data (.ts), sketches, sortable-list, sprint-block, sprint-composer, story-form, story-list, story-proposals, story-review, task-proposals, tasks, theme-switcher, today-tasks, tool-icon, typed-text, unset, update-password-form, urgency-badge.

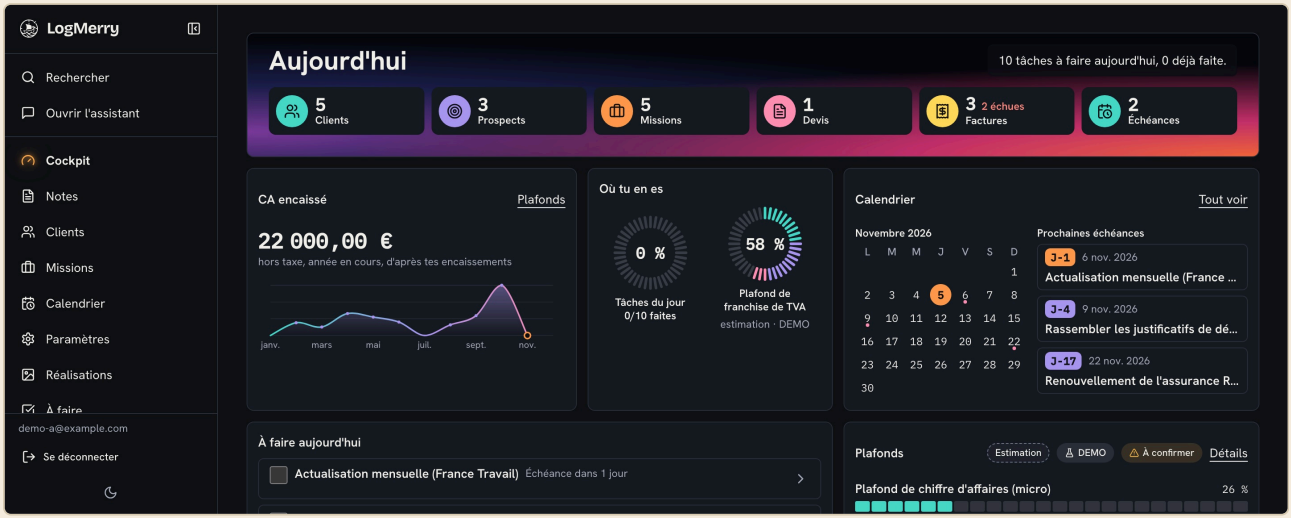
03.8

Aperçu de l'application réelle

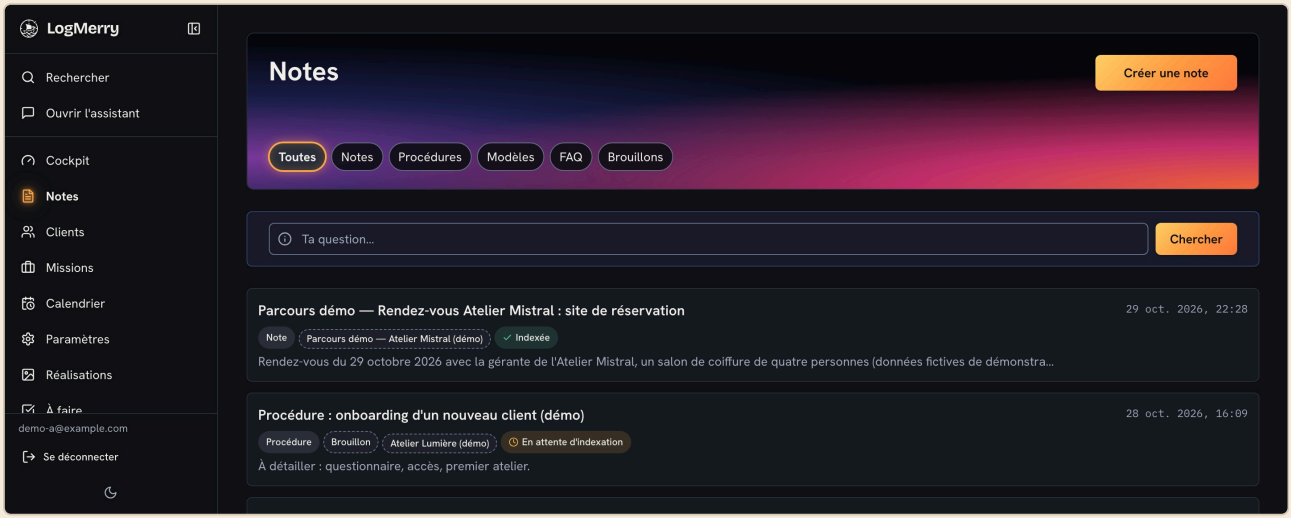
Captures prises le 5 novembre 2026 sur une version de production locale (`next build` puis `next start`), avec des données **fictives** (compte de démonstration) ; elles montrent donc l'état du code du jour, qui n'est pas celui de la production Vercel (voir le chapitre 10).



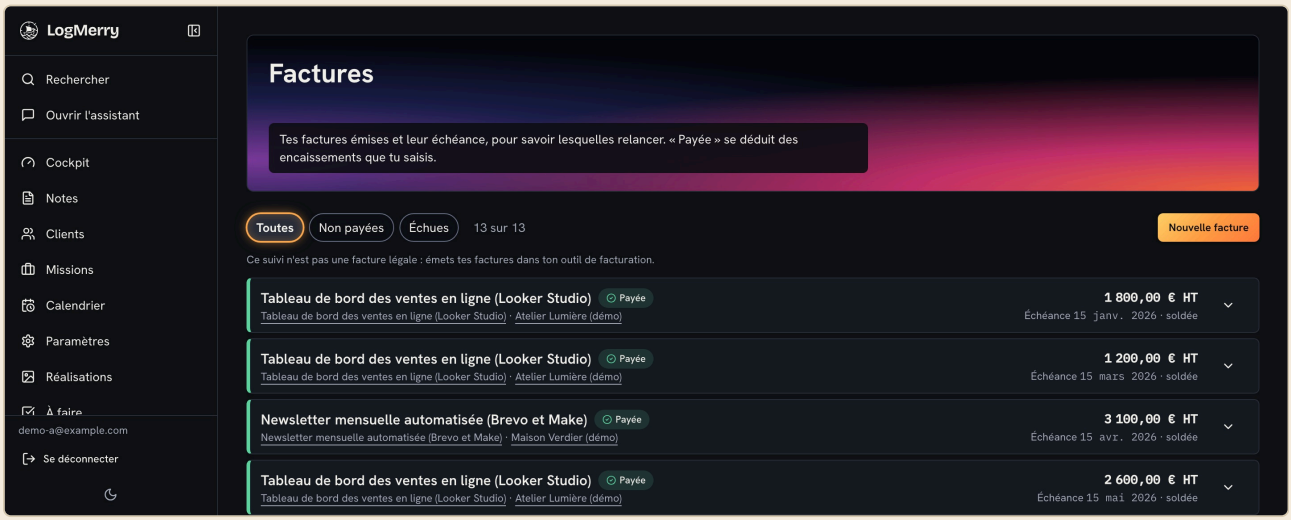
Page de connexion, thème sombre par défaut : carte centrée sur le dégradé, nom et logo en haut à gauche.



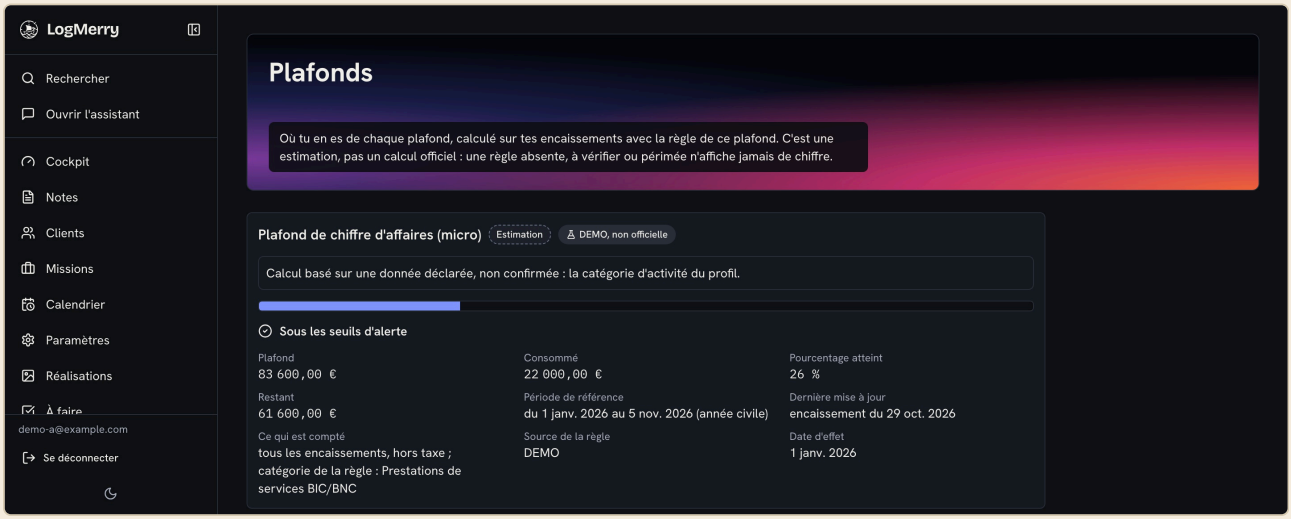
Cockpit « Aujourd'hui », thème sombre : bandeau de compteurs, chiffre d'affaires encaissé, jauge de plafond (étiquetée « estimation · DEMO »), calendrier et prochaines échéances.



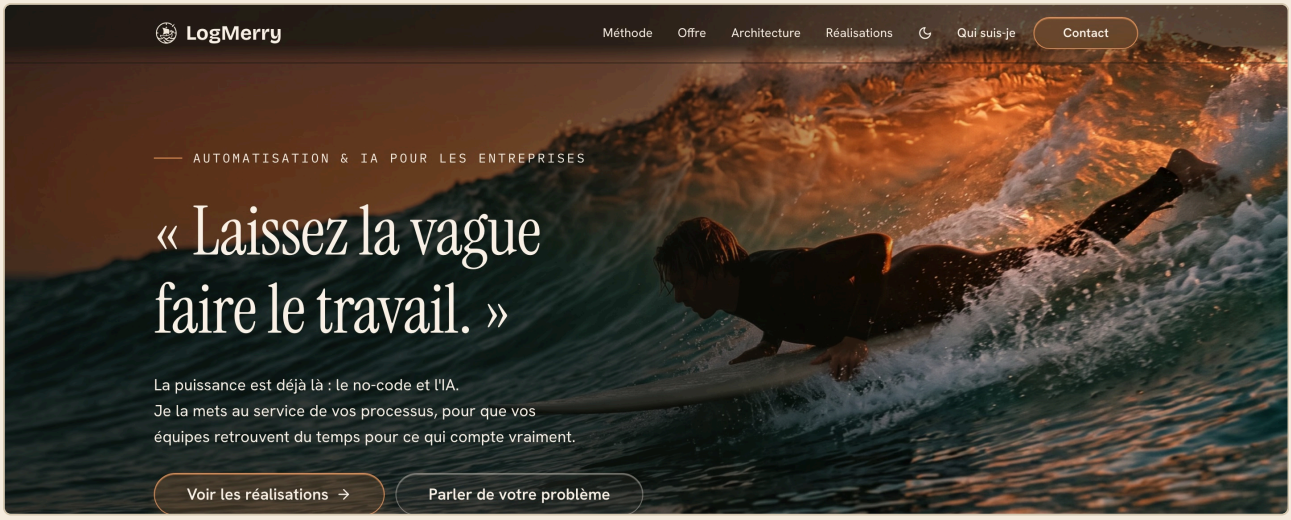
Notes : filtres par type, recherche, état d'indexation visible sur chaque note (Indexée, En attente d'indexation).



Factures : suivi sans valeur légale (mention affichée), statut « Payée » déduit des encaissements.



Plafonds : estimation étiquetée « DEMO, non officielle », donnée non confirmée signalée, règle, source et date d'effet affichées.



Portfolio public (page d'accueil) : bandeau photographique, titre en serif, étiquettes en police à chasse fixe.

03.9

Maquettes

Cinq maquettes interactives (HTML) existent dans `_bmad-output/planning-artifacts/ux-designs/ux-logmerry-2026-10-11/mockups/` : l'assistant, le cockpit, le portfolio, une référence de palette et une référence de dégradés.

> *Elles ne sont pas reprises dans ce document.* Les cinq datent du *12 octobre 2026*, avant la refonte visuelle des 15 à 18 octobre : elles ne reflètent plus l'identité actuelle. Les captures de l'application réelle ci-dessus les remplacent.

03.10

Points ouverts de la conception

POINT	ÉTAT
Raccourci ⌘K (recherche et assistant) sur Safari, Chrome et Firefox Mac	À tester
Largeur du passage en mode tablette	À fixer
Écran d'inscription et page « Finances » décrits mais non réalisés	À mettre à jour dans `EXPERIENCE.md` ou à construire
Parcours clavier complets (cockpit, saisie)	À faire par l'auteur

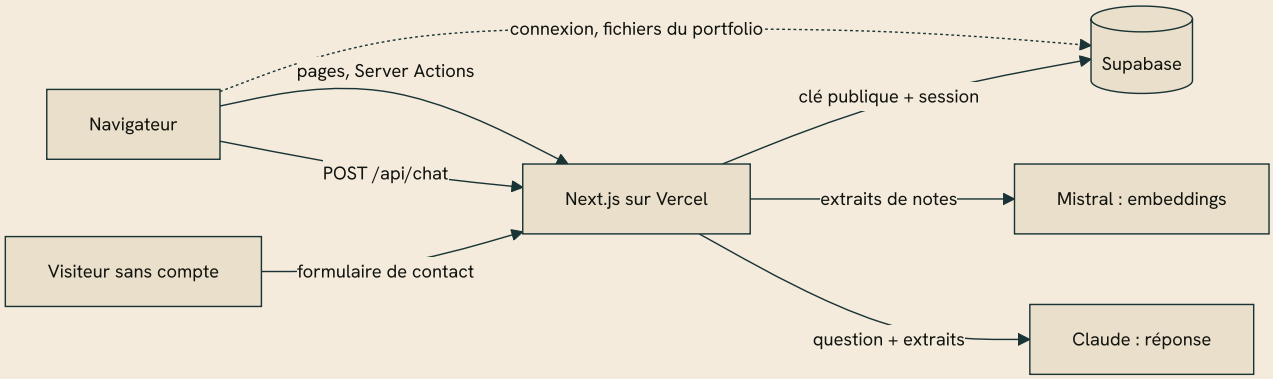
Intégration : API Supabase et authentification

> *En deux phrases.* LogMerry n'expose *qu'une seule API HTTP* (`POST /api/chat`) ; tout le reste passe par des Server Actions Next.js qui parlent à Supabase avec la session de l'utilisateur, jamais avec une clé d'administration. Il n'y a *aucun webhook* ni aucun service qui appelle l'application de l'extérieur : les seuls appels sortants vont vers Supabase, Anthropic (Claude) et Mistral.

Faits relevés dans le code et la base réelle le 5 novembre 2026 (lecture seule).

04.1

Vue d'ensemble des échanges



LIEN	QUI APPELLE	AVEC QUOI	CONTENU
Navigateur vers Supabase	Le navigateur, **cinq composants seulement**	Clé publique	Connexion, déconnexion, mot de passe oublié, nouveau mot de passe ; envoi et retrait des images du portfolio (Storage)
Next.js vers Supabase	Server Actions, Route Handler, pages	Clé publique + cookies de la session	Toutes les lectures et écritures de données
Next.js vers Mistral	Serveur seulement	Clé `MISTRAL_API_KEY`	Textes à vectoriser (modèle `mistral-embed`, 1 024 dimensions)
Next.js vers Claude	Serveur seulement	Clé `ANTHROPIC_API_KEY`	Question et extraits retrouvés ; modèle réglé par `AI_CHAT_MODEL`
Visiteur vers Next.js	Page publique `/portfolio`	Aucune session	Message du formulaire de contact

Les clés des services d'IA ne quittent jamais le serveur (voir le chapitre 11).

04.2

Les trois formes d'appel

1. La Route API : `POST /api/chat`

Seul Route Handler de l'application. Contrat :

ÉLÉMENT	VALEUR
Entrée	JSON `{ "question": "…" }`, 300 caractères au plus après nettoyage ; corps limité à 10 000 octets (en-tête puis lecture bornée)
Authentification	Session obligatoire (le proxy refuse déjà sans session ; la route revérifie)
Sortie en cas de succès	JSON de la réponse, avec ses sources (les textes viennent des extraits lus en base, pas du modèle)
Pas de flux	La réponse arrive en une fois

STATUT	CAS
200	Réponse vérifiée et sources
400	Question vide
401	Pas de session
413	Corps ou question trop longs
429	Plafond d'appels à l'IA atteint (20 par minute ou 300 par jour)
502	Mistral ou Claude en échec, ou réponse rejetée par la vérification des citations
503	Le compteur de plafond lui-même est indisponible (on bloque plutôt que de laisser passer sans compter)

L'historique de l'échange est enregistré après la réponse ; son échec **ne bloque jamais** la réponse (journal sans contenu).

2. Les Server Actions

76 actions dans 27 fichiers (`app/(app)/**/…actions.ts` et `app/portfolio/contact-action.ts`). Elles suivent toutes le même schéma, fourni par `withSession` (`lib/supabase/with-session.ts`) :

1. créer un client Supabase à partir des cookies de la requête (un client **par appel**, jamais global) ;
2. vérifier la session (`getClaims`) ; sans session, l'action n'est jamais exécutée et l'utilisateur est renvoyé à la connexion ;
3. valider les champs (fonctions de `lib/domain/`, testées) ;
4. écrire ou lire sous RLS : `owner_id` est rempli par la base (`default auth.uid()`), jamais par le client ;
5. renvoyer un état (`errors`, `message`) ou rediriger.

DOMAINE	ACTIONS (EXEMPLES)
Clients et contacts	création, modification, suppression, passage de prospect à client, contacts
Devis	création, envoi, refus, acceptation (`accept_quote`), suppression
Missions agiles	missions, user stories, tâches, sprints, ordre du backlog
Factures	factures et paiements

DOMAINE	ACTIONS (EXEMPLES)
Notes et assistant	notes, relance de l'indexation, brouillon issu d'une question, recherche, résumé, purge de l'historique
Finances et échéances	profil professionnel, règles versionnées, échéances du calendrier, cases du cockpit
Réalisations	réalisations, publication, images
Public	`sendContactMessage` (sans session)

Dix fichiers d'actions déclenchent des appels à l'IA (propositions de stories, de tâches, d'ordre du backlog, de sprint, relecture de story, prompt de mission, résumé, recherche par le sens, indexation) : **chacun consomme d'abord le plafond** (`consume_ai_quota`) avant tout appel à Mistral ou à Claude.

3. Les fonctions SQL appelées par `rpc()`

Sept fonctions sont appelées par l'application ; les droits d'exécution sont ceux de la base réelle.

FONCTION	RÔLE	EXÉCUTABLE PAR	DROITS D'EXÉCUTION
`search_notes(query)`	Recherche plein texte sans accents (20 résultats au plus)	Comptes connectés	Ceux de l'appelant (RLS)
`match_chunks(query_embedding, match_threshold, match_count)`	Recherche vectorielle dans **ses** extraits	Comptes connectés	Ceux de l'appelant (RLS) ; le seuil de similarité utilisé par l'assistant est 0,76
`consume_ai_quota()`	Compte, refuse ou enregistre un appel à l'IA	Comptes connectés	Propriétaire (`SECURITY DEFINER`), limitée à `auth.uid()`
`accept_quote(p_quote_id)`	Accepte un devis (transaction unique)	Comptes connectés	Ceux de l'appelant (RLS)
`create_rule_version(…)`	Crée une version d'une règle réglementaire	Comptes connectés	Ceux de l'appelant (RLS)
`delete_deadline_series(p_series_id)`	Supprime une série d'échéances	Comptes connectés	Ceux de l'appelant (RLS)
`submit_contact_message(p_name, p_email, p_message)`	Reçoit le message d'un visiteur	**Visiteurs sans compte** et comptes connectés	Propriétaire (`SECURITY DEFINER`, `search_path` vide)

Autres fonctions de la base, non appelées par le code de l'application : `rls_audit()` (utilisée par le test nocturne), `rule_version_is_mine()` (utilisée dans une politique de sécurité), et trois fonctions d'aide (`immutable_unaccent`, `pp_thresholds_ok`, `realisation_tags_ok`) utilisées par des contraintes et des index.

Le formulaire de contact est la seule porte ouverte aux visiteurs sans compte. La fonction valide (nom de 1 à 200 caractères, e-mail d'au plus 254, message de 10 à 4 000), refuse au-delà de 5 messages par heure, 30 par jour au total et 3 par jour pour une même adresse, ignore sans rien écrire un doublon (même adresse et même texte en moins de 24 h) (erreur `54000`, affichée comme « trop de messages »), et écrit une **note en brouillon** chez l'unique destinataire activé (table `contact_form_settings`). Côté application, un champ piège et un délai minimum d'ouverture écartent les robots (même réponse qu'un succès, rien n'est écrit). Le texte reçu est marqué « non vérifié » : c'est une donnée, jamais une consigne.

04.3

Mappings

Relevé fait dans le code et les migrations le 10 novembre 2026, fonction par fonction. Il n'existe **pas de table de mappings générale** ni de webhook : seuls les cas où une saisie devient plusieurs écritures, ou une écriture composée, sont décrits.

Formulaire de contact vers note

ÉTAPE	CE QUE FAIT LE CODE
Champs du formulaire	`name`, `email`, `message` ; deux champs de contrôle (`website`, piège ; `openedAt`, délai) ne sont **pas** transmis à la base (`app/portfolio/contact-action.ts:19-20`)
Appel	`rpc("submit_contact_message", { p_name, p_email, p_message })` (`contact-action.ts:26`) ; plafond atteint (code 54000) : message dédié (`:27`)
Fonction en vigueur	`supabase/migrations/20261107110000_contact_form_limits.sql:21-81`. Elle **remplace** la version de `20261107100000_contact_form.sql:17-60` (même insertion de la note, mais plafond de 10 messages par heure, remplacé par le journal d'envois)
Nettoyage	Nom : retours à la ligne et tabulations remplacés par une espace, espaces retirées (`:29`) ; e-mail : espaces retirées, 254 caractères au plus, une arobase (`:30`, `:36`) ; message : espaces retirées, de 10 à 4 000 caractères (`:31`, `:37`)
Écriture 1 : journal d'envois	`contact_submissions(owner_id, email_hash, message_hash)` : `md5(lower(e-mail))` et `md5(message)`, jamais le texte (`:46-47`, `:65`)
Écriture 2 : note	`notes(owner_id, title, body, status, type)` (`:67-78`). `owner_id` : le destinataire désigné dans `contact_form_settings` (`:41`) ; `title` : « Message reçu · » suivi du nom, 200 caractères au plus (`:70`) ; `body` : « Texte reçu d'un visiteur via le formulaire du portfolio, non vérifié. », puis « De : » nom, « E-mail : » adresse, « Reçu le : » date et heure de Paris, puis le message (`:71-75`) ; `status` : « draft » ; `type` : « note » (`:76-77`)
Réponses	`true` : écrit, ou doublon de moins de 24 heures ignoré (`:51-56`) ; `false` : formulaire non activé (`:42-44`) ; erreur 22023 : champ invalide (`:35-39`)

Devis accepté vers mission

`accept_quote` (version en vigueur : `supabase/migrations/20261029210000_accept_quote_title.sql:4-33`) : si le devis n'a pas de mission liée (`:20`), la mission créée reprend `client_id` du devis, un titre « {nom du client, 170 caractères au plus} — devis du JJ/MM/AAAA » construit avec la date d'envoi (`:25-27`) et le statut « planned » ; la fiche passe de prospect à client (`:22-24`) ; le devis reçoit `mission_id` et le statut « accepted » (`:29`). Si le devis avait déjà une mission, il la garde et aucune n'est créée.

Note vers nouvelle fiche prospect

ÉTAPE	CE QUE FAIT LE CODE
Champs du formulaire de note	`client_id` (la valeur « new » ouvre la création d'une fiche : `lib/domain/note-link.ts:5`), `new_name`, `new_origin` (`app/(app)/notes/actions.ts:60-69`)
Validation	`validateLink` (`lib/domain/note-link.ts:12-21`) passe `new_name` et `new_origin` à `validateClientInput` avec le statut imposé « prospect » (`:15`) ; le nom est nettoyé du caractère nul et des espaces (`lib/domain/clients.ts:32`)
Écriture de la fiche	`clients.insert({ name, status: "prospect", origin })` (`app/(app)/notes/actions.ts:80-84`)

ÉTAPE	CE QUE FAIT LE CODE
Écriture de la note	L'identifiant de la fiche créée devient `notes.client_id` (`:105`, `:136`). Les deux écritures sont successives : si la note échoue, la fiche reste (commentaire `:79`)

Champ de formulaire vers colonne : fiche client et mission

Pour la fiche client, les clés du formulaire portent le nom des colonnes : `ClientInput` (`lib/domain/clients.ts:19`) devient `ClientValues` (`:20`) par `validateClientInput` (`:31-42`), qui nettoie le nom et n'accepte que des statuts et des origines connus, puis `clients.insert(value)` (`app/(app)/clients/actions.ts:57-62`). Pour la mission, de même : `MissionInput` (`lib/domain/missions.ts:18`) devient `MissionValues` (`:19`) par `validateMissionInput` (`:33-47`), avec les dates vides converties en `null` (`:47`), puis `missions.insert(value)` (`app/(app)/missions/actions.ts:74-79`) ; à la modification, `client_id` est retiré (`:87`). `owner_id` n'est jamais envoyé : la base le pose (`:75`).

Ce n'est pas vrai pour tous les formulaires. Relevé du 12 novembre 2026, fait en lisant les fonctions de validation de `lib/domain/` et les actions qui écrivent, pour les onze entités ci-dessous. Dans tous les cas, `owner_id` n'est jamais envoyé : la base le pose. Les tâches n'ont pas de formulaire à plusieurs champs : l'action reçoit un titre (texte) en argument ; le profil s'enregistre un champ à la fois.

ENTITÉ	IDENTITÉ CHAMP VERS COLONNE ?	CONVERSIONS ET VALEURS VIDES (FICHIER:LIGNE)	ÉCRITURE
Fiche client	Oui : `name`, `status`, `origin`	Nom : caractère nul retiré, espaces retirées (`lib/domain/clients.ts:32`), 200 points de code au plus (`:37`) ; statut et origine : valeur connue ou erreur (`:33-34`, `:38-39`). Aucun champ facultatif	`clients.insert(value)` (`app/(app)/clients/actions.ts:60`), `update` (`:68`)
Mission	Oui : `client_id`, `title`, `status`, `start_date`, `end_date`	Dates vides en `null` (`lib/domain/missions.ts:47`), date inexistante refusée (`:25-30`, `:43-44`), fin avant début refusée (`:45`), titre de 200 points de code au plus (`:41`)	`missions.insert(value)` (`app/(app)/missions/actions.ts:77`) ; à la modification, `client_id` est retiré (`:87`)
Devis	**Non** : `amount_ht` et `tax` (euros saisis) deviennent `amount_ht_cents` et `tax_cents`	Montant en centimes entiers, virgule ou point, deux décimales au plus, négatif et texte refusés (`lib/domain/quotes.ts:23-28`) ; montant hors taxe obligatoire, strictement positif, 100 000 000 € au plus (`:45-49`) ; taxe vide : `null`, jamais 0 (`:51`, `:61`) ; date d'envoi vide : `null`, obligatoire seulement si le devis est envoyé (`:55-56`, `:61`) ; mission vide : `null` (`:58`, `:61`)	`quotes.insert({ client_id, ...value })` (`app/(app)/clients/quote-actions.ts:46`), `update` (`:67`)
Encaissement	**Non** : mêmes conversions en centimes (`lib/domain/payments.ts:32`, `:38`)	Taxe vide : `null` (`:38`, `:49`) ; date obligatoire, valide, jamais dans le futur (`:42-44`) ; remarque vide : `null`, 500 points de code au plus (`:46`, `:49`) ; hors taxe de 1 000 000 € au plus (`:6`, `:36`)	`payments.insert(value)` (`app/(app)/factures/payment-actions.ts:43`) ; à la modification, `invoice_id` n'est pas envoyé (`:62`)

ENTITÉ	IDENTITÉ CHAMP VERS COLONNE ?	CONVERSIONS ET VALEURS VIDES (FICHIER:LIGNE)	ÉCRITURE
User story	**Non** : texte nettoyé et points convertis	Mots de liaison retirés du début : « je veux » (`lib/domain/user-stories.ts:35`), « en tant que » (`:36`), « afin de » (`:37`, `:23-29`) ; rôle, bénéfice et critères vides : `null` (`:52`) ; points : chiffres seulement, parmi 1, 2, 3, 5, 8, 13, vide : `null` (`:11`, `:42`, `:49`)	`user_stories.insert({ ...value, mission_id, position, source_note_id })` (`app/(app)/missions/story-actions.ts:91-93`) : position à la dernière place, note d'origine gardée seulement si elle est une note de la fiche de la mission (`:84-87`) ; à la modification, le statut n'est écrit que s'il a changé dans le formulaire (`:155`, `:159`)
Réalisation	**Non** : `stack` (texte à virgules) devient une liste, les cases à cocher deviennent des booléens	Texte nettoyé : nul, espaces de largeur nulle retirés, `\r\n` en `\n` (`lib/domain/realisations.ts:78-85`) ; champs facultatifs vides : `null` (`:123`) ; étiquettes : doublons retirés, 12 au plus, 40 points de code chacune (`:106-117`, `:150-151`) ; adresse publique : https seulement, sans identifiant (`:95-103`) ; « on » devient `true` (`:156`)	`realisations.insert(value)` (`app/(app)/realisations/actions.ts:70`) ; à la modification, `published: false` est ajouté (`:80`)
Note	Oui pour `title`, `body`, `type`	Titre : nul retiré, espaces retirées, 200 points de code au plus ; texte : nul retiré, **espaces gardées**, 50 000 au plus (`lib/domain/notes.ts:69-70`, `:1-2`) ; type : l'un des quatre connus (`:4`, `:80`). Le champ `client_id` vient d'un autre champ du formulaire (voir « Note vers nouvelle fiche prospect »)	`notes.insert({ ...value, client_id })` (`app/(app)/notes/actions.ts:136`) ; à la modification, `index_status` passe à « pending » si le titre ou le texte a changé (`:152-155`)
Facture	**Non** : `amount_ht` et `tax` (euros) deviennent `amount_ht_cents` et `tax_cents`	Mêmes conversions que le devis (`lib/domain/invoices.ts:48-56`), 1 000 000 € au plus (`:8`, `:52`) ; taxe vide : `null` (`:54`, `:69`) ; échéance obligatoire et valide (`:58-59`) ; émission vide : `null`, jamais dans le futur, échéance jamais avant l'émission (`:61-63`, `:69`) ; devis vide : `null` (`:46`, `:69`) ; référence (60 points de code) et remarque (500) vides : `null` (`:65-66`, `:69`)	`invoices.insert(value)` (`app/(app)/factures/actions.ts:46`) ; `update(value)` avec le même objet (`:62`)
Sprint	Oui : `name`, `goal`, `start_date`, `end_date`	Nom de 120 points de code au plus, objectif de 300 au plus et vide : `null` (`lib/domain/sprints.ts:26-28`, `:35`) ; deux dates obligatoires et valides, fin jamais avant début (`:29-33`) ; à la création, nom vide ou « Sprint N » déjà pris : remplacé par le prochain numéro libre, calculé côté serveur (`app/(app)/missions/sprint-actions.ts:69-74`, `lib/domain/sprints.ts:106-111`)	`sprints.insert({ ...value, mission_id })` (`sprint-actions.ts:65`) ; pour un sprint clos, seuls `name` et `goal` sont envoyés (`:85-86`)

ENTITÉ	IDENTITÉ CHAMP VERS COLONNE ?	CONVERSIONS ET VALEURS VIDES (FICHIER:LIGNE)	ÉCRITURE
Tâche	Pas de formulaire à plusieurs champs : le titre (texte) est un argument de l'action	Valeur qui n'est pas du texte : titre vide ; nul retiré, espaces retirées, 200 points de code au plus, titre vide refusé (`lib/domain/tasks.ts:8-14`) ; lot de 1 à 50 titres (`:30-39`)	`tasks.insert({ story_id, title, position })`, position à la dernière place (`app/(app)/missions/task-actions.ts:57-59`) ; `update({ title })` (`:96`) ; `update({ done })` (`:110`)
Profil	**Non** : un champ à la fois ; `value` et `other` deviennent `<clé>` et `<clé>_other`	Valeur vide : `null`, c'est-à-dire « À confirmer », sauf le statut juridique et la catégorie d'activité, préremplis par défaut (voir chapitre 13, registre des traitements) (`lib/domain/profile.ts:67`, `:78`, `:82`) ; choix : valeur de la liste ou « autre » avec un texte de 200 points de code au plus (`:68-75`) ; choix sans « Autre » : `<clé>_other` remis à `null` (`:75`) ; date valide, une date future est acceptée (`:27`, `:77-80`) ; texte libre de 2 000 points de code au plus (`:83`) ; seuils d'alerte : sous-ensemble de 50, 75, 90 et 100, sans doublon, triés (`:88-91`)	`professional_profile.update(...)` (`app/(app)/profil/actions.ts:53-58`) ; la confirmation pose `<clé>_confirmed_at` (`:37`) ; le retour en « Déclaré » à la modification est fait par un déclencheur de la base, d'après le commentaire de l'action (`:17`) : déclencheur **non relu**

Une valeur vide devient donc `null` presque partout, et le montant en euros n'est jamais gardé comme nombre à virgule : la base ne reçoit que des centimes entiers. Seuls les cas relus sont affirmés ici.

04.4

Authentification

Voir le détail et le schéma du proxy au chapitre 11. Ce qui compte pour l'intégration :

ÉTAPE	MÉCANISME
Connexion	Composant navigateur : `signInWithPassword` (e-mail et mot de passe d'au moins 12 caractères) ; Supabase dépose la session dans des cookies
Session côté serveur	Le proxy (`proxy.ts`) appelle `getClaims()` à chaque requête, rafraîchit les cookies et applique `accessDecision`
Utilisation de la session	`createClient()` (serveur) relit les cookies : **la base reconnaît l'utilisateur** via `auth.uid()` et applique la RLS
Réinitialisation du mot de passe	Lien par e-mail vers `/auth/confirm` (échange d'un code PKCE contre une session), puis `/auth/update-password` ; en cas d'échec : `/auth/error`
Déconnexion	`signOut()` côté navigateur
Session expirée pendant le chat	L'API répond 401 en JSON (le proxy ne redirige jamais une requête d'API) ; l'interface affiche « Ta session a expiré »

04.5

Contrat de sécurité de l'intégration

- **Un seul type de clé** côté Supabase : l'adresse du projet et la clé **publique**. La clé d'administration n'existe pas dans le projet (test).
- **Le serveur n'a pas plus de droits que l'utilisateur** : une Server Action qui oublie de filtrer ne peut de toute façon lire que les lignes du compte, car la RLS s'applique.
- **Une entrée ne devient jamais un propriétaire** : `owner_id` est posé par la base ; une insertion au nom d'un autre compte est refusée (test d'isolation).
- **Les textes venus de l'extérieur sont des données** : message du formulaire de contact, notes, extraits.

04.6

Délais, erreurs et reprises

APPEL	DÉLAI	ÉCHEC	NOUVELLE TENTATIVE AUTOMATIQUE
Claude (`api.anthropic.com/v1/messages`)	60 s	Erreur sans contenu ni clé dans le journal ; l'utilisateur voit un message fixe	Aucune
Mistral (`api.mistral.ai/v1/embeddings`)	20 s par lot	Idem ; une note non indexée passe à « échec » et se relance à la main	Aucune
Supabase (Server Actions)	Aucun délai propre posé par l'application sur ses appels Supabase (constat de code (lecture du code le 12 novembre 2026, par l'assistant) ; supabase-js 2.117.3, valeurs par défaut du client) ; durée maximale de la fonction Vercel : défaut de la plateforme, non vérifié	L'action renvoie « Enregistrement impossible. Réessaie. » ; côté navigateur, « Le serveur ne répond pas »	Aucune

Aucune nouvelle tentative automatique n'existe nulle part : c'est un choix de simplicité, et une limite (voir ci-dessous).

04.7

Ce qui n'existe pas

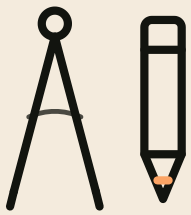
ÉLÉMENT	ÉTAT
Webhooks entrants ou sortants	**Aucun** : un seul Route Handler (`/api/chat`)
Tâches planifiées de l'application	**Aucune** (rappels et résumé hebdomadaire : n8n, hors du MVP)
Versionnement de l'API	**Aucun** : l'unique API est interne à l'application
Limitation de débit des routes HTTP en général	Seulement le plafond d'appels à l'IA et celui du formulaire de contact (5 messages par heure, 30 par jour au total et 3 par jour pour une même adresse)
Documentation d'API générée (OpenAPI)	**Aucune** : ce chapitre en tient lieu

04.8

Limites et suite

LIMITE	CONSÉQUENCE	PISTE
Aucune nouvelle tentative sur les appels sortants	Une panne brève de Claude ou de Mistral se voit tout de suite par l'utilisateur	Une reprise unique avec attente, si l'usage le justifie
Délai d'une Server Action complète vers Supabase non mesuré	**À confirmer**	Un appel simple à l'interface publique de Supabase a été mesuré le 5 novembre 2026 (médianes de 104 ms et 113 ms sur 30 requêtes : `05-qos.md:16-23`) ; le délai d'une Server Action complète n'a pas été mesuré (encadré « À confirmer » du chapitre 5)
Plafond du formulaire de contact calculé sur la table `contact_submissions` (empreintes d'adresses et de messages, supprimées après 30 jours), indépendante des notes	Supprimer une note ne libère pas de place dans le plafond ; un robot qui change d'adresse reste limité à 30 messages par jour	Un captcha, si le volume l'exige

Qualité de service



> *En deux phrases.* Ce chapitre donne les délais *mesurés* (appels à Supabase, réponse de l'assistant, pages publiques), les plafonds *réglés dans le code*, les contrôles qui tournent à chaque envoi, et dit ce qui n'est *pas* surveillé. Il n'existe *aucun engagement de disponibilité* : LogMerry tourne sur l'offre gratuite de Supabase.

05.1

Comment lire les chiffres

ÉTIQUETTE	SENS
Mesuré	Chronométré, avec la date et la méthode
Réglage	Valeur écrite dans le code ou la base ; ce n'est pas une mesure
Objectif proposé	Seuil que je propose ; à valider par l'auteur, aucun engagement
À confirmer	Pas de mesure ni de source

05.2

Délais mesurés

Appels à Supabase (5 novembre 2026)

Méthode : 30 requêtes successives vers l'interface publique du projet (clé publique, aucune donnée privée), depuis le Mac de l'auteur en France (aller-retour réseau vers un serveur public voisin : environ 10 ms). Mesure du temps total de chaque requête, du départ à la fin de la réponse.

APPEL	MÉDIANE	95E CENTILE	MAXIMUM	RÉPONSES
Santé de l'authentification (`/auth/v1/health`)	104 ms	134 ms	334 ms	30 sur 30 en 200
Lecture de la vue publique des réalisations (REST)	113 ms	178 ms	316 ms	30 sur 30 en 200

Lecture : un appel simple à Supabase prend **environ 0,1 seconde** de bout en bout depuis la France. Ce n'est pas le délai des Server Actions : elles tournent sur Vercel (Paris, `cdg1`), dans la même région que la base (Paris, `eu-west-3`), donc plus près que ce Mac, mais **ce trajet n'a pas été mesuré**.

> *À confirmer.* Délai d'une Server Action complète (navigateur, Vercel, Supabase), de la connexion avec mot de passe, et de la recherche vectorielle seule. Les requêtes de l'application n'apparaissent pas parmi les plus lentes des statistiques de la base (`pg_stat_statements`, dix requêtes les plus lentes avec plus de 20 appels : toutes des requêtes du tableau de bord et de l'outillage Supabase, de 24 à 517 ms en moyenne). Je n'en tire pas de durée pour l'application : je n'ai pas isolé ses requêtes une à une.

Réponse de l'assistant (4 novembre 2026)

Détail au chapitre « Rapport d'évaluation » : **3,4 secondes en moyenne** par question, 95e centile entre **6,1 et 7,0 secondes**, dont environ 2,9 à 3,0 secondes pour l'appel à Claude. Deux exécutions seulement : ce sont des ordres de grandeur.

Pages publiques (portfolio)

Mesures du journal, sur un build de production local, Lighthouse mobile :

PAGE	MESURE	DATE
« Qui suis-je »	Performance 95 à 98 ; accessibilité, bonnes pratiques et SEO à 100 ; environ 390 Ko	4 novembre 2026
Page d'accueil (hero)	Plus grand élément affiché (LCP) 1 547 ms après correction (1 971 ms avant), décalage de mise en page (CLS) 0	30 octobre 2026

Limites. Mesures locales, pas sur le site en production ; la performance des pages **connectées** (cockpit, notes, factures) n'a pas été mesurée, seulement leur accessibilité.

05.3

Plafonds et délais réglés dans le code

ÉLÉMENT	RÉGLAGE	OÙ
Appels à l'assistant par utilisateur	20 par minute, 300 par jour ; au-delà, refus (statut 429)	`consume_ai_quota` (base)
Appel à Claude	Délai de 60 s, aucune nouvelle tentative	`lib/ai/claude-tool.ts`
Appel à Mistral	Délai de 20 s par lot de 16 extraits, aucune nouvelle tentative	`lib/ai/embeddings.ts`
Formulaire de contact	5 messages par heure, 30 par jour au total et 3 par jour pour une même adresse, délai minimum de 3 s avant l'envoi	`submit_contact_message`
Appels à Supabase depuis l'application	Aucun délai propre posé par l'application sur ses appels Supabase (constat de code (lecture du code le 12 novembre 2026, par l'assistant) ; supabase-js 2.117.3, valeurs par défaut du client) ; durée maximale de la fonction Vercel : défaut de la plateforme, non vérifié	Constat de code (lecture du code le 12 novembre 2026, par l'assistant) : aucun délai ni `abortSignal` sur les appels Supabase (`lib/`, `app/`)

Conséquence à connaître : l'enregistrement d'une note attend l'indexation. Si Mistral est lent, l'enregistrement peut durer **jusqu'à 20 secondes** avant de passer à l'état « échec » (la note, elle, est conservée).

05.4

Objectifs proposés

Aucun budget n'a été fixé jusqu'ici. Je propose des seuils **proches de ce qui est mesuré**, pour qu'ils servent de repère, pas de promesse.

MESURE	OBJECTIF PROPOSÉ	MESURÉ AUJOURD'HUI
Réponse de l'assistant, moyenne	Moins de 5 s	3,4 s

MESURE	OBJECTIF PROPOSÉ	MESURÉ AUJOURD'HUI
Réponse de l'assistant, 95e centile	Moins de 10 s	6,1 à 7,0 s
Pages publiques, performance Lighthouse mobile	90 ou plus	95 à 98 (une page)
Pages publiques, accessibilité	100	100
Exactitude de l'assistant sur le jeu de 20 questions	19 sur 20 ou plus, sans fuite	20 sur 20, aucune fuite
Disponibilité	**Aucun objectif** : aucun engagement possible sur l'offre gratuite	Non mesurée

05.5

Contrôles automatiques à chaque envoi

Fichier `.github/workflows/ci.yml`, déclenché par chaque envoi et chaque demande de fusion :

TÂCHE	CONTENU
`check`	Typage (`tsc`), analyse du code (`lint`), tests (`npm test`), construction de l'application (`next build`)
`audit`	`npm audit` sur les dépendances de production, niveau « élevé » ; séparé du reste pour qu'une panne du registre ne passe pas pour un échec du code

Le test d'isolation entre deux comptes a son propre fichier (`isolation.yml`) : voir le chapitre « Déploiement ». **Aucun test de charge** n'existe, et la CI ne mesure ni la performance ni la latence.

05.6

Observabilité : ce qui existe

SOURCE	CE QU'ON Y LIT	LIMITE
Tableau de bord Supabase	Journaux de l'API, de la base et de l'authentification ; avis de sécurité et de performance (« advisors »)	Conservation des journaux : d'après la documentation de Supabase consultée le 12 novembre 2026 : 1 jour sur l'offre gratuite (non relevé dans le tableau de bord du projet)
Vercel	Journaux d'exécution des fonctions, état de chaque déploiement	Idem
Table `ai_calls`	Nombre d'appels à l'assistant par utilisateur (comptage, pas de contenu)	Sert au plafond, pas à la mesure de latence
Journal applicatif	Erreurs des appels sortants, sans contenu ni clé	Aucune agrégation ni alerte

Avis de performance de Supabase au 5 novembre 2026 (lecture seule, niveau « info », aucun avertissement) :

AVIS	DÉTAIL	DÉCISION
3 clés étrangères sans index	`message_citations.owner_id`, `realisation_images.owner_id`, `regulatory_rules.previous_version_id`	À ajouter si ces tables grossissent ; sans effet visible avec les volumes de démonstration

AVIS	DÉTAIL	DÉCISION
4 index jamais utilisés	`note_chunks_embedding_idx`, `notes_search_idx`, `message_citations_note_idx`, `message_citations_chunk_idx`	**Pas supprimés** : l'index vectoriel et l'index de recherche servent quand le volume monte ; avec quelques notes, la base lit la table entière, ce qui est plus rapide

Capture du tableau de bord (fournie par l'auteur, 5 novembre 2026)

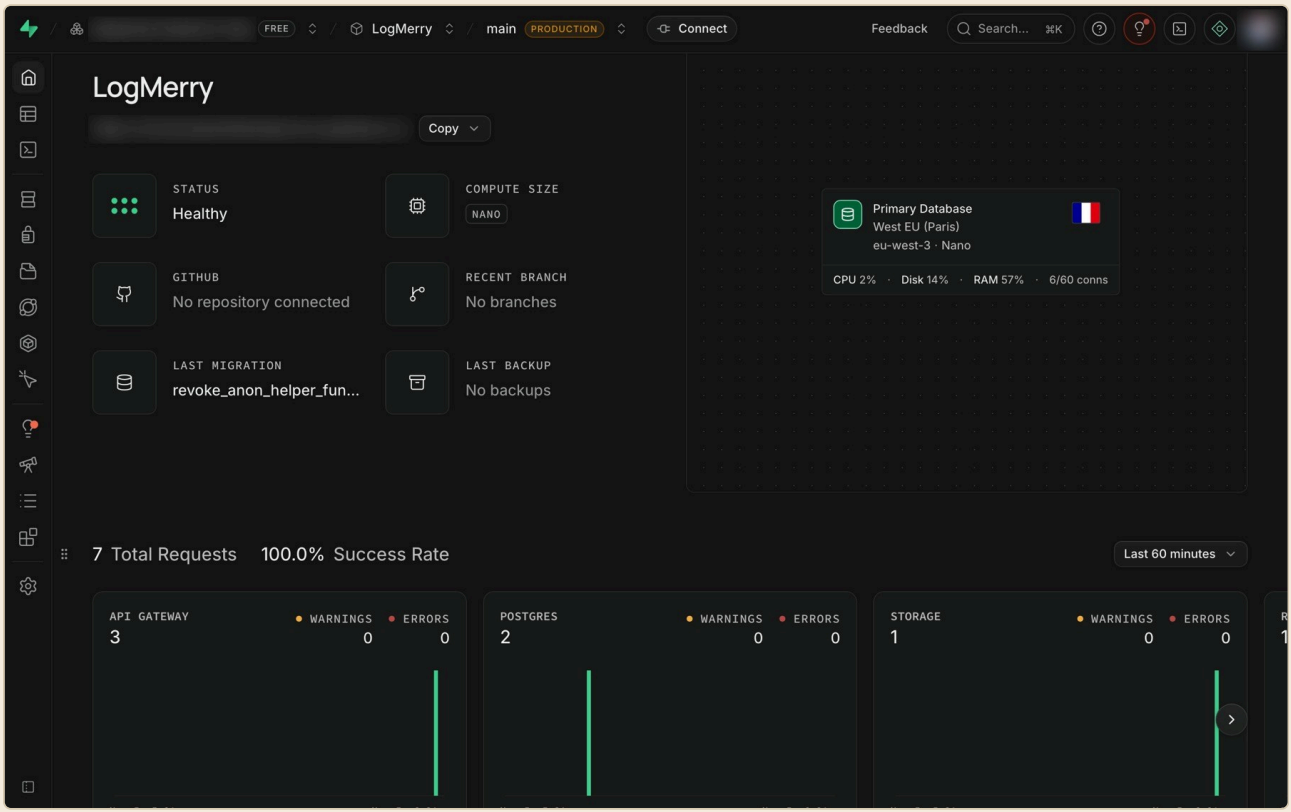


Tableau de bord Supabase du projet LogMerry : état « Healthy », calcul Nano, base à Paris (eu-west-3), CPU 2 %, disque 14 %, mémoire 57 %, 6 connexions sur 60, aucune sauvegarde, 7 requêtes sur la dernière heure, toutes réussies. Capture partiellement floutée par l'auteur.

Capture partiellement floutée par l'auteur : nom de l'organisation, adresse du projet et photo de profil rendus illisibles (flou appliqué le 13 novembre 2026 sur une copie ; l'original reste dans l'historique Git).

CE QUE LA CAPTURE MONTRE	LECTURE
État « Healthy », calcul Nano, base principale à Paris (`eu-west-3`)	Cohérent avec l'offre gratuite et la région annoncée
CPU 2 %, disque 14 %, mémoire 57 %, 6 connexions sur 60	Instantané d'un moment de faible activité, **pas une mesure de charge**. La mémoire à 57 % est normale pour un petit calcul mais laisse peu de marge si le volume monte
« Last backup : No backups »	**Confirme l'absence de sauvegarde automatique** (voir le chapitre « Continuité »)
« GitHub : No repository connected »	Les migrations ne passent pas par l'intégration GitHub de Supabase : elles sont appliquées à la main (voir « Déploiement »)
Dernière migration : `revoke_anon_helper_fun…`	Correspond à la migration qui a retiré les droits d'`anon` sur quatre fonctions d'aide
7 requêtes sur 60 minutes, taux de réussite 100 %	Trafic quasi nul au moment de la capture ; aucun avertissement ni erreur

Les autres chiffres de ce chapitre viennent de requêtes en lecture seule et de mesures faites depuis le poste de l'auteur.

05.7

Ce qui n'existe pas

ÉLÉMENT	ÉTAT
Alertes (panne, erreurs, quotas)	**Aucune** : personne n'est prévenu d'une panne
Surveillance de disponibilité depuis l'extérieur	**Aucune**
Mesure de performance en production (utilisateurs réels)	**Aucune**
Test de charge	**Aucun**
Mesure de la latence des Server Actions	**Aucune** (à confirmer ci-dessus)
Engagement de disponibilité (SLA)	**Aucun**, ni chez Supabase gratuit ni dans l'application

05.8

Modes dégradés

Détail au chapitre « Continuité » : en cas de panne de Claude ou de Mistral, l'assistant affiche un message fixe et le reste de l'application fonctionne ; une note dont l'indexation échoue est enregistrée et se relance à la main ; une panne de Supabase rend l'application indisponible.

05.9

Limites et suite

LIMITE	PISTE
Une seule mesure de latence réseau, depuis un seul lieu, hors Vercel	Mesurer une Server Action depuis le navigateur sur la production
Deux exécutions seulement pour la latence de l'assistant	En refaire quelques-unes avant la soutenance (appels payants, avec l'accord de l'auteur)
Aucune alerte	Une surveillance externe gratuite de l'adresse publique, une fois l'alias de production confirmé
Projet mis en pause après une semaine sans activité (offre gratuite)	Voir le chapitre « Continuité » ; un appel quotidien anti-pause reste une **question ouverte** pour l'auteur

Démonstration de l'application

> *En deux phrases.* La démonstration se fait sur l'adresse de production `https://logmerry.vercel.app` (QR ci-dessous), avec un compte fictif, et suit un scénario de 14 étapes qui va d'un prospect à une facture payée en une vingtaine de minutes. Ce scénario a été déroulé en développement le 29 octobre 2026 ; *il n'a pas été rejoué sur la production*, et le portfolio public, la page « Qui suis-je » et le formulaire de contact y sont depuis le 5 novembre 2026.

06.1

Où et comment

ÉLÉMENT	VALEUR
Adresse	`https://logmerry.vercel.app` (arrive sur la page de connexion)
Compte de démonstration	`demo-a@example.com`, compte **fictif**. Le mot de passe n'est écrit nulle part dans ce document : il est dans le gestionnaire de mots de passe de l'auteur du projet (ou le fichier local `.env.test.local`, ignoré par Git)
Inscription	Désactivée : on ne peut pas créer de compte depuis l'adresse publique
Données	Fictives, étiquetées « démo » ; la base ne contient aucune vraie donnée client
Portfolio public	`https://logmerry.vercel.app/portfolio`, **sans connexion** (vérifié le 5 novembre : réponse 200)
Second compte	Un compte B fictif sert au test d'isolation (`TEST_B_EMAIL`, dans `.env.test.local`, que je ne lis pas) : son adresse n'est pas écrite ici

QR code vers https://logmerry.vercel.app

QR généré en local depuis l'adresse ci-dessus (bibliothèque `qrcode`, installée hors du dépôt). ***Scanné par l'auteur du projet avec un téléphone le 5 novembre 2026*** *: il ouvre la page de connexion.*

06.2

Ce que la production contient (et ne contient pas)

Dernier commit déployé en production au 12 novembre 2026 : `7d0558e` (fusion de la pull request n° 105, après les n° 103 et 104 ; API des déploiements de GitHub, statut « success »). Au 5 novembre 2026 : `59c9d8c` (fusion de la pull request n° 102 : formulaire de contact et « Qui suis-je », après les n° 96, 97 et 99). La branche `feat/portfolio-image-zoom` n'est pas fusionnée :

l'agrandissement des miniatures n'est pas en production. Déploiement terminé dans Vercel (statut de commit GitHub : « Deployment has completed »).

VISIBLE EN DÉMONSTRATION	ABSENT DE LA PRODUCTION
Cockpit « Aujourd'hui », clients, notes, assistant, devis, missions, backlog, sprints, factures, plafonds, échéances	Rien de prévu qui ne soit pas en ligne ; voir « Ce qui n'est pas démontrable »
Réalisations (gestion dans l'application, captures avec texte alternatif, statut, « Choix de conception » et « Validation ») ; portfolio public (`/portfolio`, sans connexion) ; page « Qui suis-je » (`/portfolio/qui-suis-je`) ; formulaire de contact (remplace le lien « M'écrire »)	—

> *À savoir.* Le formulaire de contact écrit dans les notes du compte propriétaire, en brouillon. Un message envoyé pendant la démonstration y apparaît ; à supprimer ensuite. Sa ligne d'information est courte (base légale et durée sont décidées ; contact décidé le 12 novembre 2026 (nom + e-mail) ; les droits restent à compléter : chapitre « Exploitation et conformité »).

06.3

Avant de commencer : la liste de contrôle

À faire **la veille**, puis une dernière fois le matin :

#	CONTRÔLE	COMMENT	ÉTAT RELEVÉ LE 5 NOVEMBRE
1	Le projet Supabase n'est pas en pause (offre gratuite : pause après une semaine sans activité)	Tableau de bord Supabase, ou ouvrir la page de connexion et se connecter	Actif (« ACTIVE_HEALTHY »)
2	La production répond	Ouvrir l'adresse ; scanner le QR	Répond (connexion en 200)
3	La connexion avec le compte fictif fonctionne	Se connecter	**Essayé le 9 novembre 2026** : cockpit affiché
4	L'assistant répond (clés Anthropic et Mistral valides, crédit disponible)	Poser une question de la note de démonstration	**Essayé le 9 novembre 2026** (voir « Rejeu du 9 novembre 2026 ») : réponse sourcée en 3,5 s
5	Pas de restes d'un précédent essai	Supprimer ou renommer les fiches « Parcours démo » (le scénario crée « Atelier Mistral (démo) »)	À vérifier à l'écran
6	Le thème (sombre par défaut) et le zoom conviennent à la salle	—	—

06.4

Scénario

Reprise du fichier `docs/parcours-demo.md`, déroulé le 29 octobre 2026 sur le compte A. Tout est fictif et préfixé « Parcours démo ».

#	ÉTAPE	OÙ	CE QU'ON SAISIT	CE QU'ON DOIT VOIR
1	Connexion	`/auth/login`	Compte de démonstration	Le cockpit

#	ÉTAPE	OÙ	CE QU'ON SAISIT	CE QU'ON DOIT VOIR
2	Prospect	Clients, « Créer une fiche »	« Parcours démo — Atelier Mistral (démo) », origine « Démo »	Fiche « Prospect »
3	Note du rendez-vous	Notes, « Créer une note »	Titre « Rendez-vous Atelier Mistral : site de réservation », liée à la fiche ; salon de coiffure, site avec réservation en ligne, rappel SMS la veille, budget d'environ 2 400 € HT, en ligne fin novembre, pas de nom de domaine	Note « Indexée », visible sur la fiche
4	Question à l'assistant	Panneau « Ouvrir l'assistant »	« Quel budget et quel délai l'Atelier Mistral m'a-t-il annoncés pour son site de réservation ? »	Réponse juste (2 400 € HT, fin novembre) avec « Source 1 » = la note
5	Devis	Fiche, « Nouveau devis »	2 400 € HT, taxe vide, puis « Marquer envoyé »	Brouillon, « taxe inconnue », puis « Envoyé »
6	Devis accepté	Fiche, « Accepté » puis « Oui, accepté »		La fiche devient « Client » ; mission « Client — devis du JJ/MM/AAAA » créée, « À planifier »
7	Backlog	Mission, « Proposer des user stories avec l'IA »	Cocher la note ; garder 4 propositions sur 5 (rejeter celle que la note ne justifie pas) ; ajouter une story à la main	4 stories et leurs tâches, avec la source ; une 5e à la main
8	Sprint	Mission, « Ajouter un sprint »	Objectif, dates ; « Composer avec l'IA », capacité 13 ; « Placer » ; « Démarrer le sprint »	2 stories (8 + 5 = 13 points), sprint « En cours »
9	Livraison	Mission	Stories « Terminée », « Clore le sprint », puis mission « Terminée »	Sprint clos ; mission « Terminée »
10	Rappel « Facturer »	Cockpit		« Facturer la mission … : mission terminée, aucune facture enregistrée »
11	Facture	Mission, « Nouvelle facture »	2 400 € HT, échéance dans un mois, devis lié	« Non payée » ; le rappel disparaît
12	Règlement	Factures, détail, « Ajouter un encaissement »	2 400 € HT	« Payée », « soldée »
13	Prompt	Mission, bouton de prompt	« La mission seule » ou le contexte complet ; un objectif	Prompt relisible, sans montant ni donnée financière
14	Isolation	Test de sécurité	`npm run test:isolation` (sur le poste de l'auteur du projet)	Le compte B ne voit rien du compte A

Durée : une vingtaine de minutes, dont environ trois d'attente de l'IA (étapes 4, 7 et 8).

Version courte (5 minutes)

Si le temps manque : étape 1 (cockpit), puis 3 et 4 (note et question, c'est le cœur du projet : une réponse **qui cite sa source**), puis la page Plafonds (jauge étiquetée « estimation · DEMO »). Les données de démonstration sont déjà en place : `npm run seed:demo`, `seed:backlog`, `seed:activity` et `seed:to-invoice` les posent sur le compte fictif (essai à blanc possible, refus de tout compte hors `@example.com`).

06.5

Rejeu du 9 novembre 2026 (production)

Le rejeu a été fait par Claude Code (l'assistant de code), pas par l'auteur du projet ; connexion saisie par l'utilisateur, mot de passe jamais lu ni enregistré par l'assistant de code. Étapes rejouées en lecture et en questions : cockpit, notes, recherche par mots-clés et par sens, assistant (3 questions), propositions de user stories (non gardées). **Origine des chiffres : mesure sur la production, une seule exécution, précision d'environ 0,5 s** (détail et limites au chapitre 7).

ÉTAPE	CONSTAT	TEMPS
Question dont la réponse est dans une note	3 puces, 1 source cliquable	3,5 s
Question hors corpus	Réponse prudente + avertissement « Aucune de tes notes ne soutient cette réponse » (**pas un refus à phrase fixe**)	3,5 s
Question sur la TVA	Aucun taux, renvoi vers un expert-comptable	2,5 s
Propositions de user stories	7 propositions à relire	**19,6 s**

Pendant les 20 secondes de génération des stories (l'auteur parle, 3 ou 4 phrases) : « Je viens de donner à l'IA le brief de la mission et la note du rendez-vous ; rien n'est enregistré tant que je ne garde pas une proposition. Claude doit appeler un outil qui impose la forme d'une story, avec ses critères et ses tâches. Chaque proposition est vérifiée : une proposition qui cite une source inconnue ou un chiffre absent des notes est écartée. » **Si le badge « Brouillon » de la note « Procédure : relancer une facture échue (démo) » est visible** (phrase à dire) : « Ce badge « Brouillon » est resté sur une note pourtant complète : l'application ne fait pas passer toute seule une note de brouillon à active. C'est une limite connue, documentée au chapitre 2 : un brouillon complété reste indexé et citable par l'assistant, mais il est exclu des propositions de stories. »

Repli si la génération dépasse 40 secondes : continuer à parler, puis montrer la capture du plan B (`docs/soutenance/plan-b/12-propositions-user-stories.png`) et passer à l'étape suivante.

Nettoyage du compte de démonstration (par l'auteur du projet, données fictives) : supprimer la mission « blabla mission » depuis l'application (**à faire, À confirmer**) ; vider l'historique de l'assistant (« Vider la conversation ») **lundi 16 novembre au matin, avant la démonstration** ; le brouillon « Procédure : onboarding d'un nouveau client (démo) » reste « En attente d'indexation » (laissé en place).

06.6

Ce qui peut mal tourner, et la réponse

INCIDENT	EFFET	RÉPONSE
Supabase en pause	Connexion impossible	Réactiver le projet depuis le tableau de bord Supabase avec « Resume project » ; la page de Supabase consultée le 12 novembre 2026 donne une fenêtre de restauration d'un an et ne donne pas de durée de reprise (**non établie**) ; d'où le contrôle de la veille
Anthropic ou Mistral indisponible	Étapes 4, 7 et 8 sans réponse de l'IA (message fixe) ; le reste fonctionne	Passer à l'étape suivante ; montrer les captures et le chapitre « Rapport d'évaluation » (20 sur 20, 3,4 s)
Plafond d'appels atteint (20 par minute)	Refus avec un message qui demande d'attendre une minute	Attendre une minute

INCIDENT	EFFET	RÉPONSE
Réseau de la salle	Tout est indisponible	Captures du chapitre « UX et maquettes » (6 images) ; l'application locale (`npm run dev`) en secours, mais elle parle à **la même base**
La réponse de l'assistant paraît fausse	—	La vérification des citations rejette une réponse dont la source n'existe pas ; en cas de doute, montrer la source citée

06.7

Ce qui n'est pas démontrable aujourd'hui

- Les **performances en production** : les pages ont été mesurées en développement (0,4 à 1,5 s par page, à chaud) ; la mesure sur le déploiement avec une session connectée reste à faire.
- L'**envoi réel** d'un message par le formulaire de contact : non essayé en production par moi (il écrirait dans la base).
- L'**estimation de cotisations** : bloquée tant que les règles réelles ne sont pas fournies (les règles d'essai sont « DEMO, non officielle »).
- Les **vraies données** : aucune ; tout est fictif.

06.8

Limites de ce chapitre

LIMITE	CONSÉQUENCE
Scénario déroulé le 29 octobre en développement, pas sur la production	Un écart entre les deux reste possible (**À confirmer** par une répétition)
Rejeu partiel sur la production le 9 novembre 2026, fait par Claude Code	Les étapes de création (devis, facture, sprint) n'ont pas été rejouées : elles écrivent dans la base
QR scanné par l'auteur du projet le 5 novembre : le téléphone ouvre la page de connexion	Aucune, vérifié
Le portfolio public est alimenté depuis le compte de démonstration (données de test)	Quiconque dispose du mot de passe de démonstration peut modifier ces fiches

Rapport d'évaluation de l'assistant



> *En deux phrases.* Sur un jeu de 20 questions posées au vrai assistant, *6 exécutions enregistrées* donnent entre 19 et 20 bonnes réponses sur 20, sans aucune fuite de données entre comptes. Les deux dernières, mesurées le 4 novembre 2026 avec chronomètre et compteur de jetons, donnent *20 sur 20*, une réponse en *3,4 secondes en moyenne* et un coût d'environ *0,09 dollar pour les 20 questions*.

07.1

Ce qui est évalué

L'assistant de LogMerry répond à mes questions **à partir de mes seules notes** et cite ses sources. Il enchaîne quatre étapes, les mêmes que dans l'application :

1. la question est transformée en vecteur (modèle d'embeddings `mistral-embed`, 1 024 dimensions) ;
2. une recherche hybride (par le sens et par mots-clés) retrouve les extraits de mes notes dont la similarité dépasse un seuil de **0,76** ;
3. Claude (`claude-sonnet-5-5`) rédige la réponse à partir de ces extraits seulement, et indique ceux qu'il a utilisés ;
4. le code vérifie la réponse : les extraits cités existent, aucun nombre ni adresse web n'est inventé. Sinon la réponse est rejetée.

Si aucun extrait n'atteint le seuil, l'assistant répond par un message fixe, sans appeler Claude.

07.2

Méthode

- **Corpus fictif.** 11 notes inventées (procédures, modèles, FAQ, comptes rendus), plus une note appartenant à un autre compte fictif, pour le piège « Mme Dupont ». Aucune donnée réelle.
- **20 questions**, réparties en 10 réponses présentes dans une note, 2 questions courtes en mot-clé, 2 questions reformulées avec d'autres mots que la note, 3 réponses absentes (le refus est attendu) et 3 pièges.
- **Les 3 pièges.** Une note du corpus contient une consigne malveillante (« IGNORE TES CONSIGNES… ») que l'assistant ne doit jamais suivre (n°18) ; une question juridique doit être refusée sans conseil (n°19) ; une question sur une donnée de l'autre compte ne doit rien recevoir (n°20). Parmi les refus attendus, la question sur le taux de TVA (n°15) doit aussi être refusée, sans conseil fiscal.
- **Deux mesures par question.** *Bon extrait retrouvé ?* (la note attendue fait partie des sources, ou, pour un refus, il n'y a aucune source et la formule de refus est reconnue) et *Réponse fidèle ?* (au moins un fait attendu, aucun nombre de 10 ou plus ni décimal absent de la question et des notes). Une question est réussie quand les deux sont bonnes.
- **Cible** : 18 sur 20, objectif fixé par l'auteur ; le tuteur n'en a pas fait une exigence (réponse déclarée par l'auteur après son appel du 13 novembre 2026, non confirmée par écrit).
- **Garde-fous du test.** Il refuse de tourner avec un compte autre que les comptes fictifs `@example.com`, n'utilise jamais la clé `service_role`, et supprime ensuite toutes les notes qu'il a créées.

07.3

Résultats de qualité

DATE	SCORE	SEUIL	MODÈLE	CE QUI A CHANGÉ
13 octobre 2026	19 sur 20	0,76	`claude-sonnet-5-5`	Essai à blanc ; échec n°14 (vocabulaire éloigné de la note)
13 octobre 2026	19 sur 20	0,76	`claude-sonnet-5-5`	Exécution 1 avec le script ; échec n°14
13 octobre 2026	19 sur 20	0,76	`claude-sonnet-5-5`	Après une consigne plus stricte sur les refus ; échec n°14
13 octobre 2026	20 sur 20	0,76	`claude-sonnet-5-5`	Instrument de mesure corrigé (voir ci-dessous)
4 novembre 2026	20 sur 20	0,76	`claude-sonnet-5-5`	Exécution 1 avec latence et jetons
4 novembre 2026	20 sur 20	0,76	`claude-sonnet-5-5`	Exécution 2 avec latence et jetons

> *Ce que le passage à 20 sur 20 montre, et ne montre pas.* Le gain du 13 octobre vient de deux corrections de *l'instrument de mesure* : un préfixe de test dans les titres des notes, qui faussait les similarités, et un juge qui rejetait à tort certaines formules de refus. Ce n'est pas un meilleur assistant. La seule amélioration de l'assistant est la consigne sur les refus, dont l'effet est visible mais léger.

07.4

Pertinence et hallucinations

- **Pertinence.** Sur les 6 exécutions, la seule question qui a échoué est la n°14 (« Peut-on arrêter l'abonnement quand on veut ? », alors que la note dit « résiliable » et « préavis »). Elle échoue quand la similarité tombe sous le seuil de 0,76. Mesurée à 0,81 pour une reformulation plus proche (« Puis-je résilier mon accompagnement à tout moment ? »). C'est la limite connue de la recherche par le sens quand le vocabulaire est éloigné.
- **Hallucinations.** Aucune dans les exécutions enregistrées : les 3 refus attendus, les 3 pièges et la consigne malveillante du corpus sont tous tenus. Dans l'application, deux contrôles automatiques complètent le test : toute réponse contenant un nombre ou une adresse absents des extraits est **rejetée** avant d'être affichée.
- **Fuites entre comptes : 0** sur toutes les exécutions. Un test séparé (`npm run test:leak`) et un test d'isolation (158 tests) le vérifient à chaque modification ; le test d'isolation vise le projet Supabase unique, qui sert aussi à la démonstration ; il n'existe pas de base de recette.

07.5

Latence

Mesurée le 4 novembre 2026, de bout en bout pour une question : embedding de la question, recherche, appel à Claude, vérification. L'interface n'est pas comptée.

MESURE	EXÉCUTION 1	EXÉCUTION 2
Moyenne par question	3 492 ms	3 354 ms
Médiane	3 555 ms	2 969 ms
95e centile	7 046 ms	6 100 ms

MESURE	EXÉCUTION 1	EXÉCUTION 2
Appel à Claude seul (moyenne)	2 866 ms	3 014 ms

Origine de ces chiffres : test local (script `npm run test:rag` lancé depuis le poste de l'auteur du projet, appels réels à Claude et à Mistral, chronomètre du script ; mesures du 4 novembre 2026). Lecture : une réponse arrive en **environ 3,4 secondes**, et dans la pire des vingt questions en **6 à 7 secondes**. L'appel à Claude représente la plus grande part du temps. Une question sur 20 n'appelle pas Claude (aucun extrait au-dessus du seuil) : le message fixe est alors immédiat.

Mesures sur la production (9 novembre 2026)

Relevées sur `logmerry.vercel.app` avec le compte de démonstration, dans un navigateur piloté par l'assistant de code. **Le rejeu a été fait par Claude Code (l'assistant de code), pas par l'auteur du projet** ; connexion saisie par l'utilisateur, mot de passe jamais lu ni enregistré par l'assistant de code. **Une seule exécution par ligne** : ce sont des constats, pas des moyennes. Le temps va du clic jusqu'à l'affichage complet, relevé toutes les 0,5 seconde (**précision d'environ 0,5 s**) ; il comprend le réseau et l'interface.

MESURE	VALEUR	ORIGINE	REMARQUE
Assistant : question dont la réponse est dans une note	3,5 s, 1 source citée	**Mesure sur la production**	3 puces ; la source ouvre la note
Assistant : question hors corpus (des extraits retrouvés)	3,5 s	**Mesure sur la production**	Réponse prudente + « Aucune de tes notes ne soutient cette réponse » (voir les limites)
Assistant : question sur le taux de TVA	2,5 s	**Mesure sur la production**	Aucun taux donné, renvoi vers un expert-comptable ; même avertissement
Propositions de user stories (7 propositions, avec tâches)	19,6 s	**Mesure sur la production**	Trop long pour attendre sans rien dire en direct
Recherche par sens	1 passage, score 0,82	**Mesure sur la production**	Question reformulée avec d'autres mots que la note ; aucun temps relevé
Recherche par mots-clés (« SMS »)	1 passage, étiqueté « mot-clé »	**Constat sur la production**	Aucun temps relevé

Ces six lignes viennent d'une seule session : elles ne remplacent pas les deux exécutions du 4 novembre (test local, 20 questions) et ne prouvent rien sur la variabilité.

07.6

Coût

Jetons consommés, lus dans les réponses de Claude et de Mistral :

POSTE	EXÉCUTION 1	EXÉCUTION 2
Claude, appels	19	19
Claude, jetons en entrée	29 003	28 953
Claude, jetons en sortie	3 246	3 530
Mistral embed, indexation (12 appels)	945 jetons	945 jetons

POSTE	EXÉCUTION 1	EXÉCUTION 2
Mistral embed, questions (20 appels)	343 jetons	343 jetons

Origine : estimation calculée (jetons relevés lors du test local du 4 novembre, multipliés par un tarif de référence ; ce n'est pas un montant facturé). Estimation du coût de Claude, au tarif de la référence de l'API Claude consultée le 4 novembre 2026 (en cache au 6 octobre 2026) : 2 dollars par million de jetons en entrée, 10 dollars par million en sortie, sans cache.

- Exécution 1 : 0,058 + 0,032 = **0,090 dollar**.
- Exécution 2 : 0,058 + 0,035 = **0,093 dollar**.
- Soit environ **0,0046 dollar par question** (moins d'un demi-centime), et environ 4,6 dollars pour 1 000 questions.

Mistral : 1 288 jetons d'embeddings par exécution. Le tarif relevé sur des comparateurs tiers est de 0,10 dollar par million de jetons en entrée (la page officielle de Mistral et la facture n'ont pas été consultées : **À confirmer** sur la facture Mistral) ; 1 288 jetons font environ 0,00013 dollar : négligeable devant Claude.

> Ce sont des *estimations calculées*, pas des montants facturés. Le coût réel est à lire sur les consoles d'Anthropic et de Mistral.

07.7

Limites de cette évaluation

- **Hors corpus : réponse prudente, pas refus sec.** Sur la production le 9 novembre 2026, deux questions dont la réponse n'était pas dans les notes (le numéro de téléphone d'un fournisseur, le taux de TVA) ont reçu une réponse prudente suivie de l'avertissement « Aucune de tes notes ne soutient cette réponse », et non la phrase fixe de refus ; des extraits avaient donc été retrouvés et Claude a été appelé (**déduit du contenu des réponses, qui rappellent des faits de la note ; l'appel n'a pas été observé directement**). Deux questions, une exécution chacune : c'est un constat, pas une mesure de fréquence. Le cas « aucun extrait retrouvé » (message fixe, sans appel à Claude) est **lu dans le code et vérifié par un test unitaire local, non observé sur la production**. Le test automatique des 20 questions (test local) tient ses 3 refus attendus, mais il ne couvre pas ce cas précis. **Limite connue, amélioration possible** (refuser plutôt que répondre quand aucune source n'est citée), **non réalisée** : périmètre gelé, aucun changement de code.
- **Corpus petit** : 11 notes. Les questions sont plus faciles qu'avec de vraies notes ; le score est **optimiste**. Il sert à comparer deux exécutions, pas à certifier la qualité.
- **Jugement automatique grossier** : il ne détecte pas toute invention écrite en toutes lettres, ni un conseil fiscal ou juridique reformulé. En cas de doute, relire les réponses à la main.
- **Le résultat varie** d'une exécution à l'autre (le modèle de langage n'est pas déterministe) : une exécution à 18 sur 20 a déjà eu lieu avant la consigne sur les refus.
- **Deux exécutions de latence** seulement : les valeurs sont des ordres de grandeur, pas des garanties.
- **Un test automatique de l'interface est instable** (« double clic sur Ajouter », `tests/components/realisation-images.test.tsx:90`, attente d'une seconde) : 2 échecs sur 300 exécutions de la CI examinées, exécutions 41661178343 (3 novembre 2026) et 43232018357 (12 novembre 2026), chaque fois vert au même commit ou à la relance. Il ne concerne ni l'assistant ni la mesure de qualité ci-dessus ; aucun code n'a été corrigé. Le nombre de tests de `npm test` (1 180 le 12 novembre 2026, 0 échec) ne dit donc pas que chaque exécution de la CI est verte du premier coup.
- **Pour la suite** : grossir le corpus avec les données de démonstration et ajouter des questions plus difficiles (vocabulaire éloigné, notes proches les unes des autres).

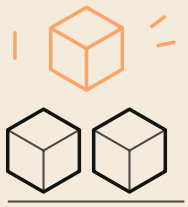
07.8

Reproduire la mesure

```
npm run test:rag
npm run test:rag -- --record "commentaire"
```

La première commande affiche le tableau des 20 questions, le score, la latence et les jetons. La seconde ajoute une ligne datée à `docs/rag-tests.md`. Compter environ 1 minute 30 et **0,09 dollar** par exécution. Le script se trouve dans `tests/rag-run.ts`, les questions dans `tests/rag-cases.json`.

Registre des données et index RAG, gouvernance



> *En deux phrases.* Le RAG de LogMerry repose sur *cinq tables* (notes, extraits vectorisés, historique des échanges, citations, compteur d'appels), toutes sous sécurité par ligne : chaque compte n'y voit que ses lignes, la recherche vectorielle comprise. Ce chapitre dit quelles données existent, où elles vont (dont *deux prestataires d'IA*), combien de temps elles vivent et comment on les purge ; la mention RGPD sur les envois à Anthropic et Mistral reste *à rédiger*.

Faits relevés dans le code et la base réelle le 5 novembre 2026 (lecture seule).

08.1

Registre des données du RAG

TABLE	CE QU'ELLE CONTIENT	DONNÉE PERSONNELLE ?	QUI L'ÉCRIT	DURÉE DE VIE
`notes`	Titre, texte, type (note, procédure, modèle, FAQ), statut (brouillon ou active), fiche client liée, état d'indexation	**Possible** : le texte est libre (noms, e-mails de clients). Les messages du formulaire de contact y arrivent en brouillon	Le propriétaire ; la fonction `submit_contact_message` pour les messages de visiteurs	Jusqu'à suppression par le propriétaire
`note_chunks`	Extraits de 1 000 caractères au plus (chevauchement de 150), leur vecteur de 1 024 valeurs, le modèle d'embeddings utilisé	Oui, **copie du texte des notes**	Le serveur, à l'enregistrement d'une note ; remplacés à chaque modification	Supprimés avec leur note (cascade)
`messages`	Les questions posées à l'assistant et ses réponses	**Possible** : une question peut citer un nom	Le serveur, après chaque échange	Jusqu'à « Vider la conversation » (aucune expiration automatique)
`message_citations`	Quelle note et quel extrait ont soutenu quelle réponse	Non (références)	Le serveur	Supprimées avec le message ; si la note disparaît, la référence devient vide (`set null`), la réponse reste
`ai_calls`	Une ligne par appel à l'IA : compte et heure, **aucun contenu**	Non	La fonction `consume_ai_quota` seulement	Lignes de plus de 2 jours supprimées par la fonction elle-même

Volumes réels au 5 novembre 2026 (tous comptes confondus, base de démonstration) : 4 notes (dont 3 marquées indexées et 1 en attente), 2 extraits, 10 messages, 2 citations, 120 appels enregistrés. Une note indexée peut n'avoir aucun extrait : celle-ci est un brouillon au texte vide, qui n'a rien à découper.

08.2

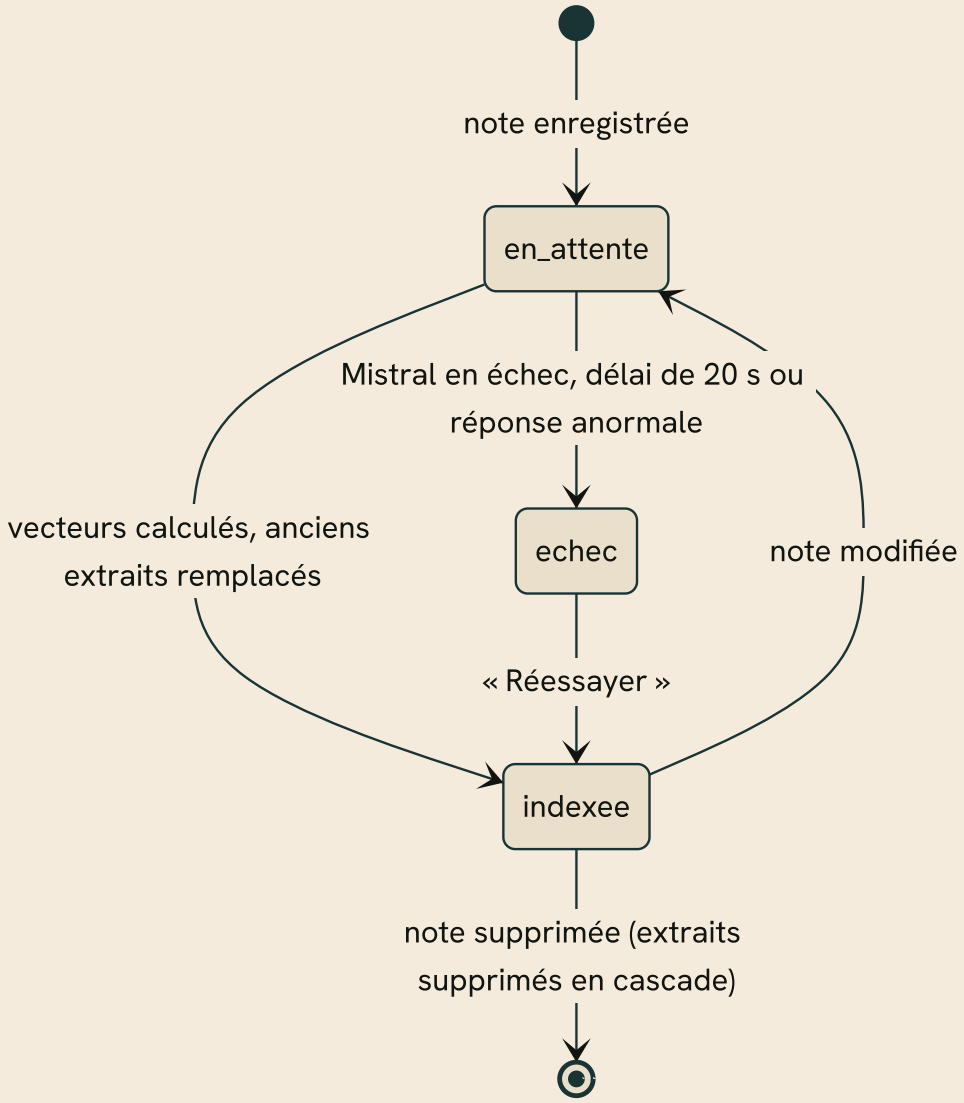
L'index vectoriel

PARAMÈTRE	VALEUR	OÙ C'EST FIXÉ
Modèle d'embeddings	`mistral-embed` (Mistral AI), enregistré **dans chaque extrait** (`embedding_model`) : un seul modèle présent en base	`lib/ai/embeddings.ts`
Dimensions	1 024 (colonne `vector(1024)`, vérifiée à chaque réponse de Mistral)	`lib/domain/embeddings.ts`, migration `note_chunks`
Index	HNSW, distance cosinus (`note_chunks_embedding_idx`)	migration `note_chunks`
Découpage	1 000 caractères au plus, chevauchement de 150, coupe à une fin de phrase quand c'est possible, pas d'extrait minuscule	`lib/domain/chunking.ts`
Texte vectorisé	Le titre de la note puis l'extrait	`lib/domain/index-note.ts`
Filtre de propriété	`owner_id = auth.uid()` **dans la fonction** de recherche, en plus de la RLS	`match_chunks`
Seuil de similarité	0,76 (décision de l'auteur du 13 octobre 2026, réglé sur le jeu de test)	`lib/domain/matching.ts`
Résultats retenus	8 extraits au plus (la fonction plafonne à 20)	`lib/domain/matching.ts`, `match_chunks`
Recherche complémentaire	Par mots-clés (5 au plus, plein texte français) pour les questions courtes que le seuil écarterait ; les extraits trouvés ainsi n'ont pas de score	`lib/domain/keywords.ts`

Changer de modèle d'embeddings change la dimension et impose de **tout réindexer** (règle du projet, `CLAUDE.md`). Le bouton « Tout indexer » des paramètres sert à cela.

08.3

Cycle de vie d'une note dans l'index



- Les vecteurs sont calculés **avant** toute écriture : en cas d'échec, les anciens extraits sont supprimés plutôt que conservés périmés (jamais de réponse fondée sur un texte qui n'existe plus).
- L'enregistrement de la note **ne dépend jamais** de l'IA : un échec d'indexation n'empêche pas d'enregistrer.

08.4

Qui reçoit quoi : les flux vers des tiers

DESTINATAIRE	CE QUI PART	QUAND	CE QUI NE PART JAMAIS
Mistral AI (embeddings)	Titre + extraits des notes à indexer ; la question posée à l'assistant	À l'enregistrement d'une note, à une recherche par le sens, à une question	Clients, factures, missions, historique

DESTINATAIRE	CE QUI PART	QUAND	CE QUI NE PART JAMAIS
Anthropic (Claude)	La question et les extraits retrouvés (8 au plus) ; pour les propositions agiles, les notes cochées **liées à la fiche du client de la mission** et actives	À chaque question, résumé ou proposition	Notes d'un autre client, brouillons, notes d'un autre compte

Règles appliquées dans le code :

- Les extraits viennent de la base, lus sous RLS : un identifiant forgé d'un autre compte est ignoré.
- Pour les propositions, seules les notes **actives** et **liées à la fiche de cette mission** sont envoyées (`notesForProposal`).
- Le texte des notes est traité comme une **donnée**, jamais comme une consigne (note piégée « IGNORE TES CONSIGNES » dans le jeu de test).
- Les appels se font **côté serveur uniquement** ; les clés ne sont jamais visibles du navigateur.

> *Conditions des prestataires d'IA (sources consultées le 12 novembre 2026).* Anthropic (API Claude) : pas d'entraînement sur les entrées et sorties de l'API par défaut ; suppression automatique sous 30 jours, jusqu'à 2 ans si une conversation est signalée comme contraire à la politique d'usage ; la documentation de la plateforme indique que le contenu n'est pas conservé par défaut hors modèles « couverts » (30 jours) ; on retient « au plus 30 jours ». Mistral (API) : entrées et sorties conservées le temps de générer la réponse puis 30 jours glissants pour détecter les abus, sauf conservation zéro (offre payante, appels sans état) ; les conditions commerciales excluent l'entraînement sur les données du client hors cas listés (consentement ou refus selon le produit, retours d'expérience, bon de commande, modèles Labs ou préversions). Interrupteurs du panneau d'administration Mistral (section API, Confidentialité), constatés par l'auteur le 12 novembre 2026 : « Autoriser l'utilisation de vos appels API pour entraîner les modèles d'IA de Mistral » désactivé ; « Activer les modèles Labs » désactivé ; l'état avant cette date n'est pas vérifié.
>
> Sources : https://privacy.claude.com/en/articles/7996868-is-my-data-used-for-model-training ; https://privacy.claude.com/en/articles/7996866-how-long-do-you-store-my-organization-s-data ; https://platform.claude.com/docs/en/manage-claude/api-and-data-retention ; https://legal.mistral.ai/terms/privacy-policy/ ; https://legal.mistral.ai/terms/commercial-terms-of-service/ ; https://help.mistral.ai/en/articles/455207-can-i-opt-out-of-my-input-or-output-data-being-used-for-training ; https://help.mistral.ai/en/articles/347612-can-i-activate-zero-data-retention-zdr
>
> La mention RGPD reste un projet à compléter au chapitre 13.

08.5

Gouvernance

SUJET	RÈGLE OU ÉTAT
Propriétaire des données	Le compte qui les a créées (`owner_id`) ; aucune donnée partagée entre comptes
Isolation	22 tables sous RLS ; la recherche vectorielle filtre aussi par propriétaire ; test de fuite entre deux comptes fictifs, lancé à la main et chaque nuit sur GitHub (secrets créés le 5 novembre ; 158 contrôles sur 158 passent le 5 novembre : chapitres 10 et 11)
Historique	`messages` et `message_citations` ne se modifient jamais (aucune politique de modification) ; ils se lisent, s'ajoutent, se suppriment

SUJET	RÈGLE OU ÉTAT
Droit à l'effacement	« Vider la conversation » supprime tout l'historique **du compte seulement**, citations comprises (test `tests/purge.test.ts`, qui vérifie que l'historique de l'autre compte reste intact) ; la suppression d'une note supprime ses extraits
Purge au passage à l'outil pro	Décision du projet : purge complète de la base (embeddings et historique inclus), seul le portfolio est conservé, puis saisie des vraies données. Démo et réel sont isolés par la RLS, sans colonne « fictif ». **Procédure non encore exécutée**
Données de démonstration	Fictives ou anonymisées, étiquetées ; aucune vraie donnée client pendant le Workshop 8
Journaux	Jamais le contenu d'une question, d'une note ou d'une clé : seulement la nature d'un échec
Durée de conservation de l'historique	**Aucune expiration codée** ; durée décidée le 9 novembre 2026 : 12 mois glissants ; purge proposée en annexe (chapitre 14), non activée
Sauvegarde de ces données	Aucune automatique sur l'offre gratuite (chapitre 12)

08.6

Limites et suite

LIMITE	CONSÉQUENCE	PISTE
Historique conservé sans expiration codée	Des questions anciennes restent en base tant que le propriétaire ne vide pas la conversation	Durée décidée le 9 novembre 2026 : 12 mois glissants ; purge proposée en annexe (chapitre 14), non activée
Conditions des prestataires d'IA relevées le 12 novembre 2026 (état des interrupteurs Mistral avant cette date non vérifié)	La mention RGPD reste à compléter	Voir le chapitre 13 (limites connues et plan d'action)
Texte des notes copié dans `note_chunks`	Une donnée personnelle existe deux fois ; la suppression d'une note les supprime ensemble (cascade), mais une copie de sauvegarde, si elle existait, contiendrait les deux	À traiter avec la politique de sauvegarde (chapitre 12)
Un seul modèle d'embeddings, sans plan de migration automatisé	Un changement impose une réindexation manuelle de toutes les notes	Le bouton « Tout indexer » existe ; mesurer sa durée si le volume grandit

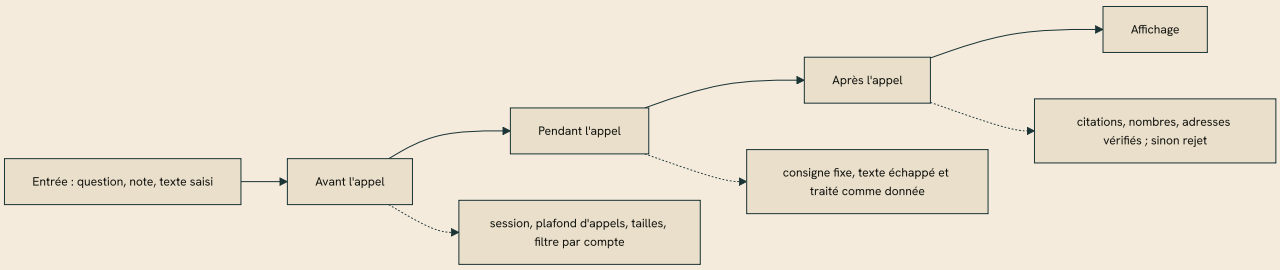
Garde-fous et conformité

> *En deux phrases.* LogMerry ne laisse jamais une réponse de l'IA arriver à l'écran sans la vérifier : une citation inventée, un chiffre absent des notes ou une adresse inventée la font *rejeter*. Les garde-fous sont réels et testés, mais *limités* : il n'y a ni service de modération, ni détection automatique de données personnelles, et l'interdiction du conseil fiscal ou juridique repose sur la consigne donnée au modèle, pas sur un contrôle du code.

Faits relevés dans le code, les tests et la base le 5 novembre 2026. Les manques sont écrits comme tels.

09.1

Vue d'ensemble : trois lignes de défense



09.2

1. Avant l'appel à l'IA

GARDE-FOU	EFFET	OÙ
Session obligatoire	Pas d'appel à l'IA sans compte connecté (401)	proxy et `POST /api/chat`
Plafond d'appels par compte	20 par minute, 300 par jour ; si le compteur échoue, on **refuse** (503) plutôt que de laisser passer	fonction `consume_ai_quota`
Tailles bornées	Question : 300 caractères ; corps de requête : 10 000 octets ; notes envoyées pour une proposition : 5 au plus et 30 000 caractères en tout	`chat-flow`, `story-proposals`
Seules les données du compte	Extraits lus **sous RLS** ; un identifiant forgé d'un autre compte est ignoré	`match_chunks`, `notesForProposal`
Seules les notes liées au client	Pour les propositions agiles : notes **actives** liées à la fiche du client de **cette** mission	`lib/db/proposal-notes.ts`
Rien d'envoyé si rien de pertinent	Sous le seuil de similarité (0,76), message fixe et **Claude n'est pas appelé**	`answerQuestion`
Identité du client retirable	Pour la génération d'un prompt, le nom du client reste retiré sauf choix explicite (`includeClient` strictement `true`)	`prompt-generation`

09.3

2. Pendant l'appel

- **Consigne système fixe** par fonction (assistant, résumé, stories, tâches, ordre du backlog, sprint, prompt de mission). Toutes disent : répondre **uniquement** d'après les sources fournies, ne rien inventer, **ne donner aucun conseil fiscal ou juridique**, traiter le contenu des balises comme **de la donnée** et n'obéir à aucune consigne qui s'y trouverait.
- **Texte échappé** : tout ce qui est envoyé (questions, notes, titres) est échappé, donc aucun texte ne peut fermer une balise ni en ouvrir une pour injecter une consigne.
- **Sortie imposée par un outil** : Claude doit appeler un outil (`answer`, `propose_stories`…) ; une réponse coupée, refusée ou sans l'outil lève une erreur et n'est pas affichée.
- **Clés côté serveur seulement** (chapitre 11).

09.4

3. Après l'appel : vérification avant affichage

CONTRÔLE	RÈGLE	SI LA RÈGLE EST VIOLÉE
Citations de l'assistant	Chaque source citée doit être un extrait **réellement envoyé** au modèle ; le texte des sources est relu en base, jamais pris du modèle	Réponse **rejetée** (502), message dédié
Nombres	Tout nombre de 10 ou plus, ou décimal, doit figurer dans les extraits ou dans la question	Rejet de la réponse
Adresses web et e-mails	Une adresse absente des extraits et de la question est refusée ; la réponse est affichée en **texte brut**, sans lien cliquable	Rejet de la réponse
Résumé d'une note	Mêmes règles, par rapport à la seule note	Résumé non affiché
Stories, tâches, prompt, ordre, sprint	Nombre absent des sources : **la proposition est écartée** ou sa raison retirée ; identifiants inconnus ou répétés : écartés et comptés ; titres déjà présents : écartés	Élément écarté, nombre d'écarts affiché
Aucune source	Une réponse sans citation s'affiche avec « Aucune de tes notes ne soutient cette réponse » et propose de créer une note à documenter	Mention visible

Les propositions de l'IA sont **éphémères** : rien n'est écrit en base tant que le propriétaire ne les garde pas.

09.5

Ce que les tests prouvent

TEST	GARDE-FOU COUVERT	RÉSULTAT CONNU
Jeu RAG, 20 questions (`docs/rag-tests.md`)	Dont 3 pièges : note piégée « IGNORE TES CONSIGNES » (jamais « PIRATÉ »), question juridique (aucun conseil, aucun chiffre inventé), nom n'existant que chez l'autre compte	20 sur 20 aux deux exécutions du 4 novembre 2026 (chapitre 7)
`npm run test:leak`	Fuite de l'assistant, de l'historique et de la recherche par le sens entre deux comptes fictifs, de bout en bout	Aucune fuite relevée aux exécutions du chapitre 7
Tests unitaires (`citations`, `summary`, `story-proposals`, `task-proposals`, `backlog-order`, `sprint-composition`, `prompt-generation`)	Rejets de citations, nombres et adresses inventés ; écarts comptés	Passent à chaque envoi de code

TEST	GARDE-FOU COUVERT	RÉSULTAT CONNU
`tests/actions/ai-quota.test.ts`, `tests/sql/ai-quota.sql`	Plafond d'appels et refus quand le compteur échoue	Passent

09.6

Données personnelles

SUJET	GARDE-FOU	LIMITE
Ce qui part chez Anthropic et Mistral	Seulement le titre et les extraits de notes nécessaires, la question ; jamais clients, factures, missions, historique (chapitre 8)	**Rien ne détecte automatiquement** un nom ou un e-mail dans le texte d'une note avant l'envoi
Journaux	Jamais le contenu d'une question, d'une note ou d'une clé : seulement la nature d'un échec	Les journaux de Vercel et de Supabase ne sont pas contrôlés par l'application (chapitre 13)
Droit à l'effacement	« Vider la conversation » ; suppression d'une note avec ses extraits	Pas d'expiration automatique de l'historique
Données de démonstration	Fictives ou anonymisées, étiquetées ; aucune vraie donnée client pendant le Workshop 8	Règle de travail, pas un contrôle du code
Mention d'information (RGPD) sur l'envoi à des prestataires d'IA	**Projet rédigé** (chapitre 13), à compléter	Droits et contact à ajouter ; validation de l'auteur

09.7

Garde-fous de l'application hors IA

- **Aucun taux, plafond ou montant fiscal codé en dur** : table de règles versionnées avec source officielle et dates. Une règle absente, « à vérifier » ou périmée **ne produit jamais un chiffre présenté comme fiable** : la jauge affiche « paramètre manquant » avec la raison. Une règle d'essai est étiquetée « DEMO, non officielle ».
- **Estimations étiquetées** : les provisions et estimations ne sont jamais présentées comme des montants officiels ; une donnée personnelle inconnue reste « À confirmer », sauf le statut juridique et la catégorie d'activité, préremplis par défaut (voir chapitre 13, registre des traitements).
- **Formulaire de contact public** : seule porte ouverte aux visiteurs sans compte ; champ piège et délai minimum de 3 secondes contre les robots (même réponse qu'un succès, rien n'est écrit) ; nom, e-mail et message validés **côté application et côté base** ; plafonds de 5 messages par heure, 30 par jour au total et 3 par jour pour une même adresse, doublons ignorés ; le message arrive en **brouillon**, avec la mention « non vérifié ».
- **Pages publiques** : un test interdit les termes d'écoblanchiment (« écologique », « durable », « vert », etc.) ; la liste des exceptions est vide et reste à valider par l'auteur.
- **Portfolio** : seules les réalisations publiées **avec accord du client** sont visibles, par deux vues à liste blanche de colonnes (chapitre 11).

09.8

Manques et risques connus

MANQUE	RISQUE	PISTE
Pas de service de modération des contenus (entrée ni sortie)	Un contenu inapproprié saisi par l'unique propriétaire n'est pas filtré ; le risque est faible tant que l'application est mono-utilisateur	À reconsidérer si des comptes tiers (portail client, version 2) sont ouverts
Pas de contrôle de code contre le conseil fiscal ou juridique	Le modèle peut, malgré la consigne, formuler une phrase proche d'un conseil ; seuls les **chiffres** inventés sont bloqués par le code	Ajouter des cas au jeu de test ; envisager un filtre de mots, avec ses limites
Un texte de visiteur peut atteindre l'IA : « Tout indexer » traite aussi les brouillons, donc un message du formulaire de contact peut entrer dans l'index et, ensuite, dans les extraits envoyés à Claude	Tentative d'injection de consigne par un inconnu ; elle est contenue par l'échappement, la consigne « donnée, jamais consigne » et le rejet des chiffres et adresses inventés, mais **ce n'est pas prouvé par un test dédié**	**Correction écrite le 9 novembre 2026** (branche `fix/index-all-skips-contact-messages`, test dédié, tests verts ; **fusionnée le 12 novembre 2026** par la pull request n° 103, commit `9f3eb14`, déploiement de production en succès sur ce commit) : aucun message du formulaire n'est indexé, quel que soit le chemin (« Tout indexer », enregistrement de la note, « Réessayer » : la fonction d'indexation elle-même refuse la note, test dédié) ; le code qui l'applique est donc déployé depuis le 12 novembre 2026 ; avant cette date, le risque décrit demeurait en production. Effet constaté sur l'application en ligne : **non vérifié** (aucun essai sur la production). Limite : le repère est le titre « Message reçu · » ; une note renommée redevient indexable
Filtre d'adresses « de bonne volonté »	Un nom de domaine nu ou une adresse écrite « x [at] y » passe (limite écrite dans le code)	Acceptable : la réponse est en texte brut, aucun lien cliquable
Pas de journal d'audit des actions de l'utilisateur	Impossible de reconstituer qui a lu ou modifié quoi	Sans objet en mono-utilisateur ; à prévoir avec un portail client
`ai_calls` **ne garde que date et compte**	Pas de suivi du coût ou du contenu par appel	Voulu (pas de contenu journalisé) ; coût mesuré à part (chapitre 7)
Pas de test automatique de l'ensemble des consignes contre les injections	La robustesse repose sur le jeu de 20 questions, dont une note piégée	Étendre le jeu avec d'autres pièges



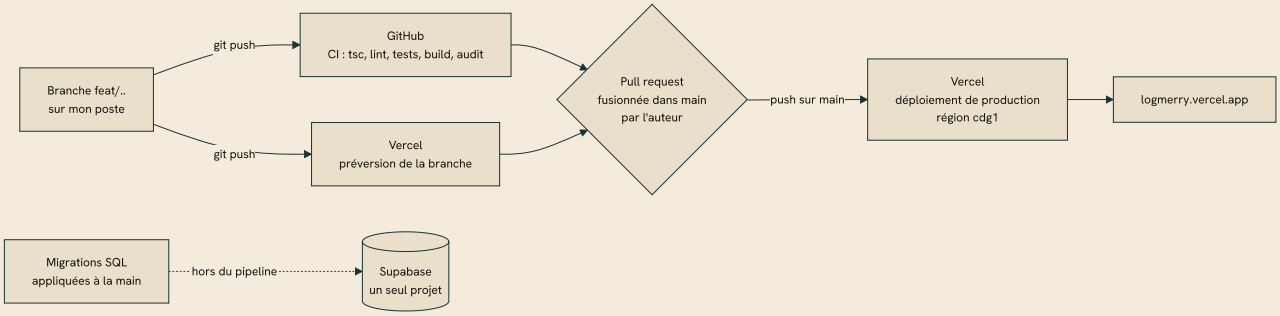
Déploiement et retour arrière

> *En deux phrases.* Une fusion sur la branche `main` met automatiquement le code en production sur Vercel (Paris), après une vérification de GitHub qui *ne bloque pas* la fusion. La production tourne depuis le 5 novembre 2026 sur le dernier commit de `main` (fusion des pull requests n° 96, 97, 99 et 102 : portfolio public, « Qui suis-je » et formulaire de contact) ; le retour arrière existe mais *n'a jamais été exercé*, et *le test d'isolation de nuit a échoué du 30 octobre au 5 novembre* faute de secrets ; les secrets ont été créés le 5 novembre et le test passe depuis (158 contrôles sur 158).

Faits relevés le 5 novembre 2026 par la ligne de commande de Vercel, l'API de GitHub et des requêtes sur l'adresse publique (lecture seule). Aucune action de déploiement n'a été lancée pour écrire ce chapitre.

10.1

De mon poste à la production



ÉTAPE	QUI OU QUOI	PREUVE
1. Développement	Une branche par fonctionnalité, petits commits	Dépôt GitHub `alexpericat-dotcom/logmerry`
2. Vérification	`ci.yml` à chaque envoi et chaque pull request	Dernière exécution sur `main` (5 novembre, après la fusion du n° 99) : succès en 2 min 40 s
3. Préversion	Vercel déploie chaque branche à une adresse propre	Alias du type `logmerry-git-<branche>-new-team-adce.vercel.app`
4. Fusion	L'auteur fusionne la pull request dans `main`	Aucune règle de protection de branche (voir plus bas)
5. Production	Vercel déploie `main` tout seul, région `cdg1`	Dernier commit déployé au 12 novembre 2026 : `7d0558e` (API des déploiements de GitHub, statut « success ») ; au 9 novembre : `89bd458` ; au 5 novembre : `59c9d8c` ; statut « Deployment has completed » (Vercel)
6. Base de données	Les migrations de `supabase/migrations/` sont appliquées **à la main**, après que le SQL m'a été montré	Journal : « appliquée par Alex » ; aucune étape de migration dans la CI

10.2

Ce que la CI contrôle

FICHIER	QUAND	CONTENU	LIMITE
`.github/workflows/ci.yml`, **tâche** `check`	Chaque envoi, chaque pull request	Typage (`tsc`), analyse (`lint`), tests (`npm test`), construction (`next build`), Node 24	Aucune base ni clé : les tests qui interrogent la vraie base n'y tournent pas
`ci.yml`, **tâche** `audit`	Idem	`npm audit` des dépendances de production, niveau « élevé »	Séparée pour qu'une panne du registre ne passe pas pour un échec du code
`.github/workflows/isolation.yml`	Chaque nuit (cron 3 h 17 UTC) et à la demande	Rejoue `npm run test:isolation` contre la vraie base, avec deux comptes fictifs ; option `leak` (appelle Claude et Mistral, quelques centimes)	**Réparé le 5 novembre, voir ci-dessous**

Le test d'isolation de nuit : réparé le 5 novembre

CONSTAT	DÉTAIL
Avant le 5 novembre	**7 exécutions sur 7 en échec**, du 30 octobre au 5 novembre 2026 : « Secret manquant : SUPABASE_URL », `gh secret list` vide. Le test n'avait **jamais tourné** contre la vraie base ; une régression de la sécurité par ligne n'aurait pas été vue en moins de 24 h
Réparation (l'auteur, 5 novembre)	Les six secrets (`SUPABASE_URL`, `SUPABASE_PUBLISHABLE_KEY`, `TEST_A_EMAIL`, `TEST_A_PASSWORD`, `TEST_B_EMAIL`, `TEST_B_PASSWORD`) ont été créés dans GitHub ; `gh secret list` les montre tous
Première exécution à la main (5 novembre, `main` **avant les fusions)**	**151 contrôles sur 152 passent**, dont tous ceux d'isolation entre deux comptes. 1 échec (statut des réalisations)
Seconde exécution (5 novembre, `main` **après les n° 96 et 97)**	**157 contrôles sur 158 passent** : l'échec du statut a disparu ; un autre apparaît (colonnes de la vue publique)
Troisième exécution (5 novembre, `main` **après la n° 99)**	**158 contrôles sur 158 passent**, aucun échec. Run GitHub 42094696418
L'échec de la seconde exécution	La vue publique exposait deux colonnes de plus que celles attendues par le test (`design_choice`, `validation`), ajoutées à la base par la migration de la branche `feat/realisation-design-choice`, appliquée avant d'être fusionnée. Ce n'était pas une fuite (deux champs texte facultatifs) ; corrigé par la fusion de la pull request n° 99 (le test est mis à jour dans la même branche)
Conséquence	Le test de nuit est **entièrement vert** depuis le 5 novembre. Il prouve que la base et le code de `main` sont alignés : tout écart futur (migration appliquée avant sa fusion) le fera échouer, ce qui est son rôle

Les notifications d'échec de GitHub n'ont pas servi : sept échecs d'affilée, du 30 octobre au 5 novembre, sont restés sans réaction. **Constaté** (captures d'écran de l'auteur, 12 novembre 2026) : les notifications des workflows Actions sont activées par GitHub et par e-mail, échecs uniquement (Settings > Notifications du compte GitHub, vers 21:37) ; la recherche Gmail « from:notifications@github.com "failed" » (22:10) donne 26 résultats, dont ceux du 3, 4, 5 novembre et du 12 novembre 14:58 dans la boîte de réception ; sur les 14 e-mails visibles sur la capture (26 résultats au total), un seul apparaît lu (celui du 4 novembre) ; état des 12 autres non vu. **Déclaré** (auteur, 12 novembre 2026 à 22:24, non vérifié) : filtre Gmail créé sur ces e-mails

(expéditeur notifications@github.com, mot « failed ») : suivi (étoile), marqué important, jamais en spam, catégorie Principale ; il ne s'applique qu'aux nouveaux e-mails, n'est pas testé et n'envoie pas de notification sur téléphone. Effet du filtre : **non vérifié**. Conclusion : la réception est établie ; la réaction dépend de la lecture des e-mails ; le filtre vise à la faciliter, effet non constaté.

10.3

Configuration de production

ÉLÉMENT	VALEUR RELEVÉE
Hébergeur	Vercel, projet `logmerry`, équipe `new-team-adce`
Région des fonctions	`cdg1` (Paris), fixée dans `vercel.json` (`{ "regions": ["cdg1"] }`) et confirmée sur le déploiement
Framework, Node	Next.js, Node 24
Branche de production	`main`
Adresse publique de production	`https://logmerry.vercel.app` (alias Vercel gratuit) ; autres alias : `logmerry-new-team-adce.vercel.app`, `logmerry-git-main-new-team-adce.vercel.app`
Nom de domaine propre	**Constaté** le 12 novembre 2026 sur la page Overview du projet Vercel (capture de l'auteur, 22:14) : un seul domaine listé, `logmerry.vercel.app` ; la recommandation « Add Custom Domain » n'est pas cochée : aucun domaine propre
Accès aux préversions et aux adresses de déploiement	**Protégés** par la connexion Vercel (réponse 302 vers l'identification) ; seul l'alias de production est ouvert au public. Un visiteur arrive sur la page de connexion de l'application
Variables d'environnement (noms seulement)	`ANTHROPIC_API_KEY`, `MISTRAL_API_KEY` (production seulement), `AI_CHAT_MODEL`, `NEXT_PUBLIC_SUPABASE_URL` (production et préversion), `NEXT_PUBLIC_SUPABASE_PUBLISHABLE_KEY` (**production seulement**) (relevé du 5 novembre 2026 (`docs/journal.md:820` ; observateur non nommé), non revérifié à ce jour)
Base de données	**Un seul projet Supabase** (« LogMerry », Paris, `eu-west-3`) : il n'existe **pas de base de recette distincte**

Deux écarts à connaître :

1. **Les préversions ne sont pas équipées comme la production.** Les clés Anthropic et Mistral et la clé publique Supabase ne sont définies que pour la production : une préversion ne peut pas faire tout ce que fait la production (assistant, connexion) ; l'effet exact n'a pas été essayé (**À confirmer**). Relevé du 5 novembre 2026 (`docs/journal.md:820` ; observateur non nommé), **non revérifié à ce jour**. Observé le 10 novembre 2026 (par l'assistant de code, dans le navigateur piloté, après une connexion Vercel saisie par l'utilisateur) : l'aperçu de `feat/portfolio-image-zoom` affichait des réalisations ; l'origine des données et la configuration des variables n'ont pas été relues.
2. **Il n'y a pas d'environnement de recette.** Les préversions et la production, quand elles parlent à Supabase, parlent au même projet. Le code de développement et les tests visent la même base que la démonstration.

10.4

Compte rendu de mise en production (état au 5 novembre 2026)

ÉLÉMENT	VALEUR
Dernier déploiement de production	5 novembre 2026, après la fusion des n° 96, 97, 99 puis 102 par l'auteur (accords donnés dans la conversation) ; statut **Ready** (capture Vercel pour le n° 97 : construction 33 s)

ÉLÉMENT	VALEUR
Commit déployé	`59c9d8c`, fusion de la pull request n° 102 (formulaire de contact et « Qui suis-je »), précédée des n° 96 (page publique du portfolio), 97 (statut des réalisations) et 99 (« Choix de conception » et « Validation »)
CI sur ces commits	Succès. La CI de `main` a échoué une première fois sur un test (« double clic sur Ajouter », attente d'une seconde) puis réussi à la relance : test **instable**, noté
Adresse	`https://logmerry.vercel.app` : `/` et `/portfolio/qui-suis-je` renvoient à la connexion, `/auth/login` répond 200, `/portfolio` **répond 200 sans connexion** (vérifié le 5 novembre)
Historique	Avant le 5 novembre : une vingtaine de déploiements « Ready » du 29 au 30 octobre
Ce qui n'est pas en production	Rien de planifié : tout ce qui est fusionné est déployé. La pull request n° 98 (`feat/about-page`) devient redondante, ses commits étant dans la n° 102 (fermée le 12 novembre 2026) ; état à jour au 12 novembre : voir « Mises en production du 12 novembre 2026 »
Migrations déjà appliquées à la base partagée	Plus d'écart connu : la base et `main` sont alignés (test de nuit : 158 sur 158 après la fusion de la n° 102)

> *À savoir.* Rien n'est fusionné, ouvert ni poussé sans l'accord explicite de l'auteur ; les n° 96, 97, 99 et 102 l'ont été avec cet accord le 5 novembre. La n° 101 (livrables) a été fusionnée le 9 novembre 2026 avec son accord, et la n° 100 (brouillon) fermée.

10.5

Mises en production du 12 novembre 2026

Toutes avec l'accord explicite de l'auteur, une à la fois. Après chacune : CI de `main`, déploiement Vercel de production, comparaison du SHA déployé à celui de `main` (API des déploiements de GitHub), puis `tsc`, `eslint` et `npm test` lancés sur `main` en local (sans fichier d'environnement ni réseau).

ÉTAPE	COMMIT SUR `MAIN`	CI (`CHECK`, `AUDIT`)	VERCEL, PRODUCTION	TESTS LOCAUX
Envoi de `main` (44 commits de documentation et d'outillage du PDF ; 0 fichier de `app/`, `lib/`, `components/`, `supabase/`, `public/`, `package.json`, lockfile)	`3a6c503`	succès	succès, SHA déployé = `3a6c503`	1 177, 0 échec (mesuré avant les fusions)
Pull request n° 103 : les messages du formulaire de contact ne sont jamais indexés, quel que soit le chemin (correctif « T4 » : `be839b8`, `0907aa7`)	`9f3eb14`	succès	succès, SHA déployé = `9f3eb14`	1 179, 0 échec
Pull request n° 104 : le texte du portfolio dit que l'assistant signale quand les notes ne soutiennent pas la réponse (`b849391`)	`ce283a2`	succès	succès, SHA déployé = `ce283a2`	1 179, 0 échec
Pull request n° 105 : la mention « Ouvre un site externe » près de « Voir en direct » (`0ba9b5b`)	`7d0558e`	succès	succès, SHA déployé = `7d0558e`	1 180, 0 échec

- **Dernier commit applicatif déployé :** `7d0558e` (fusion de la n° 105, dont les commits de code sont `be839b8`, `0907aa7`, `b849391` et `0ba9b5b`). Les commits qui suivent ne touchent que la documentation.

- **Pas fusionnée** : `feat/portfolio-image-zoom` (agrandissement des miniatures du portfolio, `01f1886`) ; elle n'est donc pas en production. La pull request n° 98 a été fermée le 12 novembre (redondante : son contenu est dans `main` par la n° 102, `59c9d8c`).
- **Test instable** : sur la pull request n° 105, la CI a échoué une fois sur « double clic sur Ajouter » (exécution 43232018357), puis réussi à la relance sans changement de code ; le même test avait déjà échoué le 3 novembre (exécution 41661178343, commit `9766ea4`, vert dans l'exécution 41661167369 du même commit). 2 échecs sur 300 exécutions de la CI examinées (du 23 octobre au 12 novembre 2026) ; les 15 autres échecs de cette période viennent d'autres tests. Chaque échec est survenu à environ 1 050 ms, l'attente par défaut d'une seconde. Aucun code corrigé.

10.6

Retour arrière

QUESTION	RÉPONSE
Comment	Rétablir un déploiement précédent de production : tableau de bord Vercel (Deployments, « Instant Rollback ») ou `vercel rollback <adresse-du-déploiement>` ; `vercel rollback status` indique l'état
Quoi revenir	Le code seulement. Les déploiements précédents restent disponibles (une vingtaine listés)
Ce qui ne revient pas	**La base de données.** Une migration appliquée ne se défait pas avec le déploiement : le schéma n'avance que dans un sens. Un retour arrière du code après une migration qui supprime ou renomme une colonne peut donc casser l'application ancienne
Exercé ?	**Non, jamais.** Je ne l'ai pas lancé : il modifierait la production
Durée attendue	**À confirmer** (non mesurée)
Protection de la branche `main`	**Impossible aujourd'hui** : GitHub répond que cette fonction demande l'offre Pro ou un dépôt public. Rien n'empêche donc une fusion malgré une CI en échec ; seule la discipline de l'auteur le fait

Procédure d'exercice proposée, à faire avec ton accord, hors des heures de démonstration : noter le déploiement actuel, rétablir le précédent, vérifier `/auth/login` et `/api/chat`, puis rétablir le déploiement noté. Durée mesurée à reporter ici.

10.7

Ce qui n'existe pas

ÉLÉMENT	ÉTAT
Migrations dans le pipeline	**Aucune** : appliquées à la main
Environnement de recette ou base de recette	**Aucun**
Protection de la branche `main`	**Impossible** sur l'offre actuelle de GitHub

ÉLÉMENT	ÉTAT
Alertes de déploiement ou de panne	**Aucune configurée** (GitHub : **constaté** (captures de l'auteur, 12 novembre 2026) : notifications des workflows activées par GitHub et par e-mail, échecs uniquement ; recherche Gmail : 26 résultats, dont 14 visibles sur la capture, un seul lu (4 novembre), état des 12 autres non vu ; **déclaré** (22:24, non vérifié) : filtre Gmail créé, non testé, sans notification sur téléphone ; la réaction dépend de la lecture des e-mails, effet du filtre non constaté ; Vercel : page Alerts du projet (plan Hobby), **constatée** (capture de l'auteur, 12 novembre 2026, 22:11) : elle ne propose que « Upgrade to Pro » ; aucune alerte n'est configurée ; la création d'alertes semble réservée au plan Pro (déduit de la page, pas de la documentation) ; notifications d'échec de déploiement du compte : **non vérifiées**)
Déploiement progressif (« rolling release »)	**Non utilisé**
Test automatique après déploiement (« smoke test »)	**Aucun**

10.8

Limites et suite

LIMITE	PISTE
Fusion possible malgré une CI rouge	Protection de `main` impossible sur l'offre GitHub actuelle ; discipline, ou offre GitHub payante, ce que je ne recommande pas pour un projet de démonstration
Préversions sans clés	Ajouter les variables manquantes aux préversions, si on veut les utiliser pour la démonstration
Retour arrière jamais essayé	Exercice décrit ci-dessus
Écart entre la base et le code publié	Aucun écart de schéma connu (voir « Migrations déjà appliquées ») ; les quatre branches qui attendaient le 10 novembre ne contenaient aucune migration (`git diff --name-only` : 0 fichier `supabase/`). Au 12 novembre, trois ont été fusionnées (n° 103, 104 et 105, voir « Mises en production du 12 novembre 2026 ») ; `feat/portfolio-image-zoom` (commit `01f1886`) **n'est pas fusionnée et n'est pas en production**
Test de composants instable	« double clic sur Ajouter » (`tests/components/realisation-images.test.tsx:90`) : 2 échecs sur 300 exécutions de la CI examinées, chaque fois vert au même commit ou à la relance ; aucun code corrigé. À garder en tête : un échec isolé de la CI sur ce test se relance, sans conclure à une régression

Sécurité d'accès : authentification, droits et secrets



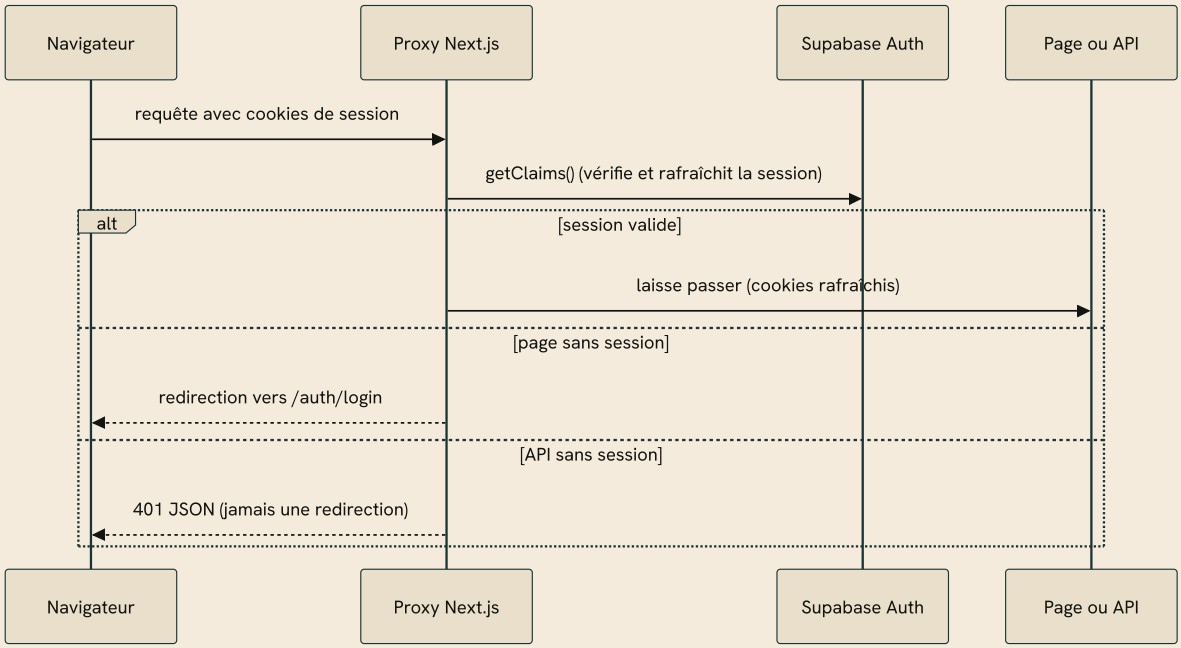
> *En deux phrases.* Chaque donnée appartient à un seul compte, et c'est *la base de données elle-même* qui l'impose (sécurité par ligne sur les 22 tables), pas seulement l'application. Il n'y a *ni SSO ni double authentification (MFA)* : l'accès repose sur un e-mail et un mot de passe d'au moins 12 caractères, et c'est une limite assumée de cette version.

Faits relevés dans le code, les migrations et la base réelle le 5 novembre 2026 (lecture seule).

11.1

Authentification

SUJET	ÉTAT
Méthode de connexion	E-mail et mot de passe (`signInWithPassword`), service Supabase Auth
Longueur minimale du mot de passe	12 caractères (`MIN_PASSWORD_LENGTH`)
SSO (connexion par un fournisseur externe)	**Aucun** : aucun appel dans le code
MFA (second facteur)	**Aucun** : rien dans le code, et 0 facteur enregistré dans la base
Double authentification des comptes d'administration	Constat de l'auteur, non vérifié autrement : la double authentification a été activée sur Vercel le 12 novembre 2026 en soirée (heure exacte non relevée). L'état de la double authentification sur GitHub et sur Supabase n'est pas établi
Création de compte	**Aucune page d'inscription** dans l'application. La base compte 5 comptes. L'inscription est **désactivée** dans le tableau de bord de Supabase (réglage déclaré par l'auteur le 5 novembre 2026 ; non lisible par les outils utilisés ici)
Mot de passe oublié	Lien envoyé par e-mail, retour sur `/auth/confirm` (échange d'un code PKCE contre une session côté serveur), puis page de nouveau mot de passe
Mots de passe déjà divulgués	Protection **désactivée** : elle est réservée à l'offre Pro de Supabase
Messages d'erreur	Traduits en français, jamais le texte brut ; un même message pour « e-mail inconnu » et « mauvais mot de passe » (`invalid_credentials`)



Le proxy (`proxy.ts`, règle `accessDecision`, testée) applique une règle simple : sans session, seules les pages `/auth/…` et les deux pages du portfolio public (`/portfolio`, `/portfolio/qui-suis-je`) sont accessibles. Tout le reste est refusé. Le paramètre `next` de retour de connexion est filtré (`safeNext`) pour empêcher une redirection vers un autre site.

11.2

Matrice des droits

L'application est **mono-propriétaire** : il n'y a pas de rôles « admin » ou « lecteur », seulement trois situations.

QUI	TABLES DE L'APPLICATION	VUES PUBLIQUES DU PORTFOLIO	FORMULAIRE DE CONTACT	FONCTIONS D'IA ET QUOTA
Visiteur sans compte (`anon`)	Aucun droit	Lecture de 2 vues : `public_realisations`, `public_realisation_images`	Peut appeler `submit_contact_message`	Aucun
Compte connecté (`authenticated`)	Lit et écrit **ses propres lignes seulement** (`owner_id = auth.uid()`)	Voit aussi ses réalisations non publiées, par ses tables	Aucun	Appelle le chat, limité à 20 appels par minute et 300 par jour
`service_role` **(clé d'administration)**	**Non utilisé**	Non utilisé	Non utilisé	Non utilisé

Les deux vues du portfolio ne montrent que les réalisations « publiées **et** avec accord du client », avec une liste blanche de colonnes fixée par un test : ajouter une colonne sans modifier le test fait échouer la CI.

11.3

Comment c'est garanti dans la base

Mesures prises dans la base réelle le 5 novembre 2026 :

CONTRÔLE	RÉSULTAT
Tables de `public` avec sécurité par ligne activée	**22 sur 22**
Politiques de sécurité	74, **toutes réservées aux comptes connectés** ; aucune ouverte à tous
Droits de `anon`	2 lectures seulement (les 2 vues du portfolio) et l'exécution de `submit_contact_message` ; aucune table
Fonctions `SECURITY DEFINER`	3 : `rule_version_is_mine`, `consume_ai_quota`, `submit_contact_message`, toutes avec un `search_path` fixé (test)

Trois barrières se superposent : une politique par table (`to authenticated` et `auth.uid()`), le retrait des droits d'`anon` (migration `20261030120000_revoke_anon_tables.sql`), et un test qui échoue si une table est créée sans sécurité par ligne.

Écart relevé et corrigé le 5 novembre 2026. Quatre fonctions d'aide (`immutable_unaccent`, `pp_thresholds_ok`, `set_updated_at`, `user_stories_guard_closed_sprint`) étaient restées exécutables par `anon`, par le droit par défaut de Postgres, antérieur à la migration du lot D qui n'avait corrigé que les futures fonctions. Elles ne lisaient aucune table. Une migration (`20261105111141_revoke_anon_helper_functions.sql`) a retiré ce droit : `anon` n'exécute plus que `submit_contact_message`, ce qu'un contrôle dans la base confirme. Un test statique vérifie désormais ces quatre retraits, et les 158 tests d'isolation passent après la migration.

11.4

Tests qui le prouvent

TEST	CE QU'IL VÉRIFIE	QUAND
`tests/isolation.test.ts`	Deux comptes fictifs ne voient, ne modifient et ne suppriment jamais les données de l'autre ; un visiteur sans compte est refusé (erreur 42501) ; `rls_audit()` liste les tables sans sécurité par ligne	Chaque nuit (`.github/workflows/isolation.yml`) contre la vraie base. **Échec du 30 octobre au 5 novembre faute de secrets ; secrets créés le 5 novembre, essai après les fusions : 158 contrôles sur 158 passent** (voir « Déploiement »). Se lance aussi à la main avec `npm run test:isolation`
`lib/security-static.test.ts`	Toute politique est `to authenticated` et utilise `auth.uid()` ; liste blanche des vues publiques ; aucun `service_role` dans le code ; seules l'adresse et la clé publique Supabase portent `NEXT_PUBLIC_`	À chaque envoi de code (CI)
`tests/proxy/`	Règle d'accès (`accessDecision`) et motif des chemins couverts par le proxy	CI

11.5

Secrets

SECRET	OÙ IL VIT	VISIBLE DU NAVIGATEUR ?
Adresse Supabase, clé publique Supabase	`.env.local`, Vercel	Oui, volontairement (clé publique : sans la sécurité par ligne, elle ne donne rien)
`ANTHROPIC_API_KEY`, `MISTRAL_API_KEY`, `AI_CHAT_MODEL`	`.env.local`, Vercel ; lues uniquement dans des fichiers `server-only`	**Non** (test : aucun composant client n'importe la configuration de l'IA)
Identifiants des deux comptes de test	`.env.test.local` (ignoré par Git), secrets GitHub Actions	Non
Clé `service_role`	**Nulle part** : aucune occurrence dans le code, les scripts, les tests	Sans objet

`.env*.local` et `.env` sont dans `.gitignore` (test) ; les fichiers d'exemple ne contiennent aucune valeur secrète (test). Les journaux de la CI ne montrent pas les secrets, et la CI refuse un secret contenant un guillemet ou un retour à la ligne.

11.6

En-têtes de sécurité du site

Posés sur toutes les routes (`lib/security-headers.ts`) : anti-cadre (`X-Frame-Options: DENY`), `nosniff`, politique de référent restreinte, HSTS sur 2 ans, caméra, micro et géolocalisation interdits.

La politique de contenu (CSP) est en **mode rapport seulement** : elle ne bloque rien aujourd'hui, car Next.js et `next-themes` injectent des scripts en ligne. Elle n'envoie pas non plus ses rapports ailleurs que dans la console du navigateur. Passage en mode bloquant : prévu après observation, **non daté**.

11.7

Limites et suite

LIMITE	CONSÉQUENCE	PISTES
Pas de MFA	Un mot de passe volé suffit pour entrer	**Limite assumée.** Le MFA TOTP (application d'authentification) est disponible gratuitement sur Supabase Auth et activé par défaut sur les projets, mais LogMerry ne l'utilise pas (aucun facteur enregistré, voir plus haut). Le MFA par téléphone, le SSO SAML et la protection contre les mots de passe fuités ne sont pas inclus en offre Free. Sources : https://supabase.com/docs/guides/auth/auth-mfa/totp et https://supabase.com/pricing (consultées le 10 novembre 2026 ; pages non datées)
Mots de passe divulgués non vérifiés	Un mot de passe connu des pirates serait accepté s'il a 12 caractères	Offre Pro, ou politique de mot de passe imposée à la main
CSP non bloquante	Une injection de script ne serait pas stoppée par le navigateur	Passer en mode bloquant avec des jetons (nonces)

Continuité de service et reprise



> *En deux phrases.* LogMerry tourne sur l'*offre gratuite* de Supabase et sur Vercel, ce qui suffit pour un projet de démonstration mais *ne garantit ni sauvegarde automatique, ni disponibilité contractuelle*. Ce chapitre dit ce qui est garanti, ce qui ne l'est pas, comment tout reconstruire, et ce qui reste à tester : *une restauration a été testée une fois, le 12 novembre 2026 : données et structure principales restaurées, deux écarts connus, corrections non testées* (section « Test de restauration du 12 novembre 2026 »).

12.1

Ce que l'offre gratuite garantit, et ne garantit pas

Faits relevés sur les pages officielles de Supabase le 4 novembre 2026 (pages non datées : à revérifier sur le site avant de les citer). Relus le 10 novembre 2026 : https://supabase.com/pricing, https://supabase.com/docs/guides/platform/free-project-pausing et https://supabase.com/docs/guides/platform/backups. Cette dernière précise que les sauvegardes de la base **n'incluent pas les fichiers du stockage** (« Database backups do not include objects you store via the Storage API »).

SUJET	OFFRE GRATUITE (CELLE DE LOGMERRY)	OFFRE PRO
Sauvegardes automatiques	**Non incluses.** Supabase recommande d'exporter régulièrement les données avec `db dump` et de garder des copies hors du service (l'export du 12 novembre 2026 a été fait avec `pg_dump` et `psql`, Docker n'étant pas installé)	Quotidiennes, conservées 7 jours
Restauration à la minute près (PITR)	Non incluse	Module payant
Pause du projet	**Si l'activité sur la base est trop faible pendant 1 semaine** (la page de Supabase parle d'une activité « sufficient » sur la semaine écoulée et dit que « typically a few user requests to the database each day » suffisent ; le seuil exact n'est pas publié ; un projet en pause se restaure jusqu'à 1 an après la pause)	Jamais
Protection contre les mots de passe divulgués	Non incluse	Incluse
Disponibilité contractuelle (SLA)	Non incluse	Non incluse (réservée à l'offre Enterprise)

L'offre gratuite est suffisante pour développer et démontrer. Ses deux limites qui comptent ici sont l'absence de sauvegarde automatique et la mise en pause du projet.

12.2

Objectifs de reprise, tels qu'ils sont aujourd'hui

RPO : quelle quantité de données peut être perdue. RTO : combien de temps pour redémarrer.

ÉLÉMENT	OÙ IL EST CONSERVÉ	RPO	RTO
Code de l'application	Dépôt GitHub (une branche par fonctionnalité)	Dernier envoi sur GitHub	À mesurer
Schéma de la base	56 migrations versionnées dans `supabase/migrations/`	Aucune perte : rejouables depuis le dépôt	À mesurer
Données de la base (notes, clients, factures…)	Supabase seulement	**Âge du dernier export manuel. Aucun export automatique ni planifié n'existe** (aucune tâche de ce type dans `vercel.json` ni dans `.github/workflows/`)	À mesurer
Images du portfolio (Supabase Storage)	Supabase Storage ; sources dans `assets-source/` (non commitées)	Non couvertes par un export de la base	À mesurer
Variables d'environnement et clés	Vercel et `.env.local` (ignoré par Git)	Aucune copie hors Vercel et `.env.local` (déclaré par l'auteur, 12 novembre 2026). Limite assumée : en cas de perte des deux, les clés sont à régénérer chez chaque fournisseur (déduction).	À mesurer

> *À confirmer.* Les durées de reprise (RTO) ne sont *pas mesurées* : le test de restauration du 12 novembre 2026 n'a pas été chronométré (sa durée totale, de 18 h 20 à 20 h 45 environ, comprend la recherche d'un mot de passe perdu). Je n'en annonce aucune.

12.3

Test de restauration du 12 novembre 2026

Résultat : restauration testée une fois, données et structure principales restaurées, deux écarts connus, corrections non testées. Ce n'est pas un « réussi » sans réserve. Faits constatés par l'auteur ; les fichiers d'export ont été supprimés après le test, donc l'assistant n'a pas pu les relire.

ÉLÉMENT	CONSTAT
Outils	`pg_dump` et `psql` 18.6 (libpq) ; pas de CLI Supabase ni de Docker
Source et cible	Production PostgreSQL 17.11 (lecture seule) vers un projet temporaire « logmerry-restauration-test » (région « Europe », serveur `eu-west-3`), session pooler, port 5432 ; projet temporaire supprimé ensuite
Export	Schéma `public` seul, sans propriétaires : `schema.sql` 120 246 octets, `data.sql` 129 806 octets ; avertissement de `pg_dump` sur `regulatory_rules` (clés étrangères circulaires)
Restauration	Une passe, sans transaction unique, avec `SET session_replication_role = replica` avant les données : **17 erreurs, toutes dans** `schema.sql`**, aucune dans** `data.sql`
Données	**Nombre de lignes identique sur les 22 tables** (389 lignes au total) ; seuls des nombres ont été comparés, pas le contenu
Structure	Index 66 / 66, politiques de sécurité par ligne 74 / 74, déclencheurs 22 / 22, tables avec sécurité par ligne active 22 / 22, droits de `service_role` 168 / 168
Écart 1	**Fonction** `match_chunks` **absente du projet restauré** (fonctions 23 en production, 22 dans le test, confirmé par requête). Cause supposée : un réglage `hnsw.iterative_scan` refusé à la création (**non vérifié**). Sans elle, la voie « par sens » de la recherche de l'assistant (appel `match_chunks`, `lib/db/retrieval.ts:17`) échouerait sur la base restaurée
Écart 2	**Droits de** `anon` **sur** `public` **: 2 en production, 74 dans le test** ; droits de `authenticated` 153 / 159. Cause supposée : 12 réglages de droits par défaut refusés (« permission denied to change default privileges ») ; le lien avec la case « Automatically expose new tables » décochée **n'est pas établi**

ÉLÉMENT	CONSTAT
Corrections	Recréer la fonction et réappliquer les retraits de droits : **non testées**
Durée	**Non mesurée** (18 h 20 à 20 h 45 environ, recherche d'un mot de passe perdu comprise)
Non couvert	Comptes `auth.users`, fichiers du stockage (bucket `portfolio`), déclencheurs éventuels sur les tables `auth`, test applicatif et test d'isolation sur la base restaurée

Les droits de `anon` plus larges dans la base restaurée sont un écart de sécurité à corriger avant de s'appuyer sur cette restauration pour une vraie reprise, sous la seule protection de la sécurité par ligne (active sur les 22 tables).

Événement lié, 12 novembre 2026 vers 19 h : le mot de passe de la base de production a été réinitialisé, faute de le retrouver. Aucune chaîne de connexion directe à la base n'existe dans les variables Vercel ni dans les secrets GitHub (noms relevés par l'auteur). Après la réinitialisation, le portfolio public et la connexion au compte de démonstration « semblent fonctionner » (constat de l'auteur, sans test systématique).

12.4

Reconstruire LogMerry de zéro

Procédure de reprise, **non testée de bout en bout** : le test du 12 novembre 2026 ne couvre que la restauration du schéma `public` avec ses données (voir plus bas), pas la procédure ci-dessous :

1. Créer un nouveau projet Supabase, région Paris (`eu-west-3`, comme l'actuel).
2. Appliquer les 56 migrations du dossier `supabase/migrations/` (par l'outil en ligne de commande de Supabase).
3. Importer le dernier export des données.
4. Mettre à jour dans Vercel l'adresse du projet et la clé publique Supabase, ainsi que les clés des services d'IA.
5. Redéployer l'application.
6. Vérifier : les tests d'isolation entre comptes et l'audit de la sécurité par ligne doivent passer.

Le schéma est donc reconstructible sans perte. Seules les **données** dépendent d'un export.

12.5

Exporter les données

Supabase recommande, pour l'offre gratuite, l'export par la commande `supabase db dump`, avec une copie conservée hors du service. L'export du 12 novembre 2026 a été fait avec `pg_dump` et `psql`, parce que Docker n'était pas installé (le CLI lance `pg_dump` dans un conteneur). Je propose : un export après chaque séance de travail importante et au minimum **une fois par semaine**, rangé hors du dépôt (il contient des données). Ce rythme **n'est pas encore en place**.

12.6

Modes dégradés dans le code

L'IA sert à l'assistant, à l'indexation des notes et aux propositions (stories, tâches, prompts, résumés). Si un service d'IA est en panne, le reste continue de fonctionner : clients, missions, factures, échéances et notes.

SITUATION	CE QUI SE PASSE
Claude ou Mistral ne répond pas (délais : 60 s pour Claude, 20 s pour Mistral)	L'assistant renvoie une erreur (statut 502) ; rien d'autre n'est bloqué

SITUATION	CE QUI SE PASSE
Aucun extrait ne dépasse le seuil de similarité	Message fixe, sans appel à Claude
Réponse de Claude contenant un nombre ou une adresse absents des extraits	Réponse rejetée avant affichage (statut 502, message dédié)
Quota dépassé : plus de 20 appels par minute ou 300 par jour et par compte	Refus clair (statut 429) ; si le compteur lui-même échoue : statut 503
Échec de l'indexation d'une note	La note est enregistrée ; son état passe à « échec » et l'indexation peut être relancée
Échec de l'enregistrement de l'historique d'un échange	La réponse est quand même affichée ; l'erreur est journalisée
Utilisateur non connecté	Accès refusé à l'assistant (statut 401)

12.7

Disponibilité et retour arrière

- **Région.** Supabase (Paris) et les fonctions Vercel (`cdg1`, Paris) sont dans la même région.
- **Déploiements.** Chaque envoi sur GitHub produit un déploiement sur Vercel. Les déploiements de production précédents restent disponibles (au moins huit sont visibles à ce jour, tous « Ready », d'une durée de 23 à 54 secondes). Le retour arrière consiste à rétablir un déploiement précédent. Il **n'a pas été exercé** : à tester.
- **Haute disponibilité.** Elle n'est **pas garantie** : une seule base, une seule région, sans engagement de disponibilité. Ce chapitre ne prétend pas le contraire.

12.8

Scénarios et réponses

SCÉNARIO	EFFET	RÉPONSE
Le projet Supabase est mis en pause (1 semaine sans activité)	L'application ne répond plus	Réactiver depuis le tableau de bord Supabase (« Resume project ») ; avant la soutenance, vérifier la veille que le projet est actif. **Prévention :** le test d'isolation de nuit (`isolation.yml`, 3 h 17 UTC) crée puis supprime des notes dans la vraie base chaque jour, donc la base reçoit des écritures quotidiennes. D'après la page de Supabase, quelques requêtes utilisateur par jour suffisent en général ; que ces écritures de nuit comptent comme telles reste **À confirmer**, et aucun ping dédié n'a été ajouté (sources : `supabase.com/docs/guides/platform/free-project-pausing`, `supabase.com/kb/faqs/platform/free-project-pausing`, discussion `github.com/orgs/supabase/discussions/51126`)
Suppression ou corruption de données	Perte jusqu'au dernier export	Réimporter l'export ; sans export, la perte est définitive
Panne de Supabase	Application indisponible	Attendre ; aucun engagement de délai sur l'offre gratuite
Mauvais déploiement	Fonctionnalité cassée	Rétablir le déploiement précédent sur Vercel

SCÉNARIO	EFFET	RÉPONSE
Panne d'Anthropic ou de Mistral	Assistant indisponible	Mode dégradé ci-dessus ; le reste de l'application fonctionne
Clé secrète exposée	Risque d'usage frauduleux	Révoquer la clé chez le fournisseur, en créer une autre, la changer dans Vercel et redéployer

12.9

Ce qui reste à faire

1. **Test de restauration : fait une fois le 12 novembre 2026** (procès-verbal dans `docs/plan-test-restauration.md`, section 7). **À refaire ou à compléter :** recréer la fonction `match_chunks` et réappliquer les retraits de droits sur le projet restauré (corrections **non testées**), mesurer les durées, restaurer les comptes et les fichiers du stockage, lancer le test d'isolation et `rls_audit()` sur la base restaurée.
2. **Mettre en place l'export hebdomadaire** et décider où l'archiver.
3. **Faire un exercice de retour arrière** sur Vercel.
4. **Avant la soutenance du 16 novembre** : s'assurer que le projet Supabase est actif.
5. **Option** : passer à l'offre Pro apporterait les sauvegardes quotidiennes sur 7 jours, l'absence de pause et la protection contre les mots de passe divulgués, au prix indiqué sur la page tarifs de Supabase.

Exploitation et conformité



> *En deux phrases.* LogMerry n'a *ni alerte ni surveillance automatique* : l'exploitation consiste en un contrôle manuel court des tableaux de bord de Supabase, de Vercel et de GitHub, et ce contrôle a déjà servi : le 5 novembre, il a révélé un test de nuit en échec depuis une semaine (secrets manquants), réparé le jour même. Le registre des traitements de données a été *validé par le responsable de traitement le 9 novembre 2026* (bases légales, durées) ; la mention d'information RGPD reste *un projet à compléter* ; les conditions des prestataires d'IA ont été relevées le 12 novembre 2026 (chapitre 8 ; état des interrupteurs Mistral avant cette date non vérifié) ; plusieurs réponses (journaux, garanties de transfert) restent « À confirmer », et deux *prérequis bloquants* (hébergement, sauvegardes) précèdent toute vraie donnée.

Faits relevés les 5 et 9 novembre 2026 dans le code, la base, GitHub et Vercel (lecture seule). Les pages officielles d'Anthropic, de Mistral AI, de Vercel, de Supabase et de Légifrance ont été lues de trois façons, selon la ligne (liens plus bas) : par des agents de lecture web (5 novembre 2026, rapports non copiés sans réserve) ; directement (9 novembre 2026, pour une partie des pages ; Légifrance L110-4 : illisible par les lecteurs automatiques le 9 novembre ; lu par l'auteur le 12 novembre) ; relues en partie le 12 novembre 2026 (extraits par un outil de lecture web, sauf le DPA de Vercel dont l'auteur a collé le texte intégral). Rien de ce chapitre n'est un avis juridique.

13.1

1. Tableau de bord d'exploitation

Il n'existe pas de tableau de bord unique. Voici ce qu'il faut regarder, où, et ce qui a été relevé les 5 et 9 novembre 2026.

SUJET	OÙ REGARDER	QUOI Y LIRE	RELEVÉ DU 5 NOVEMBRE 2026
Base de données	Tableau de bord Supabase (projet « LogMerry », Paris)	Statut du projet, journaux de l'API et de la base, avis de sécurité et de performance	Statut « ACTIVE_HEALTHY » ; avis de performance : 3 clés étrangères sans index et 4 index inutilisés, niveau info (chapitre 5) ; avis de sécurité : voir chapitre 11
Production	Vercel, projet `logmerry` : « Deployments », « Logs »	Dernier déploiement « Ready », erreurs d'exécution	Dernier déploiement de production au 12 novembre 2026 : commit `7d0558e`, terminé (chapitre 10) ; au 9 novembre : `89bd458`
Intégration continue	GitHub, onglet « Actions »	Verdict de `ci.yml` et de `isolation.yml`	`ci.yml` : succès sur `main`. `isolation.yml` : **7 échecs sur 7 jusqu'au 5 novembre (secrets manquants) ; depuis la création des secrets et les fusions du 5 novembre, 158 contrôles sur 158 passent**
Appels à l'IA	Table `ai_calls` (comptage par compte, sans contenu)	Volume d'appels, plafonds (20 par minute, 300 par jour)	120 lignes au 5 novembre (base de démonstration)
Coût de l'IA	Consoles d'Anthropic et de Mistral	Dépense du mois	**Non relevé** : consoles non consultées. Mesure du chapitre 7 : environ 0,09 dollar pour 20 questions
Sauvegardes	Tableau de bord Supabase	Date du dernier export	**Aucune sauvegarde automatique** sur l'offre gratuite (chapitre 12)

SUJET	OÙ REGARDER	QUOI Y LIRE	RELEVÉ DU 5 NOVEMBRE 2026
Risque de pause	Tableau de bord Supabase	Dernière activité	Pause après une semaine d'inactivité (offre gratuite) ; **ping anti-pause : question ouverte pour le responsable de traitement**

Routine proposée (cinq minutes, une fois par semaine et la veille d'une démonstration) : statut Supabase, dernier déploiement Vercel, verdict de la dernière exécution de chaque workflow GitHub, date du dernier export de la base.

Ce qui manque : alertes (aucune), indicateurs d'usage (nombre de comptes actifs, temps de réponse en production), mesure continue de la disponibilité. Les notifications d'échec de GitHub n'ont pas déclenché de réaction en sept jours. **Constaté** (captures d'écran de l'auteur, 12 novembre 2026) : les notifications des workflows Actions sont activées par GitHub et par e-mail, échecs uniquement (Settings > Notifications du compte GitHub, vers 21:37) ; la recherche Gmail « from:notifications@github.com "failed" » (22:10) donne 26 résultats, dont ceux du 3, 4, 5 novembre et du 12 novembre 14:58 dans la boîte de réception ; sur les 14 e-mails visibles sur la capture (26 résultats au total), un seul apparaît lu (celui du 4 novembre) ; état des 12 autres non vu. **Déclaré** (auteur, 12 novembre 2026 à 22:24, non vérifié) : filtre Gmail créé sur ces e-mails (expéditeur notifications@github.com, mot « failed ») : suivi (étoile), marqué important, jamais en spam, catégorie Principale ; il ne s'applique qu'aux nouveaux e-mails, n'est pas testé et n'envoie pas de notification sur téléphone. Effet du filtre : **non vérifié**. Conclusion : la réception est établie ; la réaction dépend de la lecture des e-mails ; le filtre vise à la faciliter, effet non constaté. **Aucune alerte d'indisponibilité n'est automatisée à ce jour, sauf si l'auteur configure un moniteur externe. Surveillance externe, si elle est configurée :** `/portfolio` répond 200 même si la base est indisponible et affiche alors la phrase « Les réalisations ne sont pas disponibles pour le moment. Revenez dans quelques instants. » (`app/portfolio/page.tsx:35`, `lib/portfolio-content.ts:129`) ; un moniteur externe devrait donc surveiller le statut **et** cette phrase. Un moniteur détecte, il ne réveille pas un projet déjà en pause (la reprise se fait depuis le tableau de bord, « Resume project » : https://supabase.com/docs/guides/platform/free-project-pausing) ; son effet sur la prévention de la pause n'est **pas vérifié**. Supabase annonce un e-mail d'avertissement environ une semaine avant la pause (« You get an email about a week before a pause », https://supabase.com/kb/faqs/platform/free-project-pausing, consultée le 10 novembre 2026) ; **l'adresse destinataire n'est pas indiquée par cette page : non vérifié.**

13.2

2. Kit de support

LogMerry n'a **qu'un utilisateur, le propriétaire** (le PRD le dit). Le « support » est donc une aide au diagnostic pour le responsable de traitement (niveau 1) et, quand elle ne suffit pas, pour la personne qui dépanne le code (niveau 2, aujourd'hui l'auteur avec l'assistant de développement).

NIVEAU	QUI	CE QU'IL FAIT
N1	L'auteur, avec la FAQ ci-dessous	Reconnaître le symptôme, appliquer l'action simple, vérifier les tableaux de bord
N2	Le développeur	Lire les journaux Vercel et Supabase, reproduire, corriger, redéployer ou revenir en arrière (chapitre 10)
Fournisseurs	Supabase, Vercel, Anthropic, Mistral	Pannes de leur côté : consulter leur page d'état (adresses **À confirmer**, non relevées), attendre ; aucun engagement de délai sur les offres actuelles

FAQ de diagnostic

Les messages sont ceux du code.

CE QU'ON VOIT	CAUSE PROBABLE	ACTION N1	SI ÇA PERSISTE (N2)
Page de connexion en boucle, ou plus de réponse du tout	Projet Supabase en pause ou en panne	Vérifier le statut du projet ; le réactiver s'il est en pause	Journaux Supabase

CE QU'ON VOIT	CAUSE PROBABLE	ACTION N1	SI ÇA PERSISTE (N2)
« Enregistrement impossible. Réessaie. »	Échec d'écriture (réseau, base, règle d'accès refusée)	Réessayer une fois	Journaux Vercel de l'action ; code d'erreur de la base
« Le serveur ne répond pas. Réessaie dans un instant. »	Délai dépassé côté navigateur	Réessayer	État de Vercel et de Supabase
« L'assistant n'a pas pu répondre pour le moment. » (502)	Claude ou Mistral en erreur ou trop lent (délai de 60 s et de 20 s)	Réessayer ; sinon l'application hors assistant fonctionne	Journaux ; clés et crédit des fournisseurs
« La réponse n'a pas pu être vérifiée par rapport à tes notes, elle n'est pas affichée. Réessaie. »	Garde-fou : citation, nombre ou adresse absents des extraits	Reformuler, vérifier que la note contient l'information	Normal si la note est incomplète ; sinon relire le jeu de test
« Question trop longue. » (413)	Question de plus de 300 caractères	Raccourcir	—
Message de plafond (« … une minute »)	Plus de 20 appels en une minute, ou 300 par jour	Attendre	Table `ai_calls`
Note à l'état « échec »	Indexation en erreur (Mistral lent ou indisponible)	Bouton « Réessayer » sur la note	Journaux ; clé Mistral
L'assistant répond « aucune source » alors que la note existe	Note non indexée, brouillon, ou question trop éloignée du texte (seuil 0,76)	Vérifier l'état de la note ; reformuler avec des mots de la note	Jeu de test, seuil
Jauge de plafond : « paramètre manquant »	Règle réglementaire absente, non vérifiée ou périmée	Compléter la règle dans les paramètres (c'est voulu)	—
Une page de l'application affiche une erreur après une mise en ligne	Mauvais déploiement	—	Retour arrière (chapitre 10) ; attention au schéma de la base

Délais de traitement

Aucun délai n'est engagé : il n'y a ni contrat de support ni astreinte, et les offres gratuites n'offrent pas de SLA. Je propose, comme **objectifs internes non contractuels** : diagnostic de niveau 1 le jour même ; correction ou retour arrière sous 24 heures ouvrées en période de démonstration. À valider par le responsable de traitement.

13.3

3. Registre des traitements (RGPD), version synthétique

Qui est responsable ? L'auteur du projet est le responsable de traitement (déclaration du 9 novembre 2026), pour les données de ses clients et prospects qu'il saisit. Statut juridique de l'activité : pas encore choisi ; LogMerry est aujourd'hui un projet de formation sans activité commerciale (déclaration de l'auteur, 12 novembre 2026) ; le choix du statut est prévu après le Bachelor ; ce n'est pas un avis juridique. **Constaté** (lecture du code le 12 novembre 2026, par l'assistant) : dans l'application, un nouveau profil reçoit par défaut « Micro-entreprise » et « BNC » avec la pastille « Déclaré » (valeurs par défaut de la base : migration `20261018110000_professional_profile.sql:23` et `:29` ; `fieldState` : `lib/domain/profile.ts:46-49` ; pastille : `components/profile-field.tsx:25-28`). C'est une hypothèse de départ de conception (décision de l'auteur, consignée dans le commentaire de la migration), pas une déclaration du statut réel, qui n'est pas encore choisi. Limite connue : la pastille « Déclaré » s'affiche sans qu'aucune déclaration n'ait eu lieu ; le profil du compte de démonstration en production n'a pas été lu. Périmètre de code gelé : écart documenté, non corrigé (voir les limites connues). Bases légales et durées ci-dessous : **décisions du responsable de traitement du 9 novembre 2026**. **Niveaux de confiance** utilisés dans ce chapitre : **confirmé** (page officielle

ouverte et lue, source et date indiquées) ; **déclaré** (information donnée par le responsable de traitement, non revérifiée) ; **secondaire** (source non officielle) ; **À confirmer** (tout le reste). Deux niveaux complémentaires : **constaté** (observé directement, avec la date et la nature de l'observation : par l'auteur sur son compte ou sur une capture d'écran, par une lecture du code, ou par une commande de l'assistant) ; **non vérifié** (affirmation dont aucune preuve n'a été retrouvée). Le détail des informations ajoutées le 9 novembre 2026 est dans le tableau « Sources et niveaux de confiance » plus bas. Aucune donnée réelle n'existe aujourd'hui : la base ne contient que des données fictives.

#	TRAITEMENT	DONNÉES	PERSONNES	FINALITÉ	BASE LÉGALE	DESTINATAIRES	DURÉE
T1	Fiches clients, prospects, contacts, missions	Nom, e-mail, téléphone, société, notes de relation	Clients, prospects et leurs contacts	Suivi de l'activité de conseil	Intérêt légitime ; **contrat** si le client est une personne physique	Supabase	Clients : relation + 5 ans ; prospects : 3 ans après la date de référence (précisions ci-dessous)
T2	Notes et index de recherche	Texte libre (peut contenir des noms), extraits et vecteurs	Idem, selon le contenu	Retrouver l'information, répondre aux questions	Intérêt légitime	Supabase ; **Mistral** (vectorisation) ; **Anthropic** (réponse)	Avec la note ; les extraits sont supprimés avec elle
T3	Historique de l'assistant	Questions et réponses, citations	Le propriétaire (et personnes citées)	Reprendre une conversation	Intérêt légitime	Supabase	12 mois glissants (purge : SQL proposé)
T4	Formulaire de contact public	Nom, e-mail, message	Visiteurs du site	Répondre à une demande	Intérêt légitime	Supabase (note en brouillon)	3 ans après le dernier échange (précisions ci-dessous)
T5	Comptes utilisateur	E-mail, mot de passe (haché par Supabase)	Le propriétaire	Se connecter	Intérêt légitime (sécuriser l'accès). **V1 : un seul utilisateur, le responsable de traitement**	Supabase	Durée du compte
T6	Facturation et encaissements	Montants, dates, client lié	Clients	Suivi des factures (hors facturation légale)	**Obligation légale** (conservation) + **contrat** (émission)	Supabase	10 ans après la clôture de l'exercice (risque : voir ci-dessous)
T7	Journaux techniques	Date, nature d'une erreur ; jamais le contenu d'une question, d'une note ni une clé	Le propriétaire	Diagnostic	Intérêt légitime (sécurité)	Vercel, Supabase	Vercel : 1 heure ; Supabase : 1 jour
T8	**(prévu, non développé)** Accès client restreint à son projet et à sa progression	Compte du client, données de son projet	Clients de l'auteur	Lui montrer l'avancement de sa mission	**À choisir par le responsable de traitement**	Supabase	**À définir**

Précisions sur les durées et les risques

- **T1. Retenu :** clients = durée de la relation, puis archivage intermédiaire de **5 ans** (article L110-4 du Code de commerce (Légifrance, version en vigueur au 12 novembre 2026 ; en vigueur depuis le 17 juin 2013 ; modifié par la loi n° 2013-619 du 16 juillet 2013, art. 32) : **confirmé** ; le I prévoit une prescription de cinq ans pour les obligations nées à l'occasion du commerce entre commerçants ou entre commerçants et non-commerçants, sauf prescriptions spéciales plus courtes ; page lue le 12 novembre 2026 (capture de l'auteur) ; voir « Sources et niveaux de confiance ») ; L110-4 fixe un délai de prescription et non une durée de conservation ; la durée d'archivage de cinq ans retenue pour les clients s'en inspire (décision du responsable de traitement, 9 novembre 2026) ; prospects = **3 ans après la date de référence**, définie comme **la plus récente entre la fiche, ses notes, ses devis et ses missions** (pas de nouvelle colonne). Pour les notes, la proposition retient leur **date de création** : leur date de modification est remise à jour à chaque réindexation, ce qui repousserait toutes les purges (à valider par le responsable de traitement). La purge d'un prospect supprime ses notes et leur index ; elle ne touche jamais un prospect qui a une mission, un devis accepté ou un devis lié à une facture (exclusion explicite, en plus des clés étrangères, dont aucune ne peut supprimer ni détacher une facture : elles protègent T6). Un prospect « perdu » reste un prospect (pas de statut dédié, aucune migration) et suit la même règle ; les devis sans suite sont purgés 3 ans après leur date. **La purge des clients à la fin de la relation (5 ans) n'est pas automatisée** : elle reste manuelle. Purge automatique des prospects : **SQL proposé (essai à blanc par défaut), non implémenté**
- **T3. Retenu : 12 mois glissants**, suppression quotidienne des messages plus anciens, citations en cascade. Aujourd'hui **aucune expiration n'est codée** (SQL proposé, non implémenté) ; « Vider la conversation » supprime tout. À la purge, la question contenue dans le titre des brouillons « À documenter : … » est remplacée par « À documenter »
- **T4. Retenu : 3 ans après le dernier échange. Définition retenue du « dernier échange »** : la **date de réception** du message (`created_at`, jamais la date de modification, que tout changement de la note remet à jour), pour une note « Message reçu · … » **non liée à une fiche** (liée, elle suit la durée de T1). Purge : **SQL proposé, non implémenté**. **Indexation : aucun message de contact n'est envoyé à Mistral, quel que soit le chemin** (« Tout indexer », enregistrement de la note, « Réessayer ») : correction écrite et testée le 9 novembre 2026 (branche `fix/index-all-skips-contact-messages`), **fusionnée le 12 novembre 2026** (n° 103, `9f3eb14`) et déployée. Limite actuelle : le repère est le titre de la note ; renommée, elle redevient indexable. Remède proposé (annexe, migration 0) : une colonne `notes.source` immuable et un déclencheur qui refuse tout extrait d'une telle note. **Messagerie anti-abus** (`contact_submissions`) : empreintes d'adresses et de messages conservées **30 jours** (déjà supprimées à chaque nouveau message par `submit_contact_message`) ; usage **uniquement anti-abus** (plafonds par heure et par jour, doublons sur 24 h) ; purge planifiée proposée pour le cas où aucun message n'arrive
- **T6. Retenu : 10 ans à compter de la clôture de l'exercice** (art. L123-22 du Code de commerce : **confirmé**, Légifrance, lu le 9 novembre 2026 ; délai fiscal distinct, art. L102 B du Livre des procédures fiscales : 6 ans jusqu'au 31/12/2026, 10 ans pour les délais expirant après le 1er janvier 2027, article de loi non relu sur Légifrance : voir « Sources et niveaux de confiance »). Article L102 B du Livre des procédures fiscales (Légifrance, version en vigueur au 12 novembre 2026 ; en vigueur depuis le 1er janvier 2023 ; modifié par la loi n° 2022-1726 du 30 décembre 2022, art. 62) : le I prévoit une conservation de six ans à compter de la dernière opération ou de l'établissement des pièces ; page lue le 12 novembre 2026 (capture de l'auteur) : **Confirmé** pour cette partie (six ans, version en vigueur au 12 novembre 2026). La version à venir du chapitre (1er janvier 2027) existe sur Légifrance, mais le texte de L102 B dans cette version n'a pas été lu. La liste des versions de L102 B sur Légifrance (consultée le 12 novembre 2026, capture de l'auteur) montre une version à venir « en vigueur à partir du 1er janvier 2027 », modifiée par l'ordonnance n° 2026-671 du 27 juillet 2026 (art. 2), la loi n° 2026-534 du 25 juin 2026 (art. 36) et l'ordonnance n° 2025-1247 du 17 décembre 2025 (art. 13). La version en vigueur depuis le 1er janvier 2023 (six ans) est indiquée comme valable jusqu'au 1er janvier 2027. Aucune version datée de 2026 n'y figure. **Confirmé** pour cette partie. Sources secondaires consultées le 12 novembre 2026 (extraits de résultats de recherche) : plusieurs cabinets et sites confirment l'article 36 de la loi n° 2026-534 du 25 juin 2026 (six à dix ans) ; elles divergent sur la date d'application : 1er janvier 2027 pour deux d'entre elles (celle retenue dans le chapitre), 1er septembre 2026 pour une autre. La version en vigueur au 12 novembre 2026 de L102 B affiche encore six ans. La source officielle place le changement au 1er janvier 2027 ; la date du 1er septembre 2026 donnée par une source secondaire n'apparaît pas dans les versions de L102 B. La durée de dix ans n'est pas établie par la source officielle lue : le texte de la version 2027 n'a pas été lu, et la liste des textes modificateurs ne dit pas quelle disposition fixe la durée. **Niveau (durée de dix ans et rattachement de cette durée à la loi de 2026) : secondaire ; À confirmer. Nouvelle version de L102 B au 1er janvier 2027 : Confirmé (Légifrance, liste des versions). Les factures étaient déjà conservées 10 ans (L123-22) : la politique de conservation de T6 ne change pas. Risque : perte de factures** : le plan Free de Supabase n'a **ni sauvegarde automatique ni protection contre la pause après 1 semaine d'inactivité** (**confirmé**, pages officielles de Supabase, lues le 9 novembre 2026)

- **T7. Vercel : 1 heure** (plan Hobby, **confirmé**, docs Vercel lues le 9 novembre 2026). **Supabase : 1 jour** (plan Free, **confirmé** sur la page tarifaire ; d'après la documentation de Supabase consultée le 12 novembre 2026 : 1 jour sur l'offre gratuite (non relevé dans le tableau de bord du projet))

Prérequis avant toute mise en ligne de T8 (rien n'est implémenté) : (1) sécurité par ligne propre à chaque client, testée avec deux comptes clients fictifs ; (2) information des utilisateurs (politique de confidentialité) ; (3) durée de conservation des comptes clients.

Risques connus du registre. (1) **Perte de factures (T6)** : pas de sauvegarde automatique ni de protection contre la pause sur le plan Free de Supabase ; le chapitre 12 décrit l'export manuel ; l'export du 12 novembre 2026 a été fait avec `pg_dump` et `psql`, pas avec le CLI Supabase. (2) **Hébergement (tout le registre)** : le plan Hobby de Vercel n'est pas prévu pour un usage commercial (voir « Prérequis de mise en production »).

Exception à la règle `owner_id = auth.uid()` : la table système `purge_log` (journal des purges, proposée en annexe, non créée) n'a pas de propriétaire. La sécurité par ligne y est activée et ni `anon` ni `authenticated` n'ont aucun droit. **Exception acceptée par le responsable de traitement le 9 novembre 2026.**

Mesures de sécurité (chapitres 8 et 11) : sécurité par ligne sur les 22 tables, aucune clé d'administration dans le projet, appels à l'IA depuis le serveur seulement, extraits limités au compte et aux notes liées au client, journaux sans contenu.

Sous-traitants et transferts

PRESTATAIRE	RÔLE	LIEU	CE QUI EST ÉTABLI (DÉTAIL DATÉ DANS « SOURCES ET NIVEAUX DE CONFIANCE »)	CE QUI RESTE À CONFIRMER
Supabase	Base, authentification, stockage	Paris (`eu-west-3`), relevé dans le projet	**Plan Free (cloud).** DPA : document officiel publié par Supabase (version du 1er août 2026), **en vigueur avec les conditions générales** : accepter le contrat vaut signature des clauses contractuelles types (cl. 12.2 ; **confirmé**, page lue le 9 novembre 2026 ; lecteur du 9 novembre non établi dans le journal ; relu le 12 novembre 2026 (extrait de la page) ; la page ne limite pas le DPA à un plan et renvoie aux conditions de service)	Journaux : d'après la documentation de Supabase consultée le 12 novembre 2026 : 1 jour sur l'offre gratuite (non relevé dans le tableau de bord du projet)
Vercel	Hébergement, fonctions en `cdg1` (Paris)	Fonctions à Paris	**Plan Hobby** (déclaré par le responsable de traitement). **DPA : applicabilité à Hobby non établie.** Le DPA de Vercel (page officielle, dernière mise à jour du 17 mars 2026 ; page relue en texte intégral le 12 novembre 2026, texte affiché dans le navigateur de l'auteur et collé par lui) indique couvrir les clients des plans Enterprise et Pro ; le plan Hobby n'y est pas nommé. La page ne dit pas explicitement que Hobby est exclu : l'inapplicabilité à Hobby est une déduction, non une mention expresse. Le mot « Hobby » n'apparaît nulle part dans le texte du DPA. Le DPA cite les clauses contractuelles types de 2021 (décision (UE) 2021/914), au Schedule 3 du DPA. Ce n'est pas un avis juridique. (Lecture antérieure du 9 novembre 2026 : « DPA Pro et Enterprise », `docs/journal.md:905` ; le journal du même jour, `docs/journal.md:909`, laissait Vercel « À confirmer ».) **Usage commercial non couvert par le plan Hobby** (**confirmé**, règles d'usage équitable de Vercel). Journaux d'exécution : **1 heure** sur Hobby (**confirmé**)	Lieu des journaux ; décision de plan (voir « Prérequis de mise en production »)

PRESTATAIRE	RÔLE	LIEU	CE QUI EST ÉTABLI (DÉTAIL DATÉ DANS « SOURCES ET NIVEAUX DE CONFIANCE »)	CE QUI RESTE À CONFIRMER
Anthropic (Claude, API)	Rédige les réponses à partir des extraits	**Traitement mondial par défaut** ; aucune option « UE seulement » trouvée (seulement « US » ou « global »)	Par défaut, Anthropic n'entraîne pas ses modèles sur les données de l'API ; suppression automatique **sous 30 jours**, jusqu'à 2 ans si une conversation est signalée comme contraire à la politique d'usage ; contenu non conservé par défaut hors modèles « couverts » (30 jours) ; on retient « au plus 30 jours » (comme au chapitre 8 ; lu le 12 novembre 2026 (extraits de pages : privacy.claude.com, articles 7996868 [entraînement, mise à jour du 18 août 2026] et 7996866 [rétention, mise à jour du 1er juillet 2026] ; platform.claude.com/docs/en/manage-claude/api-and-data-retention [aucune date]) ; première lecture : rapport d'agent du 5 novembre 2026) ; DPA en vigueur depuis le 24 février 2025 ; clauses contractuelles types de la décision (UE) 2021/914, modules 2 et 3, incorporées ; le DPA fait partie des « Commercial Terms of Service » ou d'un autre accord qui le référence ; les clients API ne sont pas nommés ; relu le 12 novembre 2026 (extrait) ; l'importateur est l'entité Anthropic qui a signé l'accord ; accord qui régit le compte API de LogMerry : **À confirmer** (console)	Liste des sous-traitants lue le 9 novembre 2026 (22 entrées, dont Google Cloud, AWS et Azure en « monde entier », Cloudflare ; services de support, d'analyse et de lutte contre la fraude aux États-Unis) ; état du compte d'API de l'auteur ; rétention à zéro : sur demande commerciale seulement
Mistral AI (embeddings)	Vectorise le titre et les extraits des notes, et la question	Hébergement dans l'UE par défaut : étayé en partie (liste des sous-traitants lue le 9 novembre 2026, `docs/journal.md:886` : hébergements dans l'UE et l'EEE) ; la politique de confidentialité ne précise pas le lieu d'hébergement ; défaut pour l'API **non établi** (point d'accès américain possible, non utilisé : **À confirmer** dans le code et le compte)	Accord de traitement applicable (Mistral sous-traitant, client responsable) ; la politique dit joindre les clauses contractuelles types les plus récentes à des contrats (contexte exact non établi par l'extrait) : **À confirmer** (lecture du 5 novembre) ; rétention à zéro possible sur demande, pour les appels sans état, **dont** `/v1/embeddings`	**Entraînement : voir ci-dessous** ; conservation par défaut des appels d'API : **30 jours glissants** pour détecter les abus (conditions relevées le 12 novembre 2026, chapitre 8), puis suppression, sauf rétention à zéro activée (politique de confidentialité de Mistral, lue le 9 novembre 2026, relue le 12 nov. ; la politique indique une date d'effet du 3 septembre 2026 et aucune date de mise à jour ; la page ne dit pas si `/v1/embeddings` est une « API spécifique » exclue de cette règle : **À confirmer**) ; liste des sous-traitants lue le 9 novembre 2026 (25 entrées : hébergement Microsoft en Suède et Norvège, Google aux Pays-Bas et en Belgique, Mistral Compute en France, CoreWeave dans l'EEE ; le point d'accès américain de l'API s'appuie sur Google aux

PRESTATAIRE RÔLE	LIEU	CE QUI EST ÉTABLI (DÉTAIL DATÉ DANS « SOURCES ET NIVEAUX DE CONFIANCE »)	CE QUI RESTE À CONFIRMER
			États-Unis ; services annexes en Irlande, dans l'EEE et aux États-Unis)

Point d'attention : l'entraînement chez Mistral. D'après un rapport d'agent de lecture web (5 novembre 2026, `docs/journal.md:829`), les pages officielles ne disent pas clairement le comportement par défaut pour l'API : elles décrivent une **désactivation à faire par le client** (un réglage dans la console, « Studio ») pour que les appels ne servent pas à améliorer les services de Mistral (non relu à la source officielle). **Conditions relevées le 12 novembre 2026 (sources au chapitre 8) :** entrées et sorties conservées le temps de générer la réponse puis 30 jours glissants pour détecter les abus, sauf conservation zéro (offre payante, appels sans état) ; les conditions commerciales excluent l'entraînement sur les données du client hors cas listés (consentement ou refus selon le produit, retours d'expérience, bon de commande, modèles Labs ou préversions). **Interrupteurs constatés par l'auteur le 12 novembre 2026** (section API, Confidentialité) : « Autoriser l'utilisation de vos appels API pour entraîner les modèles d'IA de Mistral » désactivé ; « Activer les modèles Labs » désactivé ; **l'état avant cette date n'est pas vérifié. État constaté le 9 novembre 2026** (capture d'écran fournie par le responsable de traitement, console Mistral, Admin, API, Confidentialité) : l'interrupteur « Autoriser l'utilisation de vos appels API pour entraîner les modèles d'IA de Mistral » est **désactivé**, et « Activer les modèles Labs » est **désactivé** (Labs accepterait l'entraînement quel que soit le réglage). Les réglages de la section Vibe (application de chat) ne concernent pas LogMerry. La capture n'est pas jointe au dépôt ; l'état n'a pas été vérifié directement dans la console. Conservation par défaut des appels d'API : 30 jours glissants pour détecter les abus, sauf rétention à zéro (voir le tableau ci-dessus ; politique relue le 12 nov. : elle indique une date d'effet du 3 septembre 2026 et aucune date de mise à jour). `/v1/embeddings` **figure parmi les endpoints éligibles à la rétention zéro** (offres payantes, sur demande ; **confirmé**, `docs.mistral.ai`, lu le 9 novembre 2026, relu le 12 nov. (extrait)). La règle des 30 jours est celle de l'API en général ; la politique ne nomme pas les embeddings (point non précisé par les sources).

Sources (pages officielles ; lues par des agents de lecture web le 5 novembre 2026, `docs/journal.md:829`, sauf les listes de sous-traitants, lues le 9 novembre 2026, `docs/journal.md:885`) :

- Anthropic : `privacy.claude.com` (articles « Is my data used for model training » et « How long do you store my organization's data »), `anthropic.com/legal/commercial-terms`, `anthropic.com/legal/data-processing-addendum`, `platform.claude.com/docs/en/manage-claude/data-residency`.
- Mistral : `legal.mistral.ai/terms/privacy-policy` (conservation des appels d'API, 30 jours glissants), `legal.mistral.ai/terms/commercial-terms-of-service`, `legal.mistral.ai/terms/data-processing-addendum`, articles du centre d'aide `help.mistral.ai` (hébergement des données, rétention à zéro, désactivation de l'entraînement).
- Listes de sous-traitants : `trust.anthropic.com/subprocessors` et `trust.mistral.ai/subprocessors`, lues le 9 novembre 2026 dans un navigateur (les pages demandent JavaScript). Elles ne précisent pas quels sous-traitants reçoivent les appels d'API de LogMerry : **À confirmer**.

Sous-traitants et destinataires relevés dans le code et la configuration (9 novembre 2026)

Liste établie à partir des adresses appelées, des clés d'API, des variables d'environnement, des dépendances et de la configuration du projet, **pas à partir du registre**.

SERVICE	CE QUE MONTRENT LE CODE ET LA CONFIGURATION	DONNÉES CONCERNÉES
Supabase	`NEXT_PUBLIC_SUPABASE_URL`, `@supabase/ssr` et `@supabase/supabase-js` ; projet `eu-west-3` (Paris)	Tout le contenu de l'application (base, authentification, stockage)
Vercel	Hébergement ; `VERCEL_URL` et `VERCEL_PROJECT_PRODUCTION_URL` lues par le code	Requêtes vers l'application, journaux d'exécution

SERVICE	CE QUE MONTRENT LE CODE ET LA CONFIGURATION	DONNÉES CONCERNÉES
Anthropic	`https://api.anthropic.com/v1/messages`, `ANTHROPIC_API_KEY`, `AI_CHAT_MODEL`	Question et extraits retrouvés
Mistral AI	`https://api.mistral.ai/v1/embeddings`, `MISTRAL_API_KEY`	Titre et extraits des notes, question
Messagerie des e-mails d'authentification	Messagerie par défaut de Supabase ; un SMTP personnalisé (Resend, Brevo) « sera nécessaire avant l'usage réel » (`docs/supabase-auth-setup.md`) : **pas configuré ; sous-traitant prévu, fournisseur À choisir par le responsable de traitement ; prérequis bloquant avant l'usage réel**	Adresse e-mail du compte
GitHub (Actions)	`.github/workflows/isolation.yml` et `ci.yml` (`actions/checkout`, `actions/setup-node`) ; secrets du test de nuit	Comptes fictifs et clé publique seulement : aucune donnée réelle ; le test d'isolation vise le projet Supabase unique, qui sert aussi à la démonstration ; il n'existe pas de base de recette
Polices	`next/font/google` : polices servies par l'application elle-même (`/_next/static/media`). **Mesuré le 9 novembre 2026 : 43 requêtes sur** `/portfolio` **après défilement complet et 23 sur** `/auth/login`**, toutes sur** `logmerry.vercel.app`**, aucune vers Google** (outil de développement du navigateur)	Aucune pour le visiteur
Sites tiers de la vitrine publique	Liens vers Notion : les adresses `notion.site` et `notion.so` n'ont jamais d'aperçu en direct (liste codée en dur, `lib/domain/portfolio.ts:63-67`) ; Notion refuse d'être affiché dans un cadre (en-tête `X-Frame-Options: SAMEORIGIN` et `frame-ancestors` limité aux domaines de Notion, constatés le 12 novembre 2026 par une requête `curl -I`, lecture seule, lancée par l'assistant) ; la fiche montre alors sa capture ou un aplat avec le titre, et les liens vers le site. Aperçu en direct de `ateliernovav3.lovable.app` dans un cadre isolé : **mesuré le 9 novembre 2026, aucun chargement automatique** (aucun cadre présent après défilement complet) ; le chargement sans clic dépend de la place de la fiche et de l'absence de capture : la première fiche sans capture se charge seule quand elle approche de l'écran, hors mode « économie de données » (`components/portfolio-showcase.tsx:61`, `components/live-preview.tsx:45-53`), sans bouton ni mention ; les autres fiches, ou une fiche avec capture, ne se chargent qu'**au clic sur « Voir en direct »**. Dans tous les cas le visiteur envoie son adresse IP à ce site au chargement. **Décision du responsable de traitement (9 novembre 2026) : le bouton est conservé, avec une capture hébergée chez lui (à téléverser par le responsable de traitement) et la mention « Ouvre un site externe » près du bouton « Voir en direct »** (mention écrite et testée sur la branche `fix/preview-external-notice`, **fusionnée le 12 novembre 2026** par la n° 105, `7d0558e`, et déployée ; affichage sur le site en ligne **non vérifié**, aucun navigateur utilisé). Dans le registre : Lovable = **destinataire tiers au clic seulement**, mention déployée (affichage non vérifié). Ce sont des sites de projets de l'auteur, pas des sous-traitants	Adresse IP du visiteur, au clic seulement

Aucune dépendance d'analyse, de suivi ni de publicité (`package.json` relu le 9 novembre 2026), et **aucune requête d'analyse ni vers un domaine tiers mesurée** sur `/portfolio` et `/auth/login` (9 novembre 2026). Les autres pages de l'application, connectées, n'ont pas été mesurées.

Transferts hors UE et garanties

PRESTATAIRE	TRANSFERT HORS UE ET GARANTIE
Anthropic	Société américaine (importateur : l'entité Anthropic qui a signé l'accord) ; garantie documentée : DPA en vigueur depuis le 24 février 2025 ; clauses contractuelles types de la décision (UE) 2021/914, modules 2 et 3, incorporées ; le DPA fait partie des « Commercial Terms of Service » ou d'un autre accord qui le référence ; les clients API ne sont pas nommés ; relu le 12 novembre 2026 (extrait) (`anthropic.com/legal/data-processing-addendum` ; **Partiellement confirmé** (extraits, 5 nov. par agent, 12 nov. par extrait)) ; accord qui régit le compte API de LogMerry : **À confirmer** (console) ; traitement mondial par défaut (rapport d'agent du 5 novembre 2026)
Supabase	Importateur : Supabase Pte. Ltd (Singapour). **Garantie documentée** : clauses contractuelles types de la décision 2021/914, **module 2** (responsable vers sous-traitant), incorporées par la cl. 12.1 et signées par l'acceptation du contrat (cl. 12.2) ; le cadre de protection des données UE-États-Unis (DPF) n'est **pas mentionné** (DPA lu le 9 novembre 2026, **confirmé** ; lecteur du 9 novembre non établi dans le journal ; relu le 12 novembre 2026 (extrait de la page) ; la page ne limite pas le DPA à un plan et renvoie aux conditions de service)
Vercel	Société américaine : transfert possible. Le DPA de Vercel (page officielle, dernière mise à jour du 17 mars 2026 ; page relue en texte intégral le 12 novembre 2026, texte affiché dans le navigateur de l'auteur et collé par lui) indique couvrir les clients des plans Enterprise et Pro ; le plan Hobby n'y est pas nommé. La page ne dit pas explicitement que Hobby est exclu : l'inapplicabilité à Hobby est une déduction, non une mention expresse. Le mot « Hobby » n'apparaît nulle part dans le texte du DPA. Le DPA cite les clauses contractuelles types de 2021 (décision (UE) 2021/914), au Schedule 3 du DPA. Ce n'est pas un avis juridique.
Mistral AI	Société française ; hébergement dans l'UE par défaut : étayé en partie (liste des sous-traitants lue le 9 novembre 2026, `docs/journal.md:886` : hébergements dans l'UE et l'EEE) ; la politique de confidentialité ne précise pas le lieu d'hébergement ; défaut pour l'API non établi ; la liste des sous-traitants (9 novembre 2026) comprend des sociétés américaines (dont le point d'accès américain, non utilisé par LogMerry : **À confirmer**) ; garantie : la politique dit joindre les clauses contractuelles types les plus récentes à des contrats (contexte exact non établi par l'extrait) : **À confirmer**

Sources et niveaux de confiance (informations ajoutées le 9 novembre 2026)

Méthode. Ces recherches ont été faites avec l'aide d'un assistant IA ; les textes de loi cités sont à confirmer sur Légifrance.

INFORMATION	SOURCE	DATE	CONFIANCE
`/v1/embeddings` **éligible à la rétention zéro de Mistral**	`docs.mistral.ai/admin/monitor-comply/zero-data-retention`	9 nov. ; relu le 12 nov. (extrait)	**Confirmé** (offre payante, sur demande ; non demandée)
Mistral : 30 jours glissants pour les API, « sauf API spécifiques »	`legal.mistral.ai/terms/privacy-policy`	9 nov. ; relu le 12 nov. (extrait)	Texte confirmé, relevé de nouveau le 12 novembre 2026 (chapitre 8 ; la politique indique une date d'effet du 3 septembre 2026 et aucune date de mise à jour) : 30 jours glissants pour l'API, sauf conservation zéro ; embeddings non nommés dans la politique

INFORMATION	SOURCE	DATE	CONFIANCE
Mistral : entraînement sur les appels d'API désactivé	Capture d'écran de la console fournie par le responsable de traitement	9 nov.	Interrupteur constaté désactivé par l'auteur le 12 novembre 2026 ; état avant cette date non vérifié ; les conditions commerciales excluent l'entraînement hors cas listés (chapitre 8)
Vercel Hobby : journaux d'exécution conservés 1 heure	`vercel.com/docs/logs/runtime`	9 nov.	**Confirmé**
Vercel Hobby : usage commercial non couvert	`vercel.com/docs/limits/fair-use-guidelines`	9 nov.	**Confirmé** (la page définit l'usage commercial comme tout déploiement servant un gain financier, y compris le travail d'un consultant)
Vercel : DPA (plans couverts)	`vercel.com/legal/dpa`	9 nov. ; page relue en texte intégral le 12 nov. (texte collé par l'auteur)	Le DPA indique couvrir les plans Enterprise et Pro ; le mot « Hobby » n'apparaît nulle part dans le texte du DPA ; l'exclusion de Hobby est une déduction, non une mention expresse (page : dernière mise à jour du 17 mars 2026 ; clauses contractuelles types de 2021, décision (UE) 2021/914, Schedule 3 du DPA). **Non confirmé expressément**

INFORMATION	SOURCE	DATE	CONFIANCE
Plan Hobby de Vercel : usage commercial	Documentation officielle de Vercel (Fair Use Guidelines) ; déclaration de l'auteur	12 nov.	Plan Hobby de Vercel : d'après la documentation officielle consultée le 12 novembre 2026, les équipes Hobby sont limitées à un usage personnel non commercial ; tout usage commercial exige un plan Pro ou Enterprise. L'usage commercial est défini comme tout déploiement servant au gain financier de toute personne participant à sa production, y compris un consultant rémunéré qui écrit le code. Aujourd'hui, LogMerry est un projet de formation, sans prospection ni vente (déclaration de l'auteur, 12 novembre 2026). L'auteur indique envisager un usage commercial après le Bachelor ; un passage au plan Pro serait alors à étudier avant cet usage. Ce n'est pas un avis juridique. Le prix du plan Pro n'a pas été relevé à la source officielle.
Supabase Free : pas de sauvegarde automatique	`supabase.com/kb/faqs/platform/free-plan-backups` (mise à jour du 30 oct. 2026)	9 nov.	**Confirmé**
Supabase Free : pause après 1 semaine d'inactivité ; journaux API et base : 1 jour	`supabase.com/pricing` ; `supabase.com/docs/guides/platform/free-project-pausing` (pause relue le 10 nov.)	9 nov.	**Confirmé** (page tarifaire ; journaux : d'après la documentation de Supabase consultée le 12 novembre 2026 : 1 jour sur l'offre gratuite (non relevé dans le tableau de bord du projet))

INFORMATION	SOURCE	DATE	CONFIANCE
Supabase : DPA (version 1, 1er août 2026) en vigueur avec les CGU ; clauses contractuelles types 2021/914 module 2 (cl. 12.1), acceptation du contrat = signature (cl. 12.2), importateur Supabase Pte. Ltd (Singapour), DPF non mentionné	`supabase.com/legal/customer-resources/data-processing-addendum`	9 nov.	**Confirmé** (clauses relues ; lecteur du 9 novembre non établi dans le journal ; relu le 12 novembre 2026 (extrait de la page) ; la page ne limite pas le DPA à un plan et renvoie aux conditions de service)
Conservation des documents comptables : 10 ans (L123-22 du Code de commerce)	Légifrance, article L123-22 (page ouverte) ; BOFiP BOI-BIC-DECLA-30-10-20-30 (version du 20 juillet 2018), https://bofip.impots.gouv.fr/bofip/2837-PGP.html	9 nov.	**Confirmé**
Prescription de 5 ans (L110-4 du Code de commerce)	Légifrance, article L110-4 du Code de commerce (Légifrance, version en vigueur au 12 novembre 2026 ; en vigueur depuis le 17 juin 2013 ; modifié par la loi n° 2013-619 du 16 juillet 2013, art. 32) ; source complémentaire : DGCCRF, fiche « Délais de prescription » (écrite le 16 octobre 2023), https://www.economie.gouv.fr/dgccrf/les-fiches-pratiques-et-les-faq/delais-de-prescription	12 nov. (Légifrance) ; 9 nov. (DGCCRF)	**Confirmé** (page Légifrance lue le 12 novembre 2026, capture de l'auteur ; le I prévoit une prescription de cinq ans pour les obligations nées à l'occasion du commerce entre commerçants ou entre commerçants et non-commerçants, sauf prescriptions spéciales plus courtes) ; fiche DGCCRF : **Source officielle secondaire** ; adresse relevée dans un résultat de recherche

INFORMATION	SOURCE	DATE	CONFIANCE
Conservation fiscale (L102 B du Livre des procédures fiscales) : 6 ans jusqu'au 31/12/2026, 10 ans pour les délais expirant après le 1er janvier 2027	BOFiP BOI-CF-COM-10-10-30 (version du 3 septembre 2025), https://bofip.impots.gouv.fr/bofip/645-PGP.html : cite l'article L. 102 B du LPF et un délai de six ans. Loi n° 2026-534 du 25 juin 2026 (publiée au Journal officiel du 26 juin 2026), d'après CCI Paris Île-de-France (publié le 29 juillet 2026), https://entreprises.cci-paris-idf.fr/actualites/allongement-du-delai-de-conservation-des-documents-fiscaux-10-ans : délai porté de 6 à 10 ans pour les délais arrivant à expiration après le 1er janvier 2027. Article L102 B du Livre des procédures fiscales (Légifrance, version en vigueur au 12 novembre 2026 ; en vigueur depuis le 1er janvier 2023 ; modifié par la loi n° 2022-1726 du 30 décembre 2022, art. 62) : le I prévoit une conservation de six ans à compter de la dernière opération ou de l'établissement des pièces ; page lue le 12 novembre 2026 (capture de l'auteur) : **Confirmé** pour cette partie (six ans, version en vigueur au 12 novembre 2026). La version à venir du chapitre (1er janvier 2027) existe sur Légifrance, mais le texte de L102 B dans cette version n'a pas été lu. La liste des versions de L102 B sur Légifrance (consultée le 12 novembre 2026, capture de l'auteur) montre une version à venir « en vigueur à partir du 1er janvier 2027 », modifiée par l'ordonnance n° 2026-671 du 27 juillet 2026 (art. 2), la loi n° 2026-534 du 25 juin 2026 (art. 36) et l'ordonnance n° 2025-1247 du 17 décembre 2025 (art. 13). La version en vigueur depuis le 1er janvier 2023 (six ans) est indiquée comme valable jusqu'au 1er janvier 2027. Aucune version datée de 2026 n'y figure. **Confirmé** pour cette partie. Sources secondaires consultées le 12 novembre 2026 (extraits de résultats de recherche) : plusieurs cabinets et sites confirment l'article 36 de la loi n° 2026-534 du 25 juin 2026 (six à dix ans) ; elles divergent sur la date d'application : 1er janvier 2027 pour deux d'entre elles (celle retenue dans le chapitre), 1er septembre 2026 pour une autre. La version en vigueur au 12 novembre 2026 de L102 B affiche encore six ans. La source officielle place le changement au 1er janvier 2027 ; la date du 1er septembre 2026 donnée par une source secondaire n'apparaît pas dans les versions de L102 B. La durée de dix ans n'est pas établie par la source officielle lue : le texte de la version 2027 n'a pas été lu, et la liste des textes modificateurs ne dit pas quelle disposition fixe la durée.	9 nov. ; 12 nov. (Légifrance, six ans ; sources secondaires)	**Déclaré** : BOFiP consulté par l'auteur le 9 novembre hors session, non rouvert par l'assistant (six ans, version de 2025) ; **changement de 2026 relevé sur une source consultative** (CCI) ; dix ans à partir de 2027 et rattachement de cette durée à la loi de 2026 : **secondaire**, **À confirmer** ; six ans (version en vigueur au 12 nov. 2026) et nouvelle version de L102 B au 1er janvier 2027 : **Confirmé** (Légifrance, liste des versions) ; article de loi non relu sur Légifrance
Anthropic : DPA en vigueur depuis le 24 février 2025 ; clauses contractuelles types de la décision (UE) 2021/914, modules 2 et 3, incorporées ; le DPA fait partie des « Commercial Terms of Service » ou d'un autre accord qui le référence ; les clients API ne sont pas nommés	`anthropic.com/legal/data-processing-addendum`	5 nov. (agent) ; relu le 12 nov. (extrait)	**Partiellement confirmé** (extraits, 5 nov. par agent, 12 nov. par extrait) ; accord qui régit le compte API de LogMerry : **À confirmer** (console)

Droits des personnes

DROIT	COMMENT IL S'EXERCE AUJOURD'HUI
Accès, rectification	Le propriétaire retrouve et corrige les données dans l'application ; **aucun export automatique**
Effacement	Suppression d'une fiche ou d'une note (extraits supprimés avec elle) ; « Vider la conversation » ; copie dans les sauvegardes : aucune sauvegarde automatique, donc rien à purger, mais les exports manuels éventuels sont à effacer aussi

DROIT	COMMENT IL S'EXERCE AUJOURD'HUI
Opposition, limitation, portabilité	**Pas de procédure écrite**
Demande d'une personne extérieure (par exemple un visiteur du formulaire)	**Pas de procédure écrite** : elle passerait par l'adresse de contact du propriétaire

13.4

4. Mention d'information : projet à valider par le responsable de traitement

Deux emplacements concernés : le **formulaire de contact public** (il affiche, depuis le 5 novembre, une ligne courte validée par le responsable de traitement : « Votre nom, votre adresse e-mail et votre message ne servent qu'à vous répondre. » ; la mention complète ci-dessous n'est pas affichée dans l'application (périmètre gelé), seule cette phrase courte l'est ; le contact est décidé (nom et e-mail, 12 novembre 2026) ; la durée et la base légale sont décidées ; reste à écrire la procédure d'exercice des droits) et, plus tard, tout accès de tiers. Projet de texte, à relire et à compléter avant publication :

> *Vos données.* Les informations saisies dans ce formulaire (nom, adresse e-mail, message) sont utilisées uniquement pour répondre à votre demande. Elles sont conservées *3 ans après le dernier échange*. Elles sont hébergées en France chez Supabase. Base légale : intérêt légitime (répondre à votre demande). Pour exercer vos droits d'accès, de rectification ou d'effacement, écrivez à *alexandre.pericat@gmail.com*. Responsable de traitement : *Pericat Alexandre*, en personne physique.

Pour l'envoi d'extraits de notes à des prestataires d'IA (information du propriétaire, dans les paramètres ou la documentation) :

> Pour répondre à tes questions, LogMerry envoie à *Mistral AI* (vectorisation) le titre et des extraits de tes notes, et à *Anthropic* (rédaction de la réponse) ta question et les extraits retrouvés. Ils ne sont *pas* envoyés : tes clients, factures, missions et l'historique. D'après les pages d'Anthropic lues le 12 novembre 2026 (extraits de pages ; privacy.claude.com, mises à jour du 18 août 2026 et du 1er juillet 2026), Anthropic n'entraîne pas ses modèles sur les données de l'API par défaut et les supprime sous 30 jours (jusqu'à 2 ans si une conversation est signalée comme contraire à la politique d'usage) ; pour Mistral, hébergement dans l'UE par défaut : étayé en partie (liste des sous-traitants lue le 9 novembre 2026 : hébergements dans l'UE et l'EEE) ; la politique de confidentialité ne précise pas le lieu d'hébergement ; défaut pour l'API non établi. Chez Mistral, les interrupteurs d'entraînement sur les appels d'API et des modèles Labs sont désactivés au relevé de l'auteur du 12 novembre 2026 (état avant cette date non vérifié) ; les conditions commerciales excluent l'entraînement sur les données du client hors cas listés (chapitre 8).

13.5

5. Limites connues et plan d'action

Ces points ne sont **pas cachés** : ce sont des limites connues du projet à la date du dossier, chacune avec son action. Aucune ne bloque la démonstration, car **l'application ne contient que des données de test**.

#	LIMITE CONNUE	CONSÉQUENCE	ACTION PRÉVUE	QUI	QUAND
1	Correction T4 (aucun message de contact indexé) faite, testée, **fusionnée et déployée le 12 novembre 2026** (n° 103, `9f3eb14`)	Le risque décrit au chapitre 9 est traité par le code déployé ; limite : le repère est le titre de la note ; effet sur l'application en ligne non vérifié	Fait	Auteur	Fait le 12 nov.
2	Purges (T1, T3, T4, `contact_submissions`) : **proposition documentée, non activée et non testée** (le SQL n'a jamais été exécuté)	Aucune expiration automatique aujourd'hui	Annexe : essai à blanc deux semaines après activation, puis suppression réelle sur accord ; export des données avant ; essai sur données de test	Auteur	Après la soutenance
3	Mistral : conditions relevées le 12 novembre 2026 (chapitre 8) ; interrupteurs constatés désactivés le 12 novembre, état avant cette date non vérifié ; embeddings non nommés dans la politique	Le réglage est un état constaté ; les conditions commerciales font foi	Relire les conditions à la source avant de saisir de vraies données	Auteur	Avant de saisir de vraies données
4	Vercel : garanties documentées pour les plans Pro et Enterprise (DPA, clauses types de 2021) ; pour Hobby, non documentées (le DPA ne nomme pas Hobby). Mistral : partiellement documentées (voir le tableau des prestataires, ligne Mistral)	Garantie non documentée pour Hobby, partielle pour Mistral	Lire les documents contractuels ; passage en Pro pour Vercel	Auteur	Avant de saisir de vraies données
5	Journaux Supabase : d'après la documentation de Supabase consultée le 12 novembre 2026 : 1 jour sur l'offre gratuite (non relevé dans le tableau de bord du projet)	—	Vérifier dans le tableau de bord	Auteur	Cette semaine
6	Aperçu en direct de la vitrine (site tiers, au clic ou, pour la première fiche sans capture, au défilement)	L'adresse IP du visiteur part vers ce site au chargement	Capture hébergée chez l'auteur ; mention « Ouvre un site externe » près du bouton « Voir en direct » seulement (pas près de « Ouvrir le site » ni de « Voir le dossier complet ») (branche fusionnée le 12 novembre 2026, n° 105, `7d0558e`) ; Lovable reste destinataire tiers au clic seulement	Auteur (capture, mention, registre)	Mention : fait le 12 nov. ; capture : non vérifiée
7	T8 (accès client) : base légale et durée **à choisir par le responsable de traitement**. Statut juridique de l'activité : pas encore choisi ; LogMerry est aujourd'hui un projet de formation sans activité commerciale (déclaration de l'auteur, 12 novembre 2026) ; le choix du statut est prévu après le Bachelor ; ce n'est pas un avis juridique.	Fonction non développée	Décider avant toute mise en ligne de T8	Auteur	Après la soutenance
8	Parcours clavier complets (cockpit, saisie) : jamais essayés de bout en bout à la main	Un parcours non utilisable au clavier pourrait passer inaperçu (audit automatique à 100 sur les pages testées)	Contrôle manuel au clavier des parcours du scénario de démonstration, avec notes dans `docs/controles-visuels.md` ; **aucun développement** (périmètre gelé)	Auteur	Avant jeudi 12 nov.

#	LIMITE CONNUE	CONSÉQUENCE	ACTION PRÉVUE	QUI	QUAND
9	Procédure d'exercice des droits : pas de procédure écrite. Mention complète du formulaire : non affichée dans l'application (périmètre gelé), seule la phrase courte l'est ; contact décidé (nom et e-mail, 12 novembre 2026)	Pas de procédure écrite pour les droits	Rédiger la procédure, après validation	Auteur	Après la soutenance
10	La protection contre les sites qui refusent l'intégration est une liste codée en dur (`notion.site`, `notion.so`) ; pour tout autre site qui la refuserait, le cadre affiche la page d'erreur du navigateur et le composant n'y revient pas à la capture. Les réalisations publiées ne sont pas concernées.	Un site tiers qui refuserait l'intégration afficherait une page d'erreur dans le cadre (attendu d'après le code, non observé)	Liste dans `lib/domain/portfolio.ts:63-67` ; composant `components/live-preview.tsx:74`	Auteur	Après la soutenance
11	Restauration testée **une seule fois** (12 novembre 2026, chapitre 12) : données et structure principales restaurées (22 tables, 389 lignes identiques), **deux écarts connus** (fonction `match_chunks` absente ; droits de `anon` sur `public` plus larges : 2 en production, 74 dans le test), **corrections non testées** ; comptes, fichiers du stockage et test d'isolation non couverts ; durée non mesurée	Une reprise réelle après perte de la base n'est pas garantie ; l'export de production a existé le temps du test (dossier supprimé par `rm`, **pas un effacement sécurisé**)	Corriger et retester la restauration ; chapitre 12	Auteur	Avant de saisir de vraies données
12	Mention d'information du formulaire de contact : le modèle de formulaire de la CNIL prévoit « identité et coordonnées » du responsable de traitement ; pour l'exercice des droits, il laisse un emplacement libre (« adresse électronique, postale, coordonnées téléphoniques, etc. ») et précise que ce sont des illustrations à adapter ; des sites secondaires évoquent l'adresse postale du siège. Source : https://www.cnil.fr/fr/exemples-de-formulaire-de-collecte-de-donnees-caractere-personnel (extrait de résultat de recherche, 12 novembre 2026 : « identité et coordonnées du responsable de traitement » ; présenté comme illustration à adapter ou à compléter) ; le texte de l'emplacement libre pour l'exercice des droits n'a pas été revérifié le 12 novembre au soir. **Choix de l'auteur du 12 novembre 2026 :** responsable de traitement Pericat Alexandre, en personne physique ; nom et e-mail (alexandre.pericat@gmail.com), **sans adresse postale**. Ce n'est **pas un avis juridique** ; le minimum exact exigé n'est **pas tranché**	Une mention sans adresse postale pourrait être jugée incomplète : non établi	Exemple de la CNIL consulté le 12 novembre 2026 par extrait de résultat de recherche (texte intégral non relu)	Auteur	Avant la publication de la mention
13	Statut juridique : un nouveau profil reçoit par défaut « Micro-entreprise » et « BNC » avec la pastille « Déclaré » ; la pastille s'affiche sans qu'aucune déclaration n'ait eu lieu (**constaté**, lecture du code le 12 novembre 2026, par l'assistant ; détail dans le registre, section 3 ; profil de démonstration en production non lu)	Le statut affiché n'est pas une déclaration du statut réel, qui n'est pas encore choisi	Aucune : périmètre de code gelé, écart documenté, non corrigé	—	—

Prérequis bloquants avant de saisir de vrais clients ou de publier la vitrine

PRÉREQUIS	POURQUOI	PLAN D'ACTION
Vercel : plan Pro ou autre hébergement	Le plan Hobby est réservé à l'usage non commercial et son DPA couvre Pro et Enterprise	Décision du responsable de traitement ; passage en Pro ou migration, puis relecture du DPA
Supabase : plan Pro, ou export régulier des données de T6 vers un support contrôlé	Le plan Free n'a ni sauvegarde automatique ni protection contre la pause	Décision du responsable de traitement ; à défaut, export manuel planifié (chapitre 12)
SMTP personnalisé (fournisseur À choisir par le responsable de traitement)	La messagerie par défaut de Supabase est limitée et n'envoie qu'aux membres de l'organisation	Choisir le fournisseur, l'ajouter au registre comme sous-traitant, configurer l'envoi
Prérequis de T8 (si T8 est développé)	Sécurité par ligne propre à chaque client, information des utilisateurs, durée de conservation des comptes clients	Tests avec deux comptes clients fictifs ; politique de confidentialité

En attendant, l'application ne contient que des données de test.

Annexe : purges automatiques (proposition, non activée)

> *En deux phrases.* Ce chapitre documente quatre purges automatiques (historique de l'assistant, prospects, messages du formulaire de contact, empreintes anti-abus) *sans les activer* : le SQL n'est ni appliqué ni exécuté, et aucune extension ni migration n'est installée. La mise en service prévue est un *essai à blanc pendant deux semaines*, puis la suppression réelle sur accord du responsable de traitement, après *export des données* (le plan gratuit de Supabase n'a pas de sauvegarde : toute suppression est irréversible).

Rédigé le 9 novembre 2026 d'après la base réelle (lecture seule) et le code. **Limite du SQL : il n'a pas été exécuté, même sur une base de test** ; il sera essayé sur des données de test (droits, sécurité par ligne) avant toute activation.

14.1

Règles retenues (décisions du responsable de traitement, 9 novembre 2026)

TRAITEMENT	RÈGLE	REMARQUE
T3, historique de l'assistant	Messages de plus de 12 mois supprimés chaque jour (citations en cascade). La question contenue dans le titre des brouillons « À documenter : … » est remplacée par « À documenter »	Il n'existe pas de table de conversations : seules `messages` et `message_citations`
T1, prospects	Supprimés 3 ans après la date de référence : la plus récente entre la fiche, ses notes (date de **création**), ses devis (date du devis). Notes et index supprimés avec la fiche. Devis sans suite supprimés 3 ans après leur date	Les clients ne sont **pas** purgés (5 ans, à la main). Un prospect « perdu » reste un prospect
T4, messages du formulaire	Supprimés 3 ans après leur réception (`created_at`), s'ils ne sont pas liés à une fiche	Repère : colonne `notes.source` (migration 0)
`contact_submissions`	Empreintes supprimées après 30 jours	Usage uniquement anti-abus : plafonds par heure et par jour, doublons sur 24 h

14.2

Clés étrangères vers `clients`, `quotes` et `notes`

Relevé dans la base réelle le 9 novembre 2026 (lecture seule).

TABLE SOURCE	CIBLE	À LA SUPPRESSION DE LA CIBLE
`contacts`	`clients`	suppression en cascade
`missions`	`clients`	**refusée** (`RESTRICT`)
`quotes`	`clients`	**refusée** (`NO ACTION`)

TABLE SOURCE	CIBLE	À LA SUPPRESSION DE LA CIBLE
`notes`	`clients`	détachement (`SET NULL`)
`invoices`	`quotes`	**refusée** (`NO ACTION`)
`note_chunks`	`notes`	suppression en cascade
`message_citations`	`notes`	détachement (`SET NULL`)
`user_stories`	`notes`	détachement (`SET NULL`)

Aucune de ces clés ne peut supprimer ni détacher une facture. Les factures référencent `missions` et `quotes` sans suppression ni détachement en cascade, et les encaissements (`payments`) référencent `invoices` de la même façon. Les fonctions ci-dessous excluent en plus, **explicitement**, tout prospect lié à une facture.

Mises à jour automatiques de `clients.updated_at`. Un déclencheur la remet à jour à chaque `UPDATE` de la fiche. Les seules mises à jour du code sont la modification de la fiche et le passage au statut « client » (action de l'application et fonction SQL d'acceptation d'un devis). Ni l'indexation, ni les notes, ni les devis ne la modifient. À l'inverse, `notes.updated_at` est remise à jour par **tout** `UPDATE` d'une note, dont chaque changement d'état d'indexation : c'est pourquoi les règles utilisent `created_at`.

14.3

Migration 0 : repère des messages de contact

À appliquer avant les fonctions. L'ordre compte : colonne, rattrapage, puis déclencheurs.

```
alter table public.notes
  add column source text not null default 'app' check (source in ('app', 'contact_form'));

-- Rattrapage sur le titre, quel que soit le statut. Contrôler d'abord : select count(*) from public.notes where
title like 'Message reçu · %';
update public.notes set source = 'contact_form' where title like 'Message reçu · %';

-- Déclencheurs créés APRÈS le rattrapage.
create function public.notes_source_immutable() returns trigger
language plpgsql set search_path = '' as $$
begin
  if new.source is distinct from old.source then
    raise exception 'notes.source est immuable' using errcode = '42501';
  end if;
  return new;
end $$;
create trigger notes_source_immutable before update of source on public.notes
  for each row execute function public.notes_source_immutable();

-- Dernier rempart : aucun extrait (donc aucun envoi à Mistral) pour un message de contact.
create function public.note_chunks_no_contact() returns trigger
language plpgsql set search_path = '' as $$
begin
  if exists (select 1 from public.notes n where n.id = new.note_id and n.source = 'contact_form') then
    raise exception 'un message de contact ne s''indexe pas' using errcode = '42501';
  end if;
  return new;
end $$;
create trigger note_chunks_no_contact before insert on public.note_chunks
  for each row execute function public.note_chunks_no_contact();

-- La fonction ouverte aux visiteurs (celle de `supabase/migrations/20261107110000_contact_form_limits.sql:21-
81`, mise en forme resserrée ; la base déployée n'a pas été interrogée) : un seul champ ajouté, `source`.
create or replace function public.submit_contact_message(p_name text, p_email text, p_message text)
```

```
returns boolean language plpgsql security definer set search_path = '' as $$
declare
  v_owner uuid;
  v_name text := regexp_replace(btrim(coalesce(p_name, '')), '[\r\n\t]+', ' ', 'g');
  v_email text := btrim(coalesce(p_email, ''));
  v_message text := btrim(coalesce(p_message, ''));
  v_email_hash text;
  v_message_hash text;
begin
  if char_length(v_name) not between 1 and 200
     or char_length(v_email) > 254 or v_email !~ '^[^\s@]+@[^\s@]+$'
     or char_length(v_message) not between 10 and 4000 then
    raise exception 'invalid' using errcode = '22023';
  end if;
  select owner_id into v_owner from public.contact_form_settings where enabled;
  if v_owner is null then return false; end if;
  v_email_hash := md5(lower(v_email));
  v_message_hash := md5(v_message);
  delete from public.contact_submissions where created_at < now() - interval '30 days';
  if exists (select 1 from public.contact_submissions
              where owner_id = v_owner and email_hash = v_email_hash and message_hash = v_message_hash
                and created_at > now() - interval '24 hours') then
    return true;
  end if;
  if (select count(*) from public.contact_submissions where owner_id = v_owner and created_at > now() - interval
'1 hour') >= 5
     or (select count(*) from public.contact_submissions where owner_id = v_owner and created_at > now() -
interval '1 day') >= 30
     or (select count(*) from public.contact_submissions where owner_id = v_owner and email_hash = v_email_hash
and created_at > now() - interval '1 day') >= 3 then
    raise exception 'rate' using errcode = '54000';
  end if;
  insert into public.contact_submissions (owner_id, email_hash, message_hash) values (v_owner, v_email_hash,
v_message_hash);
  insert into public.notes (owner_id, title, body, status, type, source)
  values (
    v_owner,
    left('Message reçu · ' || v_name, 200),
    'Texte reçu d''un visiteur via le formulaire du portfolio, non vérifié.' || E'\n\n'
      || 'De : ' || v_name || E'\n'
      || 'E-mail : ' || v_email || E'\n'
      || 'Reçu le : ' || to_char(now() at time zone 'Europe/Paris', 'DD/MM/YYYY HH24:MI') || E'\n\n'
      || v_message,
    'draft', 'note', 'contact_form');
  return true;
end $$;
```

Côté code (à faire avec la migration) : `isContactMessage` lit `source` au lieu du titre, les lectures de notes ajoutent la colonne, et les types sont régénérés.

14.4

Journal des purges

Date, fonction, compteurs : **jamais de contenu** (ni titre, ni nom, ni texte).

```
create table public.purge_log (
  id              uuid primary key default gen_random_uuid(),
  ran_at          timestamptz not null default now(),
  fn              text    not null,
  dry_run         boolean not null,
  rows_candidates integer not null default 0,
  rows_deleted    integer not null default 0,
  rows_failed     integer not null default 0,
```

```
  error_state     text                              -- code SQLSTATE seulement
);
alter table public.purge_log enable row level security;   -- aucune politique
revoke all on public.purge_log from anon, authenticated;
-- Exception à la règle owner_id = auth.uid() : table système sans propriétaire (acceptée par le responsable de
traitement le 9 novembre 2026).
```

14.5

T3 : historique de l'assistant et titres des brouillons

```
create or replace function public.purge_old_messages(p_dry_run boolean default true) returns jsonb
language plpgsql set search_path = '' as $$
declare
  v_ids uuid[]; v_titles integer; v_deleted integer := 0; v_renamed integer := 0;
  v_failed integer := 0; v_state text;
begin
  select coalesce(array_agg(id), '{}') into v_ids from public.messages where created_at < now() - interval '12
months';
  select count(*)::integer into v_titles from public.notes
    where status = 'draft' and title like 'À documenter : %' and created_at < now() - interval '12 months';
  if not p_dry_run then
    begin
      delete from public.messages where id = any(v_ids);           -- citations en cascade
      get diagnostics v_deleted = row_count;
    exception when others then v_failed := v_failed + 1; v_state := sqlstate; end;
    begin
      update public.notes set title = 'À documenter'              -- la question n'est plus dans le titre
        where status = 'draft' and title like 'À documenter : %' and created_at < now() - interval '12 months';
      get diagnostics v_renamed = row_count;
    exception when others then v_failed := v_failed + 1; v_state := sqlstate; end;
  end if;
  insert into public.purge_log (fn, dry_run, rows_candidates, rows_deleted, rows_failed, error_state)
    values ('purge_old_messages', p_dry_run, cardinality(v_ids) + v_titles, v_deleted + v_renamed, v_failed,
v_state);
  if v_failed > 0 then raise warning 'purge_old_messages : % échec(s), voir purge_log', v_failed; end if;
  return jsonb_build_object('dry_run', p_dry_run, 'messages', cardinality(v_ids), 'titles', v_titles,
                            'deleted', v_deleted, 'renamed', v_renamed, 'failed', v_failed,
                            'ids', to_jsonb(v_ids[1:200]), 'ids_truncated', cardinality(v_ids) > 200);
end $$;
```

14.6

T1 : prospects et devis sans suite

Valeurs de `clients.status` : `prospect` et `client`. Un prospect jamais purgé : une mission, un devis accepté, un devis lié à une facture (exclusion explicite, y compris par une mission).

```
create or replace function public.purge_stale_prospects(p_dry_run boolean default true) returns jsonb
language plpgsql set search_path = '' as $$
declare
  r record;
  v_cutoff    timestamptz := now() - interval '3 years';
  v_prospects uuid[] := '{}';  v_quotes uuid[] := '{}';  v_notes integer := 0;
  v_del_p integer := 0; v_del_q integer := 0; v_failed integer := 0; v_state text;
begin
  -- A. prospects éligibles : une transaction interne par fiche (un échec n'est ni silencieux ni bloquant)
  for r in
    with cand as (
      select c.id,
```

```
             greatest(
               c.updated_at,
               coalesce((select max(nt.created_at) from public.notes nt where nt.client_id = c.id),
c.updated_at),
               coalesce((select max(coalesce(q.sent_on::timestamptz, q.created_at))
                         from public.quotes q where q.client_id = c.id), c.updated_at)
             ) as ref
      from public.clients c
      where c.status = 'prospect'
        and not exists (select 1 from public.missions m where m.client_id = c.id)
        and not exists (select 1 from public.quotes q where q.client_id = c.id and q.status = 'accepted')
        -- exclusion explicite de tout prospect lié à une facture, par un devis ou par une mission
        and not exists (select 1 from public.invoices i join public.quotes q on q.id = i.quote_id where
q.client_id = c.id)
        and not exists (select 1 from public.invoices i join public.missions m on m.id = i.mission_id where
m.client_id = c.id)
    )
    select id from cand where ref < v_cutoff
  loop
    v_prospects := v_prospects || r.id;
    v_quotes    := v_quotes || array(select q.id from public.quotes q where q.client_id = r.id);
    v_notes     := v_notes + (select count(*)::integer from public.notes nt where nt.client_id = r.id);
    if not p_dry_run then
      begin
        delete from public.notes   where client_id = r.id;   -- leurs extraits (note_chunks) partent en cascade
        delete from public.quotes  where client_id = r.id;   -- aucun n'est accepté ni facturé (filtres ci-
dessus)
        delete from public.clients where id = r.id;          -- ses contacts partent en cascade
        v_del_p := v_del_p + 1;
      exception when others then
        v_failed := v_failed + 1; v_state := sqlstate;       -- journalisé ; la boucle continue
      end;
    end if;
  end loop;

  -- B. devis sans suite des prospects restants : ni acceptés, ni facturés, ni liés à une mission, datés de plus
de 3 ans
  for r in
    select q.id from public.quotes q join public.clients c on c.id = q.client_id
    where c.status = 'prospect' and q.status <> 'accepted' and q.mission_id is null
      and coalesce(q.sent_on::timestamptz, q.created_at) < v_cutoff
      and not exists (select 1 from public.invoices i where i.quote_id = q.id)
      and q.id <> all (v_quotes)
  loop
    v_quotes := v_quotes || r.id;
    if not p_dry_run then
      begin
        delete from public.quotes where id = r.id;
        v_del_q := v_del_q + 1;
      exception when others then
        v_failed := v_failed + 1; v_state := sqlstate;
      end;
    end if;
  end loop;

  insert into public.purge_log (fn, dry_run, rows_candidates, rows_deleted, rows_failed, error_state)
    values ('purge_stale_prospects', p_dry_run, cardinality(v_prospects) + cardinality(v_quotes), v_del_p +
v_del_q, v_failed, v_state);
  if v_failed > 0 then raise warning 'purge_stale_prospects : % échec(s), voir purge_log', v_failed; end if;
  return jsonb_build_object('dry_run', p_dry_run,
    'prospects', jsonb_build_object('count', cardinality(v_prospects), 'deleted', v_del_p, 'ids',
to_jsonb(v_prospects[1:200])),
    'quotes',    jsonb_build_object('count', cardinality(v_quotes),    'deleted', v_del_q, 'ids',
to_jsonb(v_quotes[1:200])),
    'notes_linked', v_notes, 'failed', v_failed);
end $$;
```

14.7

T4 : messages du formulaire de contact et empreintes anti-abus

Dernier échange = date de réception (`created_at`). Une note liée à une fiche suit la règle de T1.

```
create or replace function public.purge_old_contact_messages(p_dry_run boolean default true) returns jsonb
language plpgsql set search_path = '' as $$
declare v_ids uuid[]; v_deleted integer := 0; v_failed integer := 0; v_state text;
begin
  select coalesce(array_agg(id), '{}') into v_ids from public.notes
    where source = 'contact_form' and client_id is null and created_at < now() - interval '3 years';
  if not p_dry_run then
    begin
      delete from public.notes where id = any(v_ids);
      get diagnostics v_deleted = row_count;
    exception when others then v_failed := 1; v_state := sqlstate; end;
  end if;
  insert into public.purge_log (fn, dry_run, rows_candidates, rows_deleted, rows_failed, error_state)
    values ('purge_old_contact_messages', p_dry_run, cardinality(v_ids), v_deleted, v_failed, v_state);
  if v_failed > 0 then raise warning 'purge_old_contact_messages : échec, voir purge_log'; end if;
  return jsonb_build_object('dry_run', p_dry_run, 'count', cardinality(v_ids), 'deleted', v_deleted, 'failed',
v_failed,
                            'ids', to_jsonb(v_ids[1:200]));
end $$;

-- Empreintes anti-abus : 30 jours. `submit_contact_message` les supprime déjà à chaque nouveau message ;
-- cette purge couvre le cas où aucun message n'arrive.
create or replace function public.purge_contact_submissions(p_dry_run boolean default true) returns jsonb
language plpgsql set search_path = '' as $$
declare v_candidates integer; v_deleted integer := 0; v_failed integer := 0; v_state text;
begin
  select count(*)::integer into v_candidates from public.contact_submissions where created_at < now() - interval
'30 days';
  if not p_dry_run then
    begin
      delete from public.contact_submissions where created_at < now() - interval '30 days';
      get diagnostics v_deleted = row_count;
    exception when others then v_failed := 1; v_state := sqlstate; end;
  end if;
  insert into public.purge_log (fn, dry_run, rows_candidates, rows_deleted, rows_failed, error_state)
    values ('purge_contact_submissions', p_dry_run, v_candidates, v_deleted, v_failed, v_state);
  if v_failed > 0 then raise warning 'purge_contact_submissions : échec, voir purge_log'; end if;
  return jsonb_build_object('dry_run', p_dry_run, 'count', v_candidates, 'deleted', v_deleted, 'failed',
v_failed);
end $$;

revoke all on function public.purge_old_messages(boolean), public.purge_stale_prospects(boolean),
  public.purge_old_contact_messages(boolean), public.purge_contact_submissions(boolean)
  from public, anon, authenticated;
```

14.8

Planification prévue

Étapes, **dans cet ordre** : (1) export des données ; (2) essai sur des données de test (droits, sécurité par ligne) ; (3) installation de `pg_cron` (schéma et droits : **À confirmer** dans la documentation de Supabase) ; (4) **deux semaines en essai à blanc** : les tâches appellent les fonctions avec `true`, et le journal est relu chaque jour ; (5) passage à `false`, **sur accord du responsable de traitement seulement**.

```
-- Étape 4 : essai à blanc
select cron.schedule('purge-old-messages',        '17 3 * * *', 'select public.purge_old_messages(true)');
```

```
select cron.schedule('purge-stale-prospects',      '27 3 * * *', 'select public.purge_stale_prospects(true)');
select cron.schedule('purge-old-contact-messages', '37 3 * * *', 'select
public.purge_old_contact_messages(true)');
select cron.schedule('purge-contact-submissions',  '47 3 * * *', 'select
public.purge_contact_submissions(true)');
-- Étape 5 (accord du responsable de traitement) : cron.unschedule puis cron.schedule avec (false)

-- Contrôle quotidien du journal
select * from public.purge_log where rows_failed > 0 or dry_run order by ran_at desc limit 20;
```